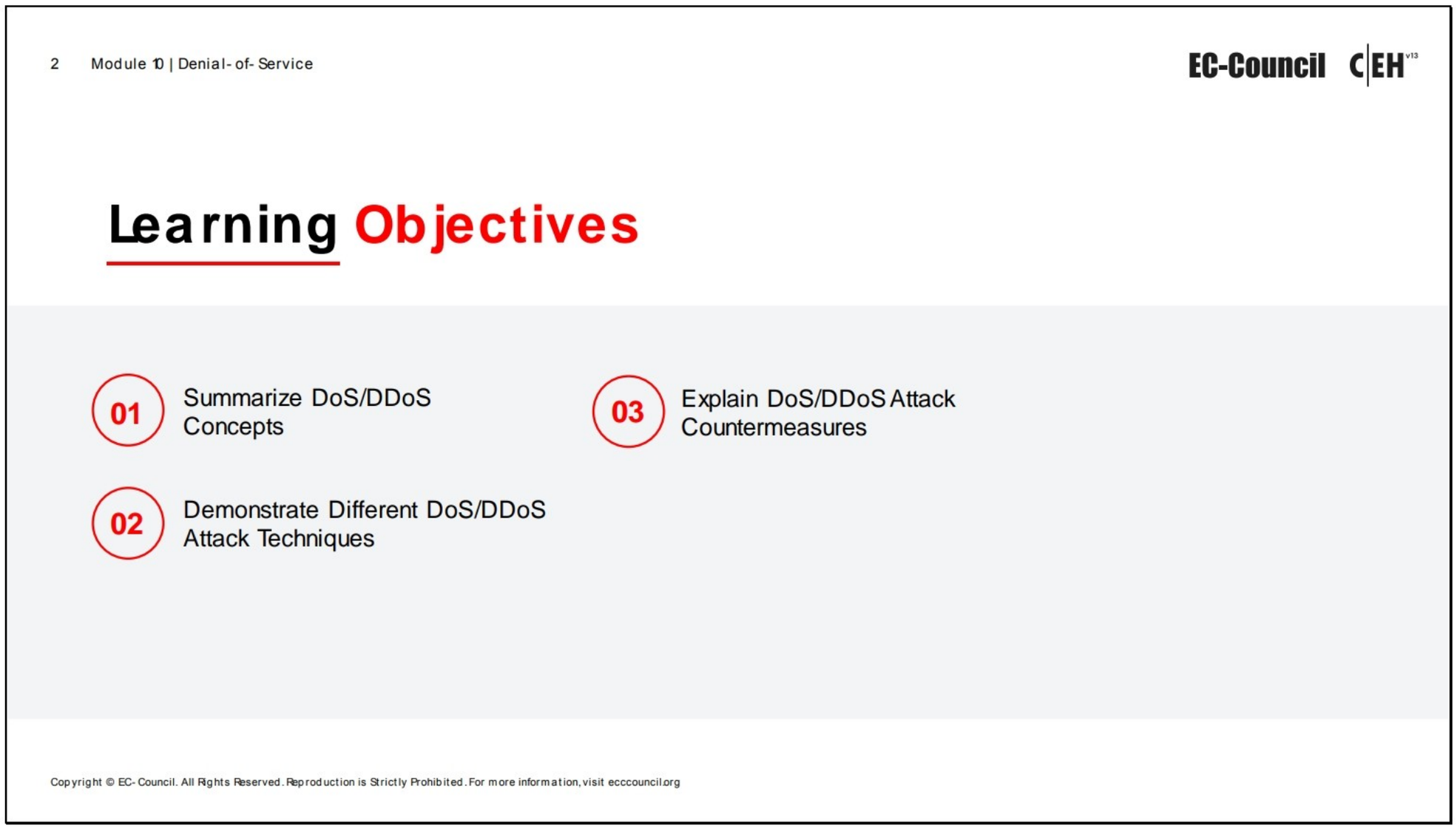
Module 10

Denial-of-Service

EC-Council
Official Curricula

EC-Council C|EH v13 Certified Ethical Hacker

This page is intentionally left blank.



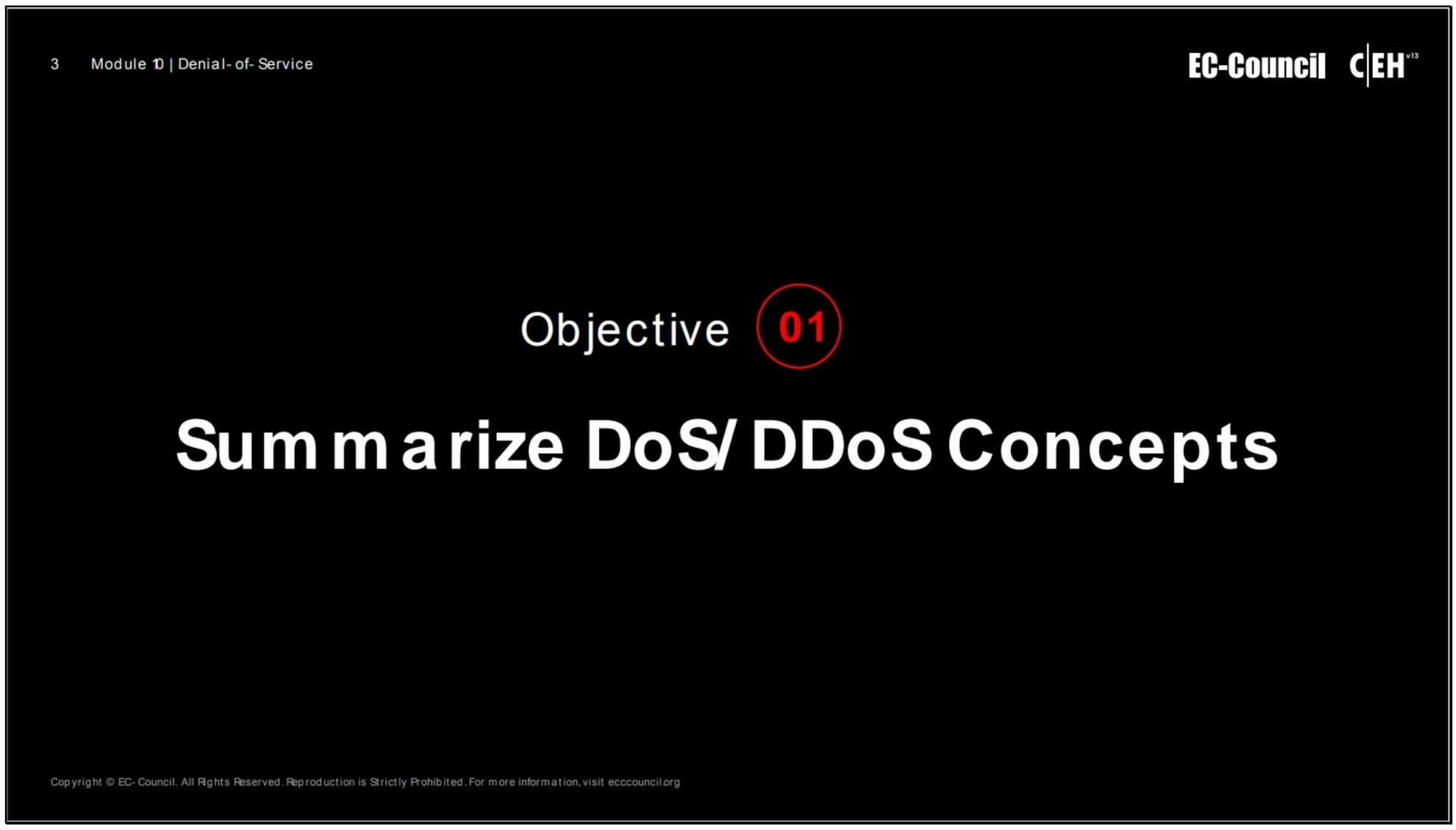
Learning Objectives

Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) attacks are a major threat to computer networks. These attacks attempt to make a machine or network resource unavailable to its authorized users. Usually, DoS/DDoS attacks exploit vulnerabilities in the implementation of the Transmission Control Protocol (TCP)/Internet Protocol (IP) model or bugs in a specific operating system (OS).

At the end of this module, you will be able to do the following:

- Describe DoS/DDoS concepts
- Describe botnets
- Understand various DoS/DDoS attack techniques
- Explain different DoS/DDoS attack tools
- Illustrate DoS/DDoS case study
- Apply best practices to mitigate DoS/DDoS attacks
- Apply various DoS/DDoS protection tools

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



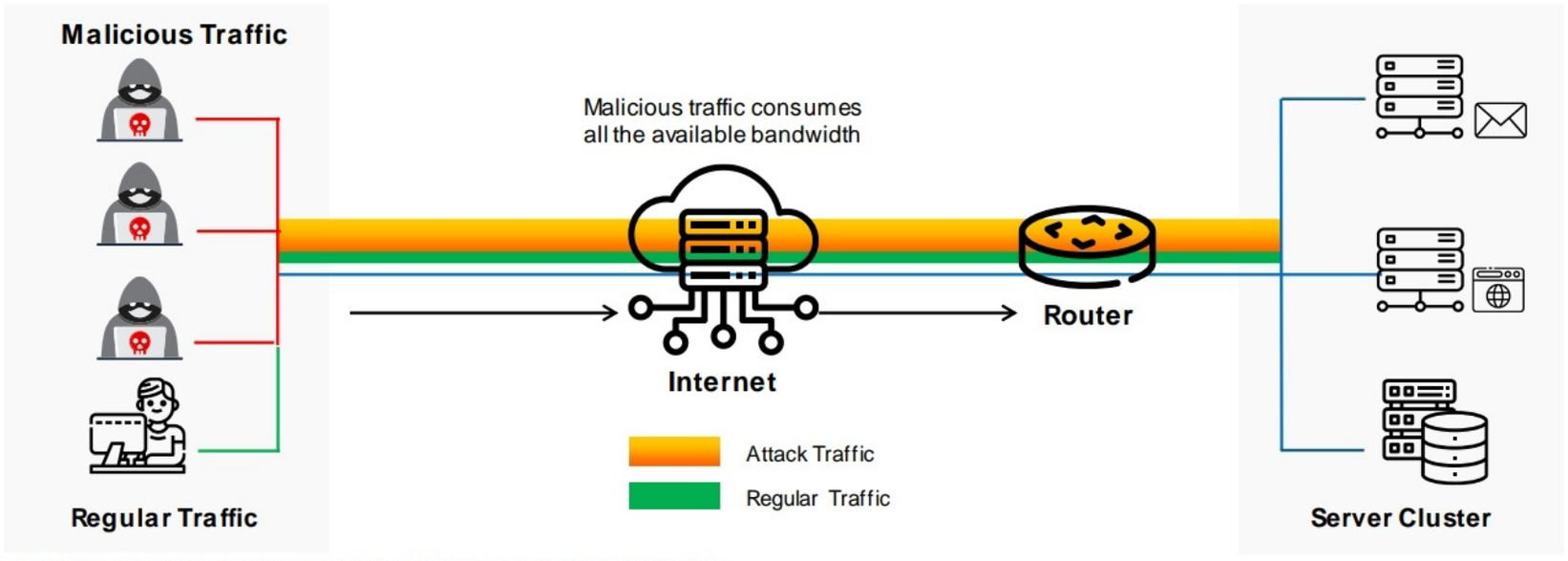
DoS/DDoS Concepts

For a good understanding of DoS/DDoS attacks, one must be familiar with related concepts in advance. This section defines DoS and DDoS attacks and discusses how DDoS attacks work.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

What is a DoS Attack?

- Denial-of-Service (DoS) is an attack on a computer or network that **reduces, restricts, or prevents** accessibility of system resources to its legitimate users
- In a DoS attack, attackers flood the victim system with **non-legitimate service requests or traffic** to overload its resources
- The impact of DoS attacks include loss of goodwill, network outages, financial losses, and operational disruptions



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

What is a DoS Attack?

A DoS attack is an attack on a computer or network that reduces, restricts, or prevents access to system resources for legitimate users. In a DoS attack, attackers flood a victim's system with nonlegitimate service requests or traffic to overload its resources and bring down the system, leading to the unavailability of the victim's website or at least significantly reducing the victim's system or network performance. The goal of a DoS attack is to keep legitimate users from using the system, rather than to gain unauthorized access to a system or to corrupt data.

The following are examples for types of DoS attacks:

- Flooding the victim's system with more traffic than it can handle
- Flooding a service (e.g., Internet Relay Chat (IRC)) with more events than it can handle
- Crashing a TCP/IP stack by sending corrupt packets
- Crashing a service by interacting with it in an unexpected manner
- Hanging a system by causing it to go into an infinite loop

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

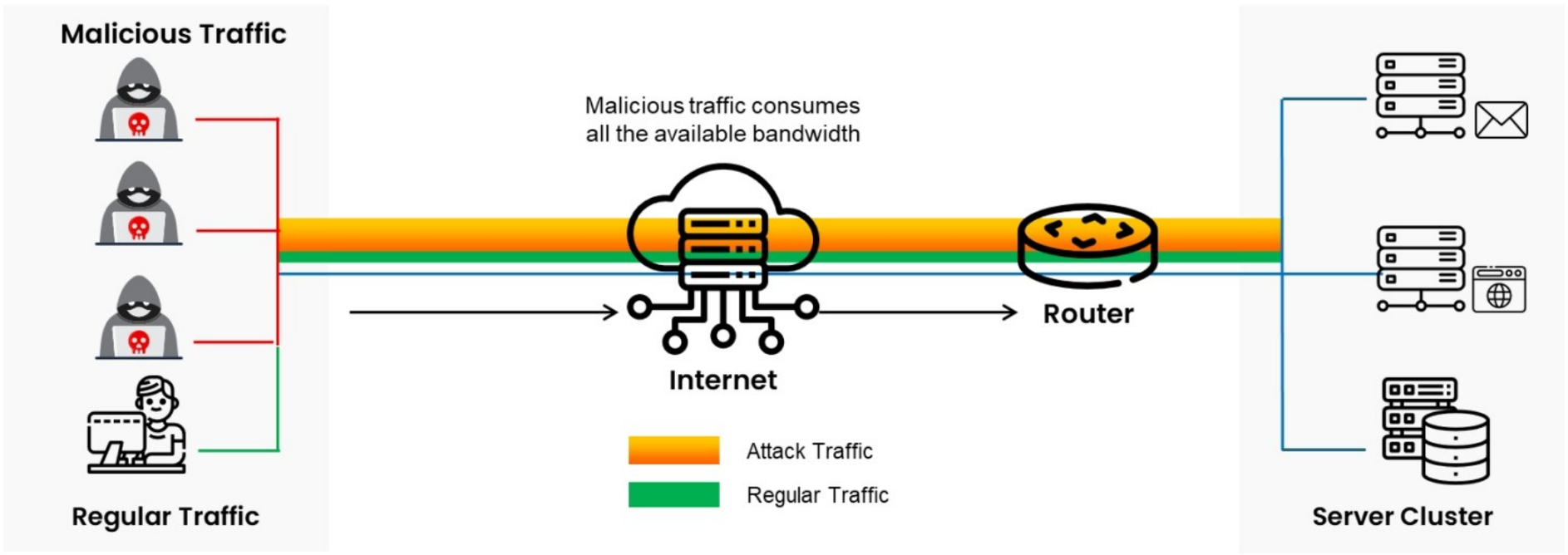


Figure 10.1: Schematic of a DoS attack

DoS attacks have various forms and target various services. The attacks may cause the following:

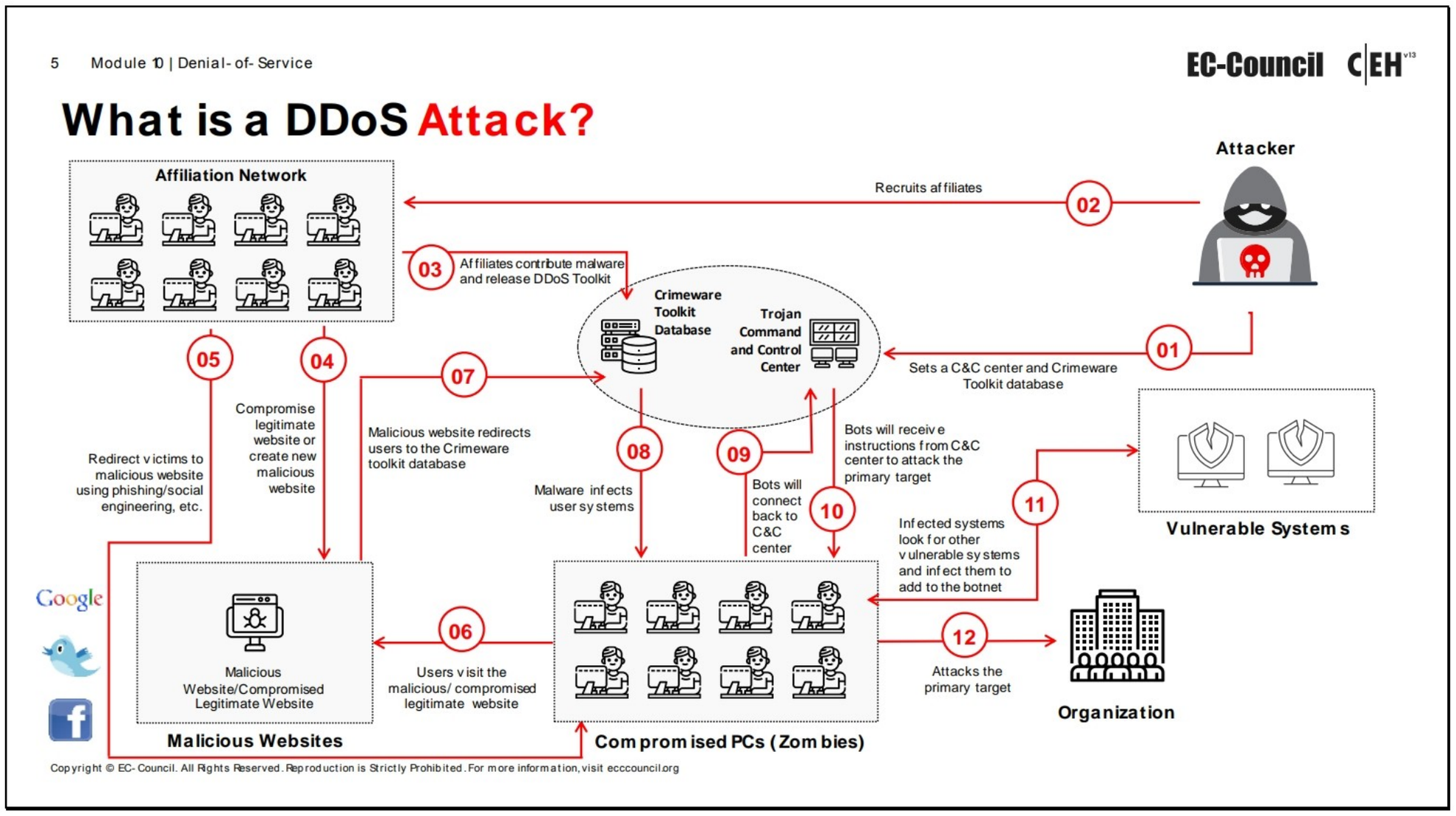
- Consumption of resources
- Consumption of bandwidth, disk space, CPU time, or data structures
- Actual physical destruction or alteration of network components
- Destruction of programming and files in a computer system

In general, DoS attacks target network bandwidth or connectivity. Bandwidth attacks overflow the network with a high volume of traffic by using existing network resources, thereby depriving legitimate users of these resources. Connectivity attacks overflow a system with a large number of connection requests, consuming all available OS resources to prevent the system from processing legitimate user requests.

Consider a food catering company that conducts much of its business over the phone. If an attacker wants to disrupt this business, they need to find a way to block the company's phone lines, which would make it impossible for the company to do business. A DoS attack works along the same lines—the attacker uses up all the ways to connect to the victim's system, making legitimate business impossible.

DoS attacks are a kind of security breach that does not generally result in the theft of information. However, these attacks can harm the target in terms of time and resources. Furthermore, security failure might cause the loss of a service such as email. In the worst-case scenario, a DoS attack can cause the accidental destruction of the files and programs of millions of people who were connected to the victim's system at the time of the attack. The impact of DoS attacks includes loss of goodwill, network outages, financial losses, and operational disruptions

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



What is a DDoS Attack?

Source: *https://www.techtarget.com*

A DDoS attack is a large-scale, coordinated attack on the availability of services on a victim's system or network resources, and it is launched indirectly through many compromised computers (botnets) on the Internet.

As defined by the World Wide Web Security FAQ, "A distributed denial-of-service (DDoS) attack uses many computers to launch a coordinated DoS attack against one or more targets. Using client/server technology, the perpetrator is able to multiply the effectiveness of the denial of service significantly by harnessing the resources of multiple unwitting accomplice computers, which serve as attack platforms." The flood of incoming messages to the target system essentially forces it to shut down, thereby denying service to legitimate users.

The services under attack belong to the "primary victim," whereas the compromised systems used to launch the attack are called "secondary victims." The use of secondary victims in performing a DDoS attack enables the attacker to mount a large and disruptive attack while making it difficult to track down the original attacker.

The primary objective of a DDoS attack is to first gain administrative access on as many systems as possible. In general, attackers use a customized attack script to identify potentially vulnerable systems. After gaining access to the target systems, the attacker uploads and runs DDoS software on these systems at the time chosen to launch the attack.

DDoS attacks have become popular because of the easy accessibility of exploit plans and the negligible amount of brainwork required to execute them. These attacks can be very dangerous because they can quickly consume the largest hosts on the Internet, rendering them useless.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How do DDoS Attacks Work?

In a DDoS attack, many applications barrage a target browser or network with fake exterior requests that make the system, network, browser, or site slow, useless, and disabled or unavailable.

The attacker initiates the DDoS attack by sending a command to zombie agents, which are Internet-connected computers compromised by an attacker through malware programs to perform various malicious activities through a command and control (C&C) server. These zombie agents send a connection request to a large number of reflector systems with the spoofed IP address of the victim, which causes the reflector systems to presume that these requests originate from the victim's machine instead of the zombie agents. Hence, the reflector systems send the requested information (response to the connection request) to the victim. Consequently, the victim's machine is flooded with unsolicited responses from several reflector computers simultaneously, which may either reduce the performance or cause the victim's machine to shut down completely.

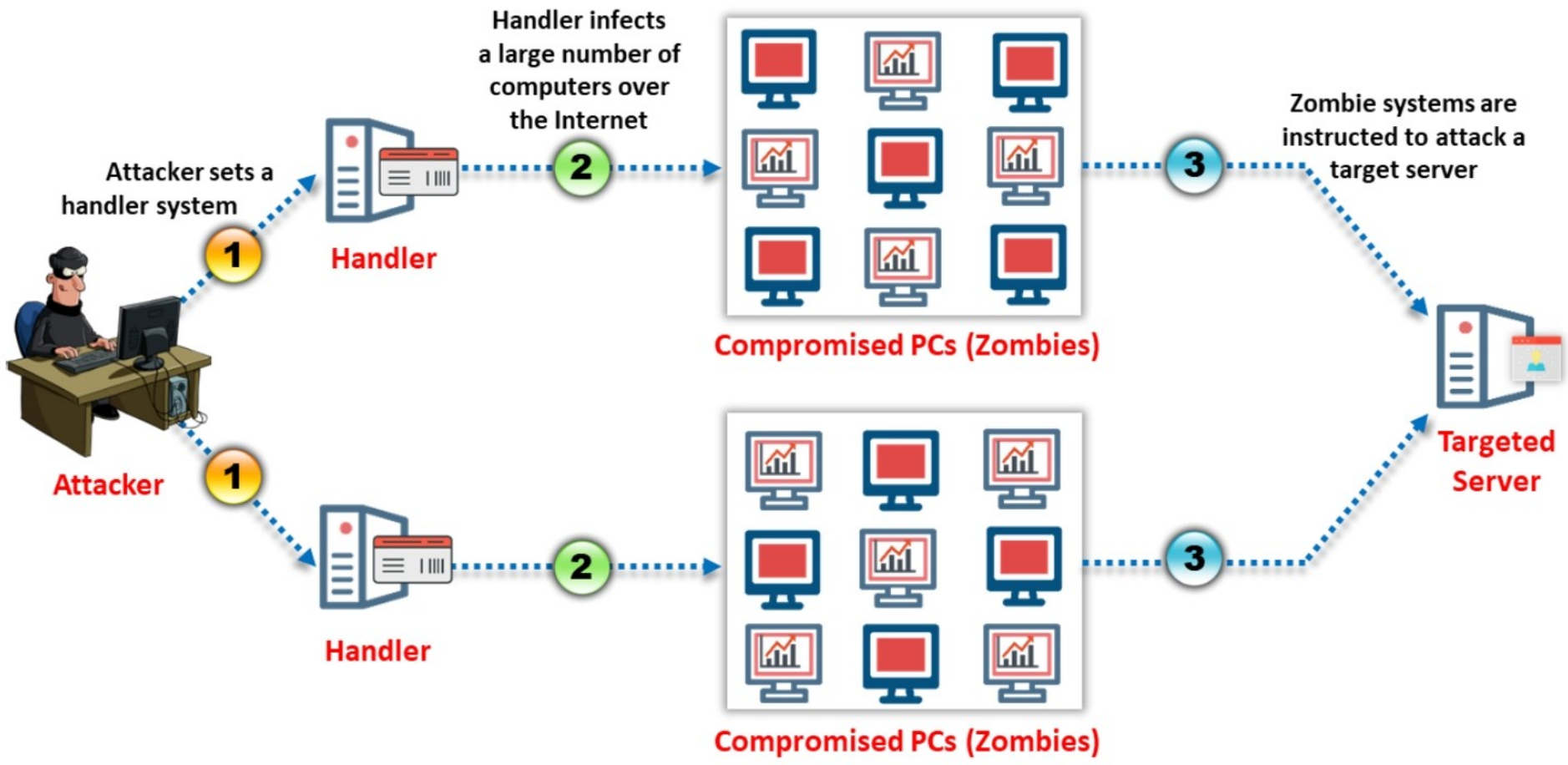


Figure 10.2: Schematic of a DDoS attack

Botnets

The term "bot" is a contraction of "robot" and refers to software applications that run automated tasks over the Internet. Attackers use bots to infect a large number of computers that form a network, or "botnet," allowing them to launch DDoS attacks, generate spam, spread viruses, and commit other types of crime.

This section deals with organized cyber-crime syndicates, organizational charts, botnets, and botnet propagation techniques; botnet ecosystems; scanning methods for finding vulnerable machines; and the propagation of malicious code.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Organized Cyber Crime: Organizational Chart

Organized Crime Syndicates

While cyber criminals worked independently in the past, they now tend to operate in organized groups. They are increasingly associated with organized crime syndicates and take advantage of the sophisticated techniques of these syndicates to engage in illegal activity, usually for monetary benefit. There are organized groups of cyber criminals who work in a hierarchical set up with a predefined revenue-sharing model, which is a kind of major corporation that offers criminal services. Organized groups create and rent botnets and offer various services ranging from the development of malware and hacking of bank accounts to the deployment of massive DoS attacks against any target for a price.

For example, an organized crime syndicate might perform a DDoS attack against a bank to divert the attention of the bank's security team while they clean out bank accounts with stolen account credentials. The growing involvement of organized criminal syndicates in politically motivated cyber warfare and hacktivism is a matter of concern for national security agencies.

Cybercrime features a complicated range of players, and cyber criminals are paid according to the task they perform or the position they hold. The head of the cybercrime organization (i.e., the boss) acts as a business entrepreneur. The boss does not commit any crimes directly. Immediately below the boss in the organizational hierarchy is the "underboss," who sets up a C&C server and crimeware toolkit database to manage the implementation of attacks and provide Trojans. Below the underboss are various "campaign managers" with their own affiliation networks for implementing attacks and stealing data. Finally, resellers sell the stolen data.

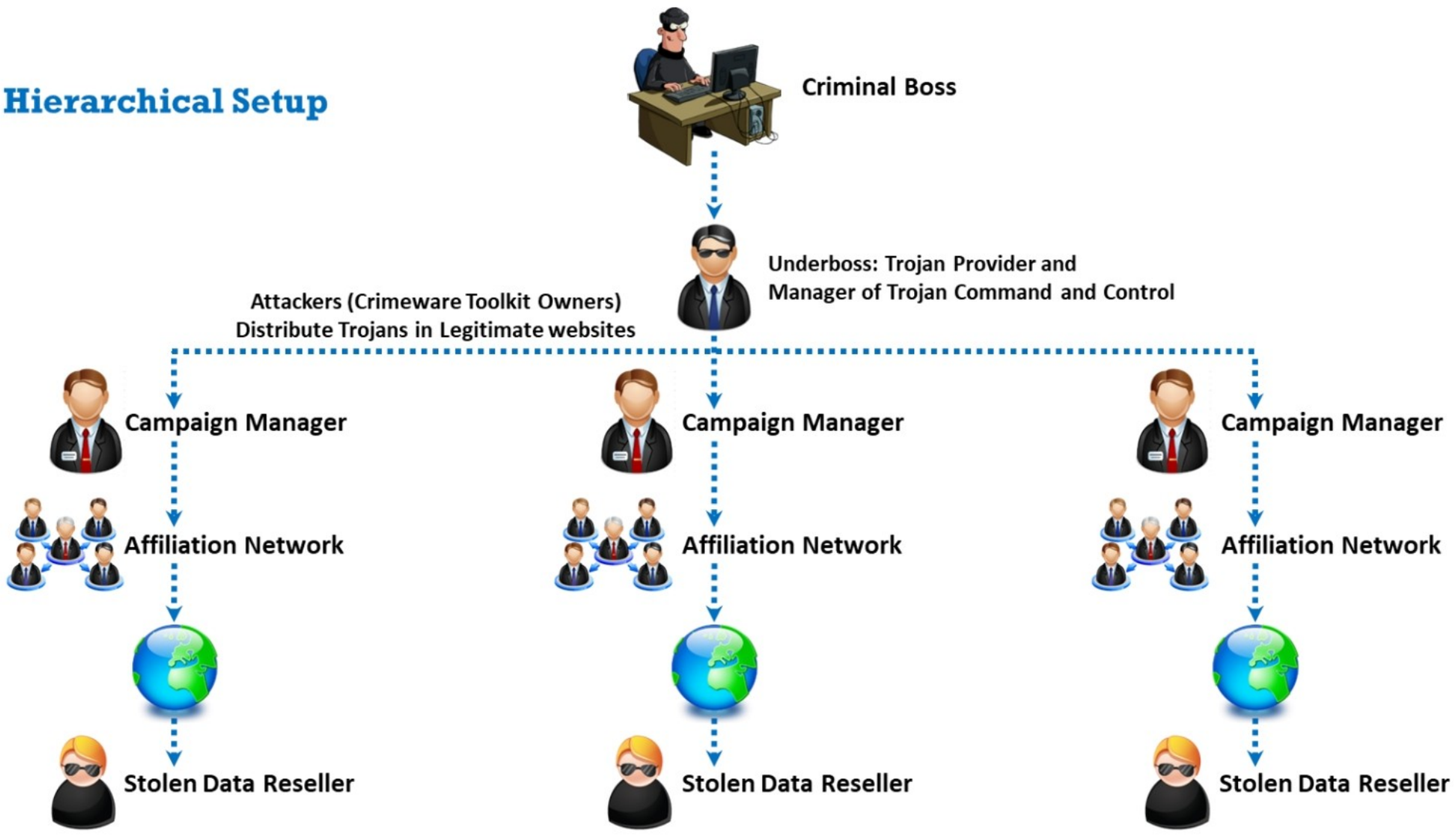


Figure 10.3: Hierarchical setup of a cybercrime organization

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Botnets

Bots are used for benign data collection or data mining activities, such as "web spidering," as well as to coordinate DoS attacks. The main purpose of a bot is to collect data. There are different types of bots, such as Internet bots, IRC bots, and chatter bots. Examples for IRC bots are Cardinal, Sopel, Eggdrop, and EnergyMech.

A botnet (a contraction of "roBOT NETwork") is a group of computers "infected" by bots; however, botnets can be used for both positive and negative purposes. As a hacking tool, a botnet is composed of a huge network of compromised systems. A relatively small botnet of 1,000 bots has a combined bandwidth larger than the bandwidth of most corporate systems.

The advent of botnets led to an enormous increase in cybercrime. Botnets form the core of the cybercriminal activity center that links and unites various parts of the cybercriminal world. Cybercriminal service suppliers are a part of a cybercrime network. They offer services such as malicious code development, bulletproof hosting, the creation of browser exploits, and encryption and packing.

Malicious code is the primary tool used by criminal organizations to commit cybercrimes. Botnet owners order both bots and other malicious programs such as Trojans, viruses, worms, keyloggers, and specially crafted applications to attack remote computers via networks. Developers offer malware services on public sites or closed Internet resources.

Botnets are agents that an intruder can send to a server system to perform an illegal activity. Botnets run hidden programs that allow the identification of system vulnerabilities. Attackers can use botnets to perform the tedious tasks involved in probing a system for known vulnerabilities.

Attackers can use botnets to perform the following:

- **DDoS attacks**: Botnets can generate DDoS attacks, which consume the bandwidth of the victim's computers. Botnets can also overload a system, wasting valuable host system resources and destroying network connectivity.
- **Spamming**: Attackers use a SOCKS proxy for spamming. They harvest email addresses from web pages or other sources.
- **Sniffing traffic**: A packet sniffer observes the data traffic entering a compromised machine. It allows an attacker to collect sensitive information such as credit card numbers and passwords. The sniffer also allows an attacker to steal information from one botnet and use it against another botnet. In other words, botnets can rob one another.
- **Keylogging**: Keylogging is a method of recording the keys typed on a keyboard, and it provides sensitive information such as system passwords. Attackers use keylogging to harvest account login information for services such as PayPal.
- **Spreading new malware**: Botnets can be used to spread new bots.
- **Installing advertisement add-ons**: Botnets can be used to perpetrate a "click fraud" by automating clicks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Google AdSense abuse**: Some companies permit showing Google AdSense ads on their websites for economic benefits. Botnets allow an intruder to automate clicks on an ad, producing a percentage increase in the click queue.
- **Attacks on IRC chat networks**: Also called clone attacks, these attacks are similar to a DDoS attack. A master agent instructs each bot to link to thousands of clones within an IRC network, which can flood the network.
- **Manipulating online polls and games**: Every botnet has a unique address, enabling it to manipulate online polls and games.
- **Mass identity theft**: Botnets can send a large number of emails while impersonating a reputable organization such as eBay. This technique allows attackers to steal information for identity theft.
- **Credential stuffing:** With access to a large number of compromised computers (bots), attackers can perform automated login attempts using stolen credentials on a wide variety of websites, a tactic known as credential stuffing.
- **Cryptocurrency mining:** Attackers can install cryptocurrency mining software on compromised machines within a botnet, using their processing power to mine cryptocurrency without the knowledge or consent of the owners.

The below figure illustrates how an attacker launches a botnet-based DoS attack on a target server. The attacker sets up a bot C&C center, following which they infect a machine (bot) and compromises it. Later, they use this bot to infect and compromise other vulnerable systems available in the network, resulting in a botnet. The bots (also known as zombies) connect to the C&C center and awaits instructions. Subsequently, the attacker sends malicious commands to the bots through the C&C center. Finally, as per the attacker's instructions, the bots launch a DoS attack on a target server, making its services unavailable to legitimate users in the network.

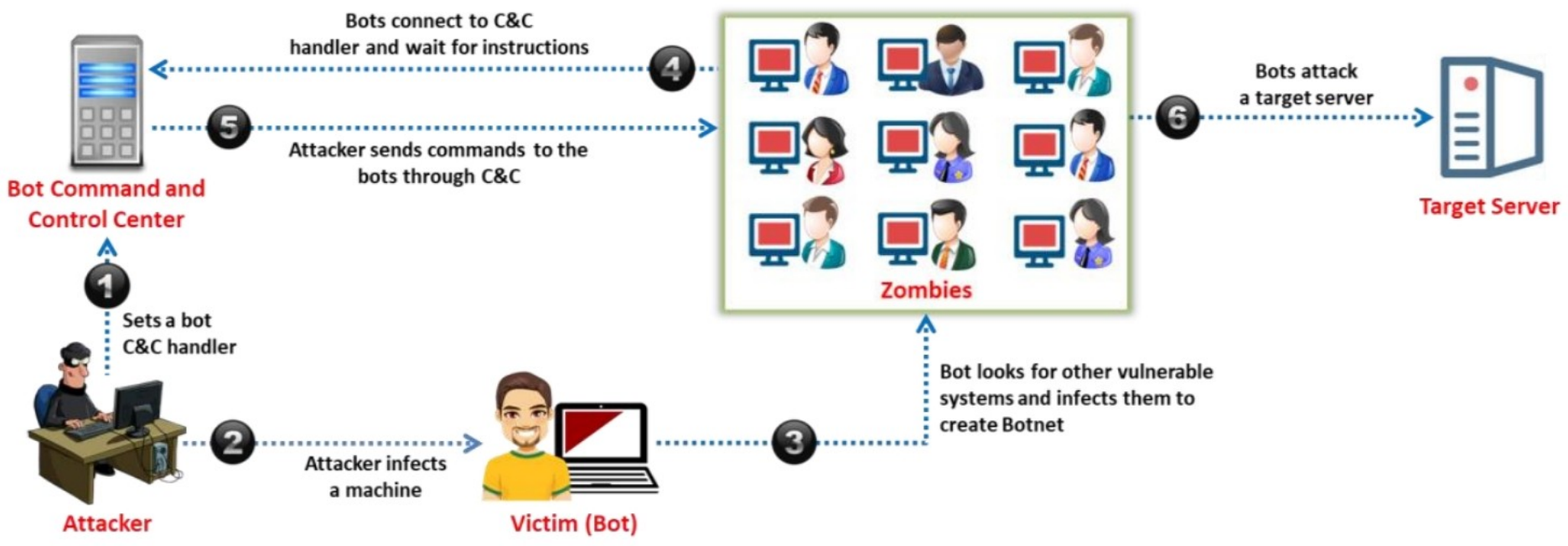


Figure 10.4: Botnet-based DDoS attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

A Typical Botnet Setup

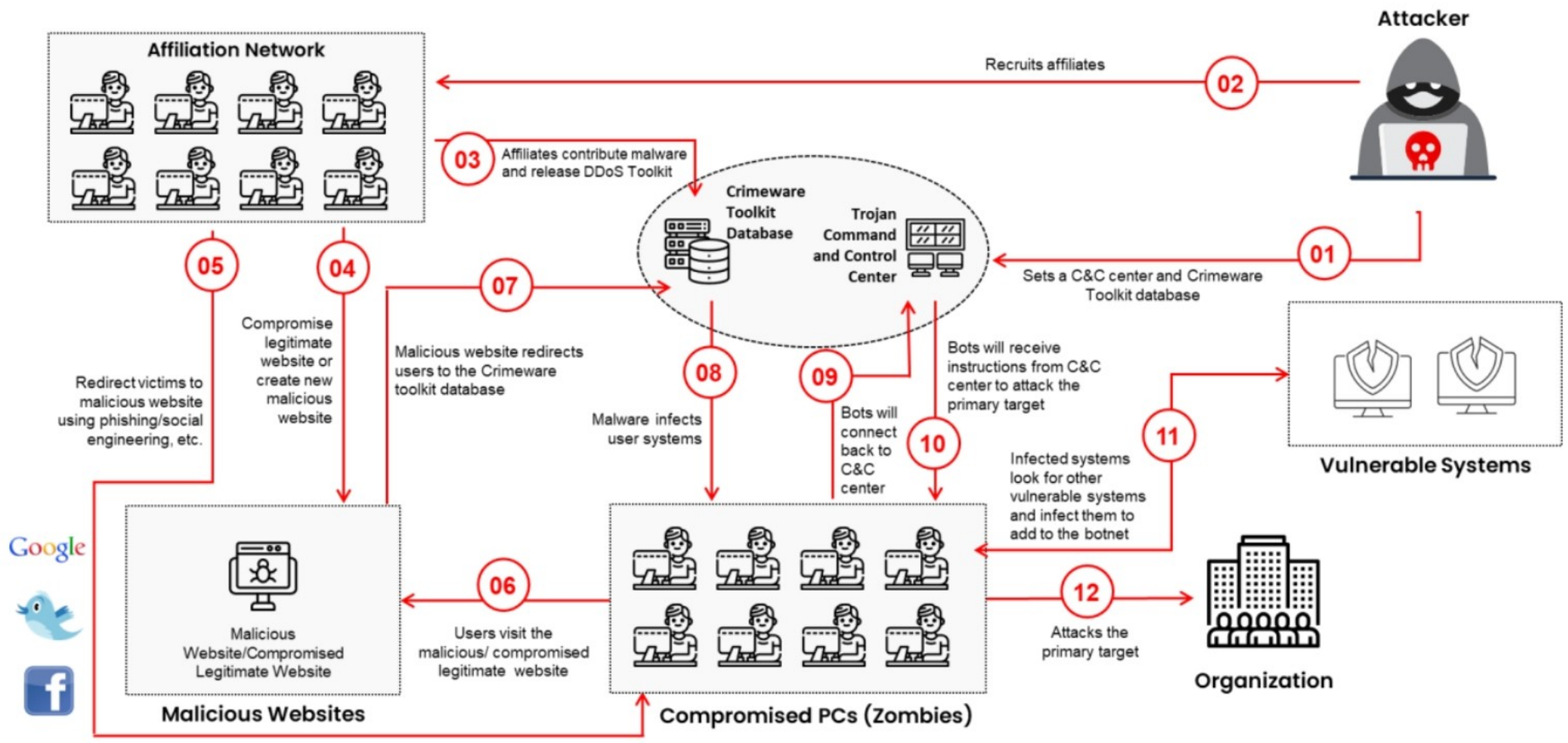


Figure 10.5: Typical botnet setup

Botnet Ecosystem

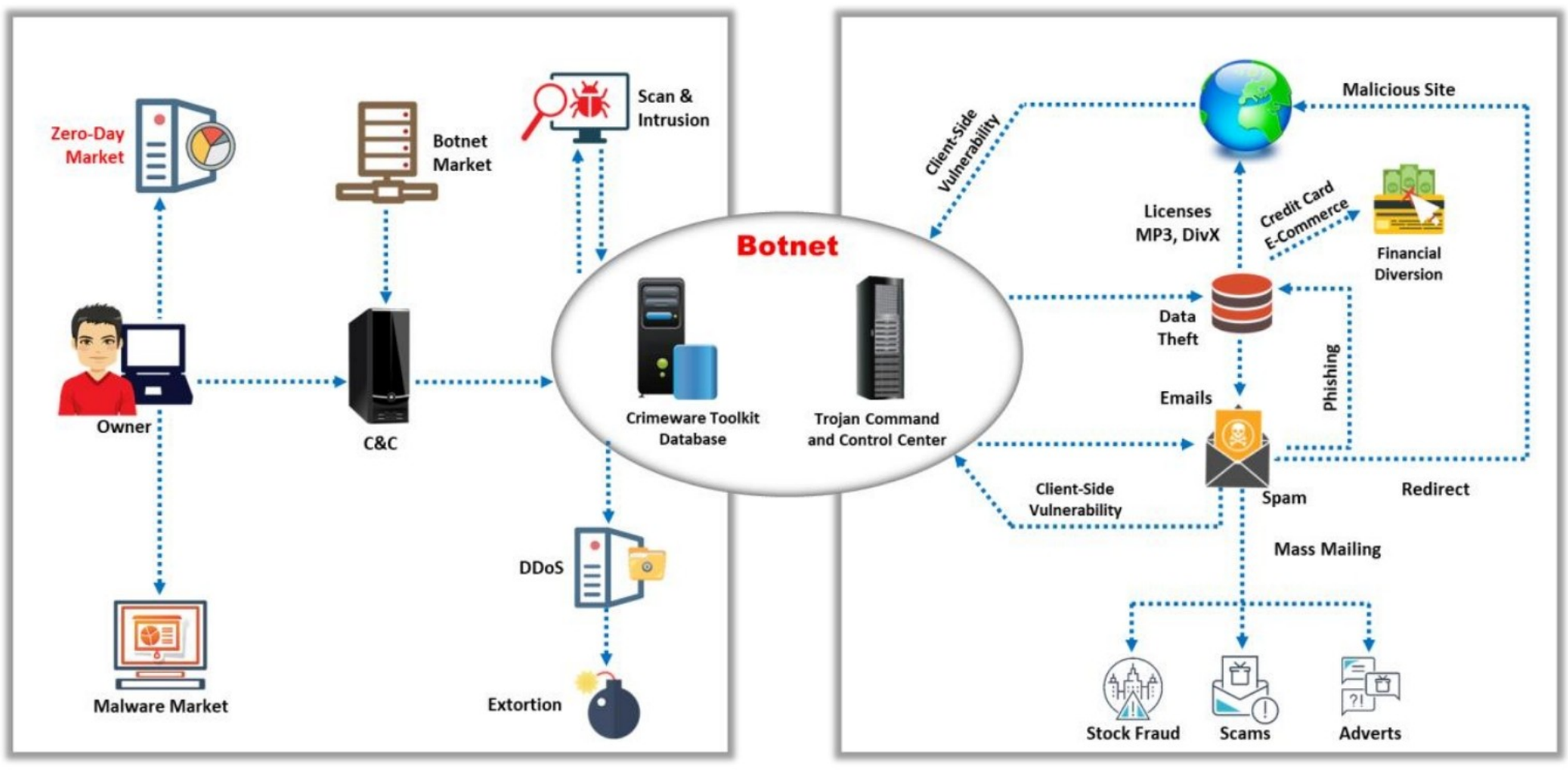
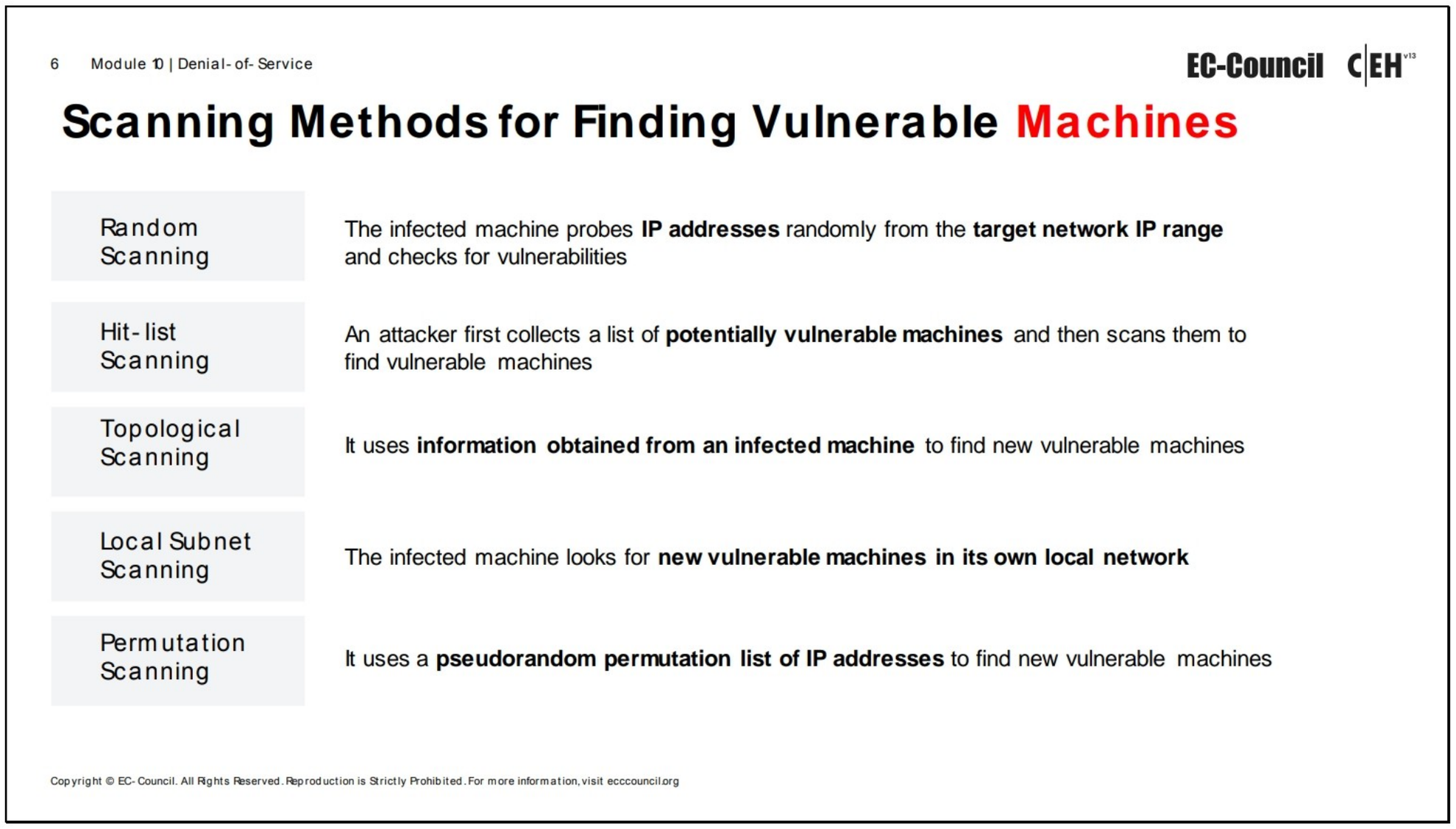


Figure 10.6: Botnet ecosystem

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Scanning Methods for Finding Vulnerable Machines

Discussed below are scanning methods used by an attacker to find vulnerable machines in a network:

- **Random Scanning**

  In this technique, the infected machine (an attacker's machine or a zombie) probes IP addresses randomly in the target network's IP range and checks their vulnerability. On finding a vulnerable machine, it hacks and attempts to infect the vulnerable machine by installing the same malicious code installed on it. This technique generates significant traffic because many compromised machines probe and check the same IP addresses. Malware propagates quickly in the initial stage, and the speed of propagation reduces as the number of new IP addresses available decreases with time.

- **Hit-list Scanning**

  Through scanning, an attacker first collects a list of potentially vulnerable machines and then creates a zombie army. Subsequently, the attacker scans the list to find a vulnerable machine. On finding one, the attacker installs malicious code on it and divides the list in half. The attacker continues to scan one half, whereas the other half is scanned by the newly compromised machine. This process keeps repeating, causing the number of compromised machines to increase exponentially. This technique ensures the installation of malicious code on all the potentially vulnerable machines in the hit list within a short time.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Topological Scanning**

  This technique uses the information obtained from an infected machine to find new vulnerable machines. An infected host checks for URLs in the hard drive of a machine that it wants to infect. Subsequently, it shortlists URLs and targets, and it checks their vulnerability. This technique yields accurate results, and its performance is similar to that of the hit-list scanning technique.

- **Local Subnet Scanning**

  In this technique, an infected machine searches for new vulnerable machines in its local network, behind a firewall, by using the information hidden in the local addresses. Attackers use this technique in combination with other scanning mechanisms.

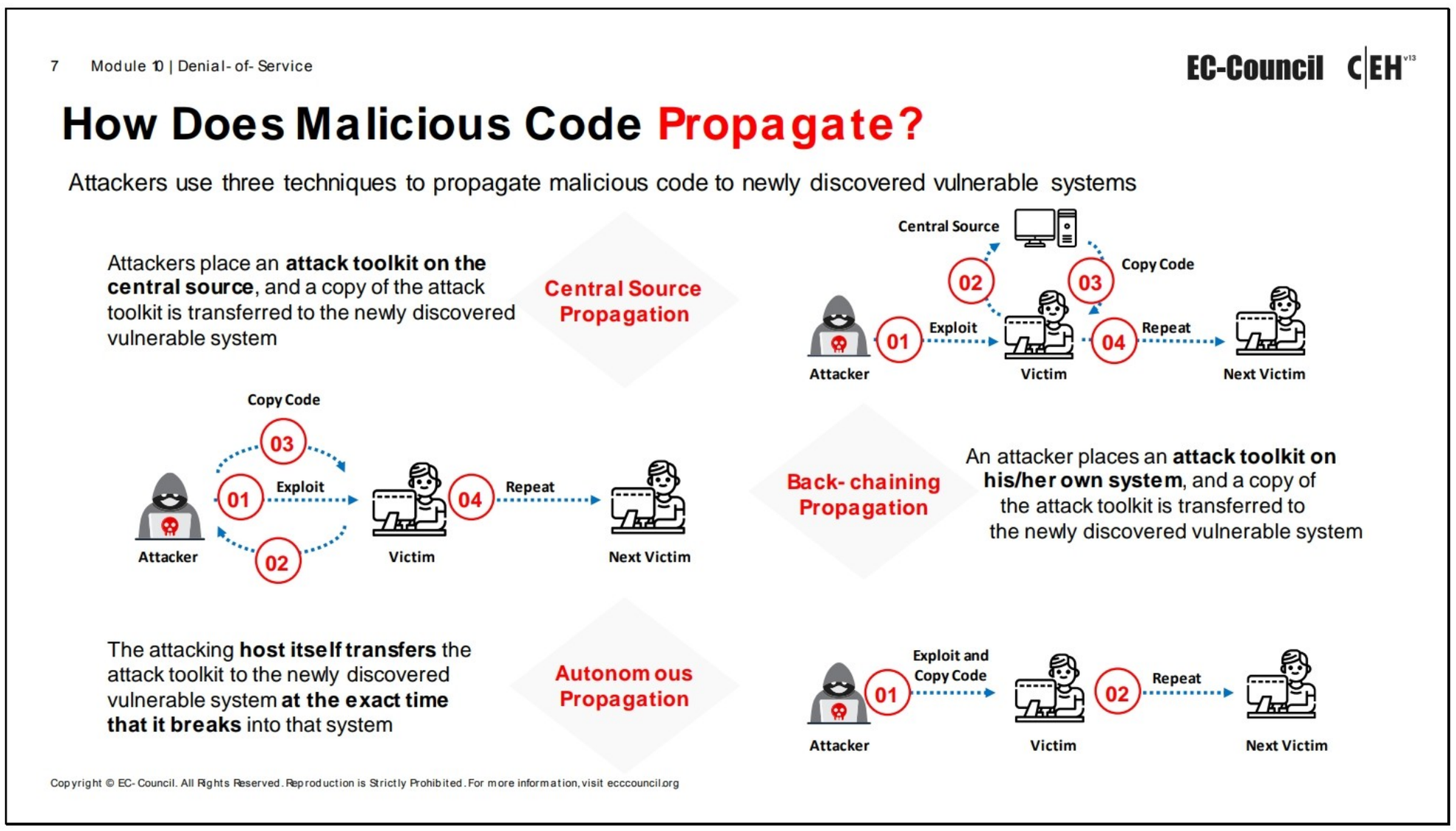
- **Permutation Scanning**

  In this technique, attackers share a common pseudorandom permutation list of IP addresses of all machines. The list is created using a block cipher of 32 bits and a preselected key. If a compromised host is infected during either hit-list scanning or local subnet scanning, the list is scanned from immediately after the point of the compromised host to identify new targets. If a compromised host is infected during permutation scanning, scanning restarts from a random point. If an already infected machine is encountered, scanning restarts from a new random start point in the permutation list. The process of scanning stops when the compromised host consecutively encounters a predefined number of already infected machines and fails to find new targets. Thereafter, a new permutation key is generated to initiate a new scanning phase.

  Permutation scanning has the following advantages:

  - The reinfection of a target is avoided.
  - New targets are scanned at random, thereby ensuring a high scanning speed.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How Does Malicious Code Propagate?

Discussed below are three techniques used by an attacker to propagate malicious code and build attack networks:

- **Central Source Propagation**

  In this technique, the attacker places an attack toolkit on a central source and a copy of the attack toolkit is transferred to a newly discovered vulnerable system. Once the attacker finds a vulnerable machine, they instruct the central source to transfer a copy of the attack toolkit to the newly compromised machine, on which attack tools are automatically installed under management by a scripting mechanism. This initiates a new attack cycle, in which the newly infected machine searches for other vulnerable machines and repeats the process to install the attack toolkit. In general, this technique uses HTTP, FTP, and RPC protocols.

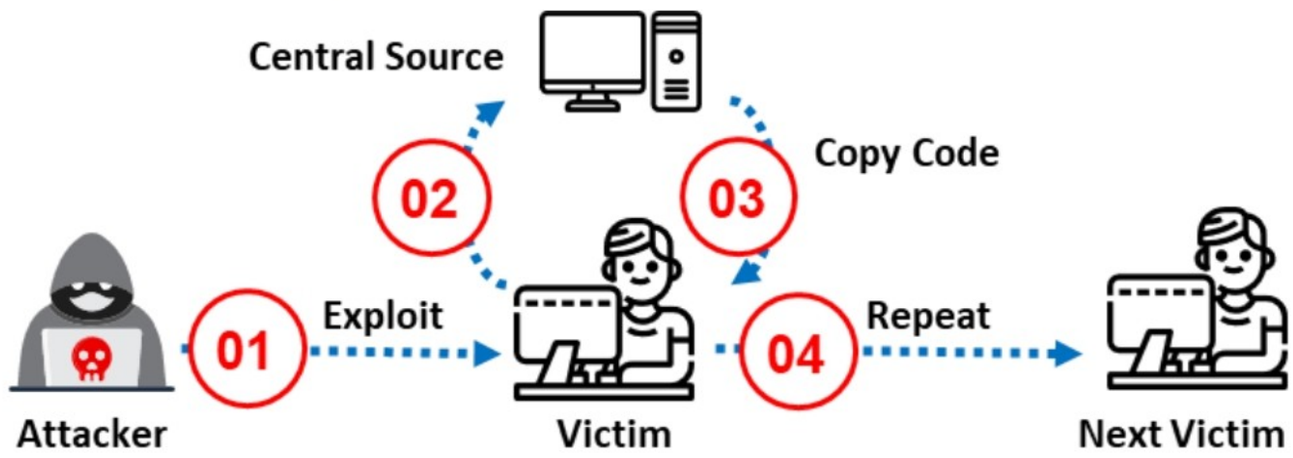


Figure 10.7: Central source propagation

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Back-chaining Propagation**

  In this technique, the attacker places an attack toolkit on their own system, and a copy of the attack toolkit is transferred to a newly discovered vulnerable system. The attack tools installed on the attacking machine use some special methods to accept a connection from the compromised system and then transfer a file containing the attack tools to it. Simple port listeners containing a copy of this file or full intruder-installed web servers, both of which use the Trivial File Transfer Protocol (TFTP), support this back-channel file copy.

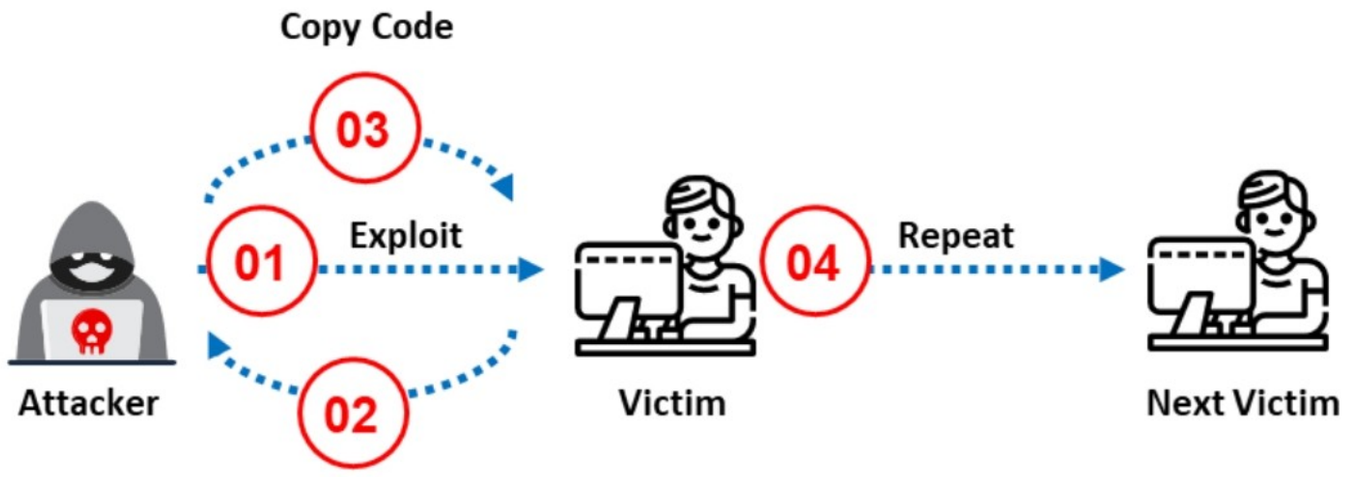


Figure 10.8: Back-chaining propagation

- **Autonomous Propagation**

  Unlike the previously discussed mechanisms, in which an external file source transfers the attack toolkit, in autonomous propagation, the attacking host itself transfers the attack toolkit to a newly discovered vulnerable system, exactly at the time it breaks into that system.

Figure 10.9: Autonomous Propagation

DDoS Case Study

DDoS attacks are sophisticated and complex attacks based on DoS and multiple distributed attack sources. In a DDoS attack, a large number of compromised computers (zombies) interrupt or suspend network services. This section presents a case study of a DDoS attack.

DDoS Attack

In a DDoS attack, attackers use a group of compromised systems (bots or zombies) usually infected with Trojans to perform a DoS attack on a target system or network resource.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

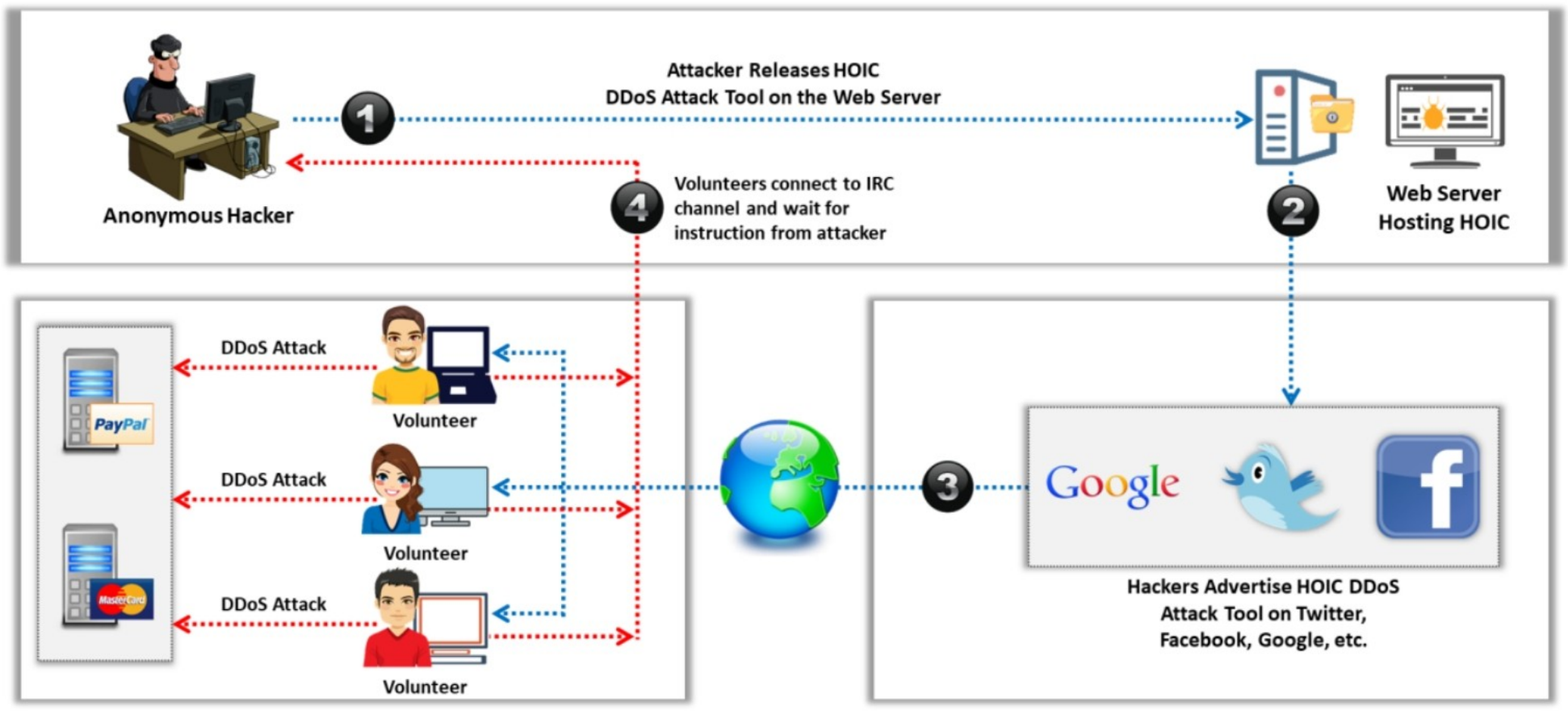


Figure 10.10: DDoS attack scenario

As shown in the figure, an anonymous hacker hosts a High Orbit Ion Cannon (HOIC) DDoS attack tool on a web server they own or on a compromised web server. The hacker then advertises the HOIC DDoS attack tool on social networking sites or search engines such as Twitter, Facebook, and Google with a malicious download link.

Users who desire to perform the DDoS attack may download the HOIC DDoS attack tool by clicking on the malicious download link provided by the hacker. These users are termed "volunteers." All the volunteers connect via an IRC channel to the anonymous hacker and await instructions to proceed further. The hacker instructs the volunteers to flood the target web server (e.g., PayPal, MasterCard, and PAYBACK) with multiple requests. On receiving instructions, the volunteers act accordingly. Consequently, the target server becomes overwhelmed and stops responding to requests from even legitimate users.

Hackers Advertise Links for Downloading Botnets

Hackers advertise botnets on various blogs, search engines, social networking sites, emails, and so on with download links. Hackers also use fake updates and security alerts to trick the victim into downloading the malware. The intention in doing so is to spread the botnet and increase the size of the attack network. This method of attack is very quick and effective. The below figure shows examples for ads hosted by hackers on the Internet to download botnets.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

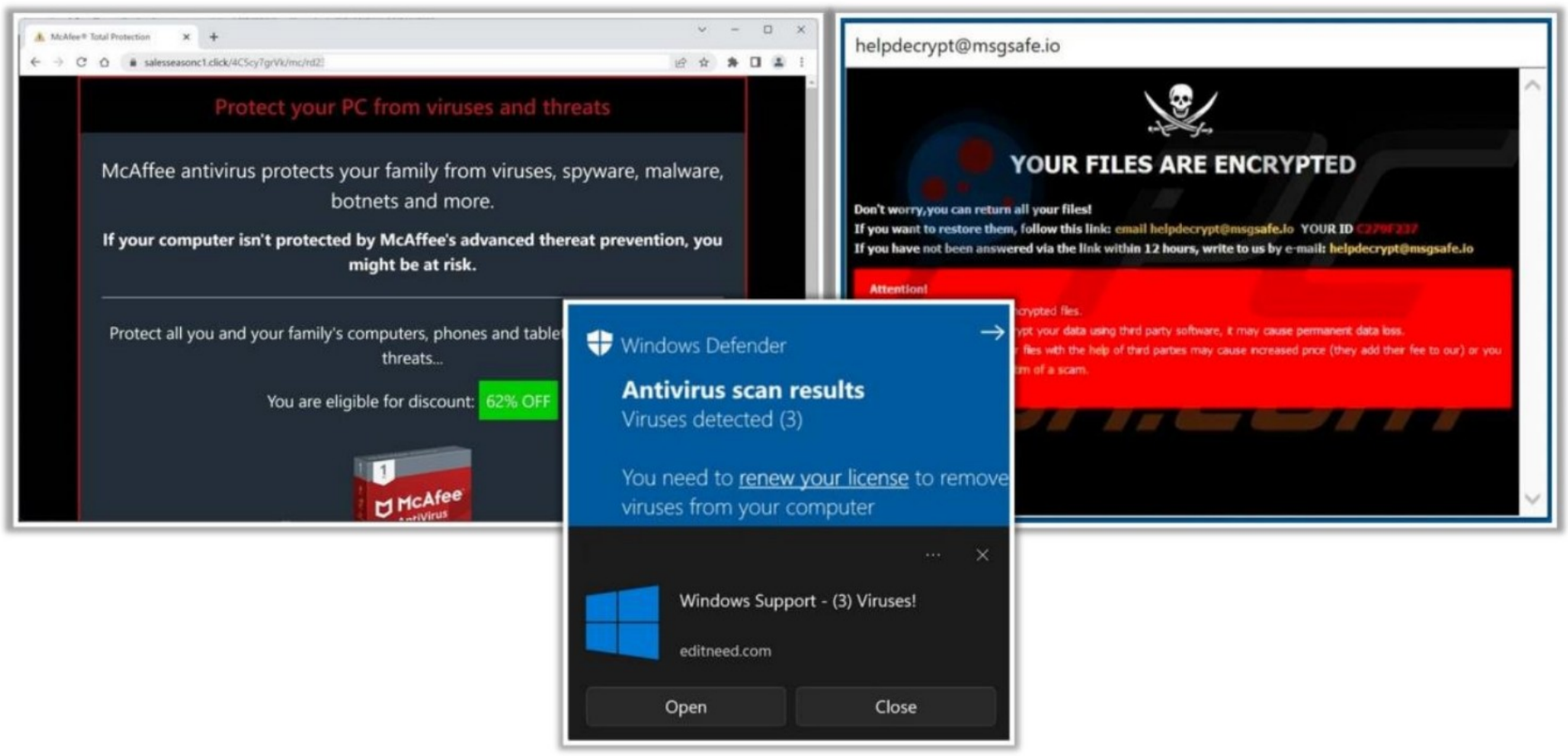


Figure 10.11: Advertisements with links to download botnets

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Use of Mobile Devices as Botnets for Launching DDoS Attacks

- Android devices are passively **vulnerable to various malware** such as Trojan, bots, and RATs, which are often found in third-party application stores
- These unsecured Android devices are becoming primary targets for attackers to **enlarge their botnet** because they are **highly vulnerable to malware**
- Malicious Android applications found in the **Google Play store** and **drive-by downloads** are just a few examples of **infection methods**
- The attacker **binds the malicious APK server** to the Android application package (**APK file**), **encrypts** it, and **removes unwanted features** and **permissions** before distributing the malicious package to a **third-party app store** like the Google Play Store
- Once the user is **tricked into downloading and installing** such an application, the attacker can gain full control of the victim's device, **enslaving the targeted device** into the **attacker's mobile botnet** to perform malicious activities such as **launching DDoS attacks** and **web injections**

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Use of Mobile Devices as Botnets for Launching DDoS Attacks

Android devices are passively vulnerable to various malware such as Trojans, bots, Remote Access Trojans (RATs), and so on, which are often found in third-party application stores. These unsecured android devices are becoming the primary targets for attackers to enlarge their botnet network because they are highly vulnerable to malware. Malicious android applications found in the Google Play Store and as drive-by downloads are examples for infection methods. The attacker binds a malicious server to the android application package (APK) file, encrypts it, and removes unwanted features and permissions before distributing the malicious package to a third-party app store such as Google Play Store. Once the victims are tricked into downloading and installing such applications, the victim's device is taken over by the attacker and integrated into the attacker's mobile botnet to perform malicious activities such as DDoS attacks and web injections.

DDoS Case Study: HTTP/2 'Rapid Reset' Attack on Google Cloud

Source: *https://cloud.google.com*

The DDoS response team at Google has warned that distributed denial-of-service (DDoS) attacks are rapidly increasing in size. In September 2023, Google's DDoS response team claimed that it had successfully thwarted a devastating 398 million requests per second (rps) DDoS attack, which was 7.5 times larger than the previous attack (46 rps). This attack employed novel HTTP/2 "Rapid Reset" techniques aimed at disrupting websites, Internet services, and Internet infrastructure companies.

- **Attack Timeline**

  The DDoS attack was recorded in late August and continued until the end of September 2023. This HTTP/2 "Rapid Reset" DDoS attack tried to impact major infrastructure

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

providers including Google services, Google Cloud infrastructure, and their customers for 2-3 minutes where it peaked. Although the attack was short-lived, the targeted services experienced an unexpected surge of TCP packets with the RST (Reset) flags that aimed to flood and reset the target server.

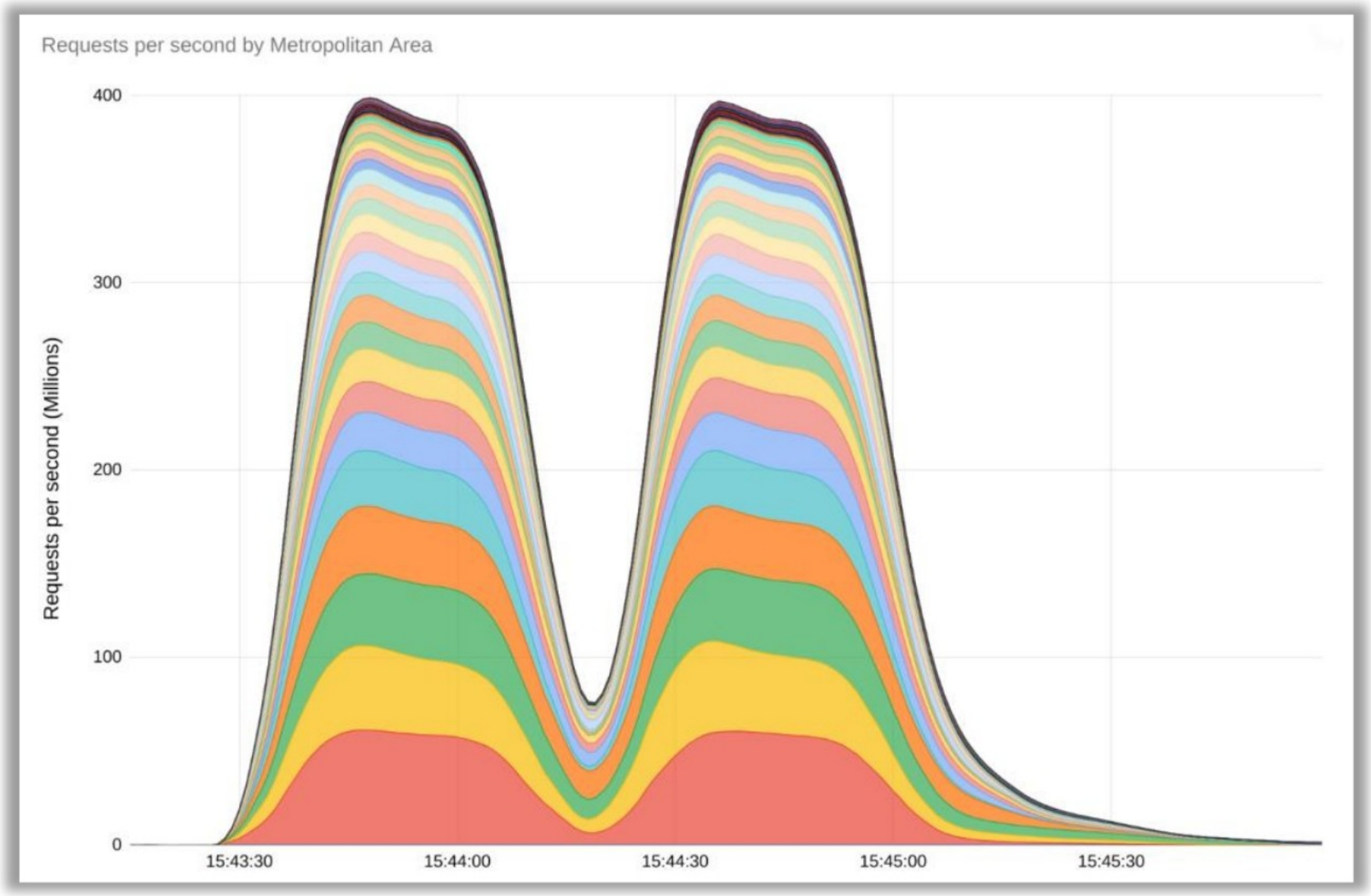


Figure 10.12: DDoS attack where it peaked at 398 million requests per second

However, Google's DDoS mitigation infrastructure played a vital role in sustaining the operation of their services. Google, with its clients, industry peers along with the broader online community took the initiative to spearhead a collaborative endeavor to block the attack.

- **Attack Mechanism**

The attack was initiated using a novel "Rapid Reset" technique that leverages stream multiplexing, a feature of the widely adopted HTTP/2 protocol. The ability of HTTP/2 to utilize multiplexing for managing up to 100 live streams through a sole TCP connection posed a significant vulnerability. This vulnerability was exploited by attackers to initiate a consecutive series of stream requests, all of which were reset streams, thereby causing significant disruption.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

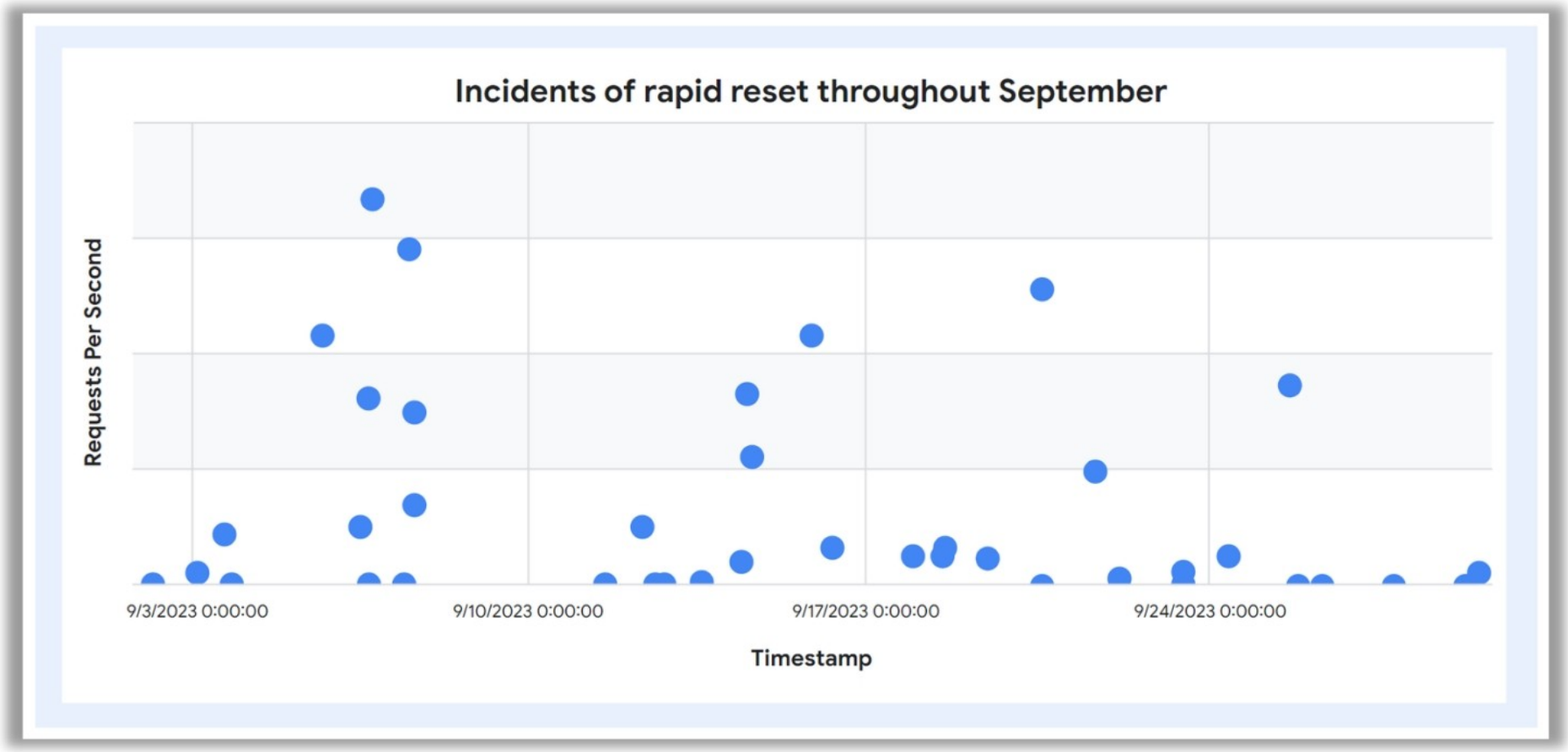


Figure 10.13: Timeframe of attack campaign

- **Google's Response**

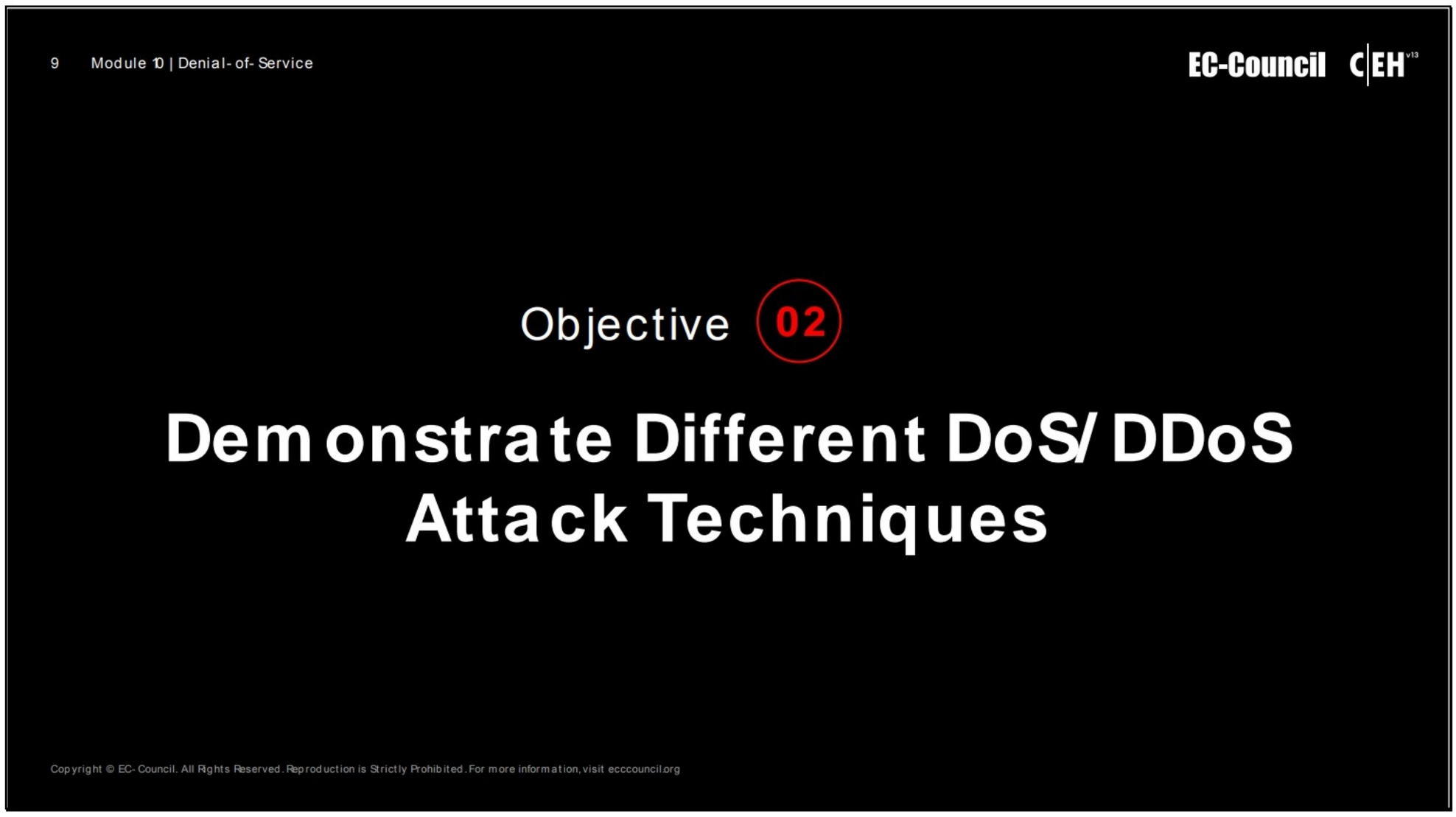
  The Google response team claims that they successfully countered the attack on the perimeter of Google's network by utilizing their substantial investment in edge capacity. This ensured that both their services and those of their customers remained largely unaffected. As the response team gained deeper insights into the attack methods employed, they devised a series of countermeasures and upgraded their proxies and defense systems to effectively neutralize this threat. The same robust hardware and software infrastructure that Google uses for its own Internet-facing services was provided to the cloud customers who utilize Google Cloud's Application Load Balancer and Cloud Armor.

  Soon after identifying the earliest instances of this attack, Google promptly implemented additional mitigation strategies and initiated a collaborative response with other cloud providers and software maintainers utilizing the HTTP/2 protocol stack. Real-time threat intelligence and its mitigation methods were shared immediately to prevent significant disruption.

  This collaborative effort across industries resulted in the development of patches and other mitigation techniques adopted by numerous major infrastructure providers. It also facilitated coordinated responsible disclosure of the new attack methodologies and their potential impact on various widely used open source and commercial proxies, application servers, and load balancers.

  The collective vulnerability to this attack was assigned CVE-2023-44487 and classified as a high severity vulnerability with a CVSS score of 7.5 out of 10.

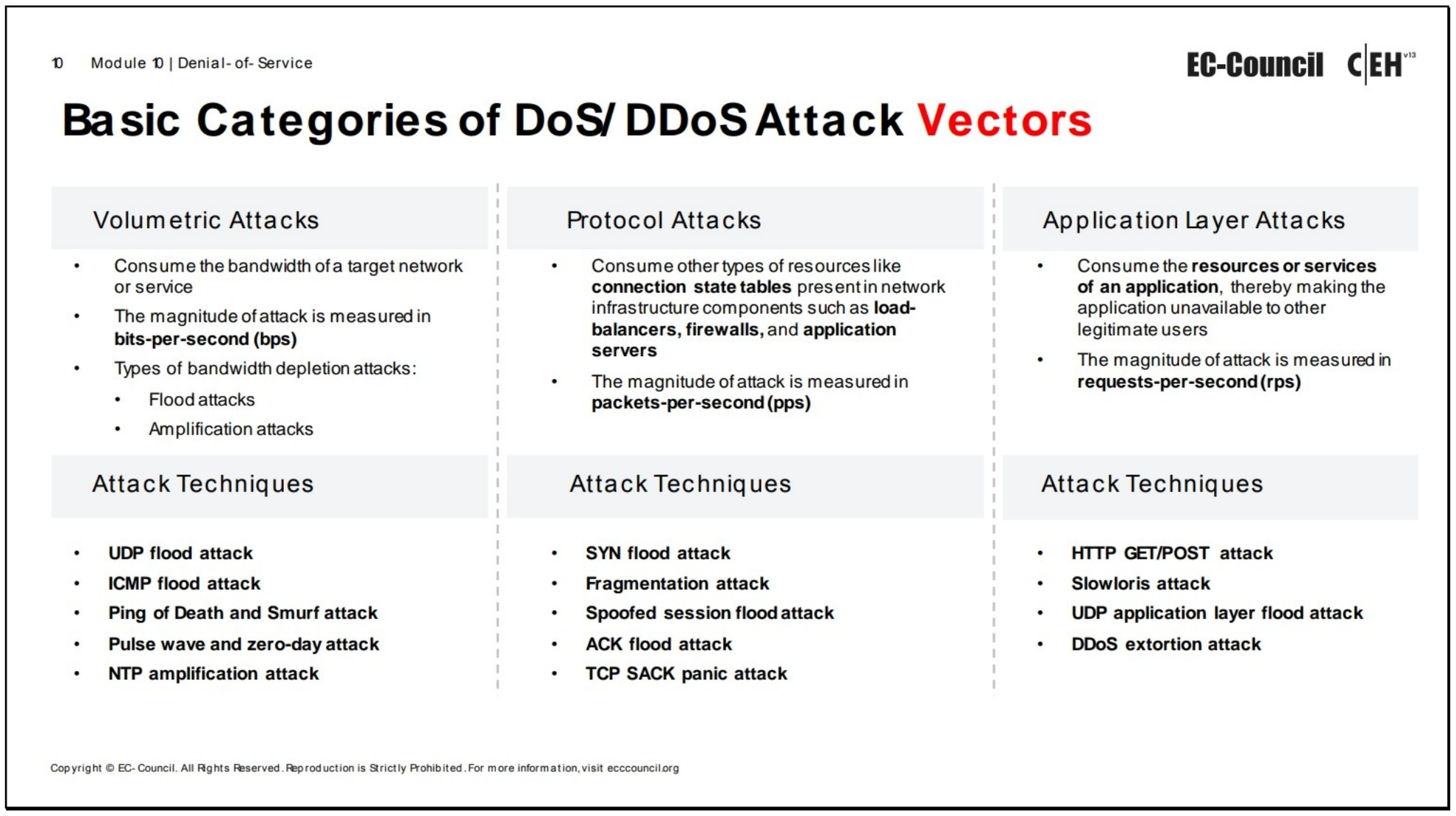
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



DoS/DDoS Attack Techniques

Attackers implement various techniques to launch denial-of-service (DoS)/distributed denial-of-service (DDoS) attacks on target computers or networks. This section discusses the basic categories of DoS/DDoS attack vectors, various attack techniques, and various DoS/DDoS attack tools used to take over a single or multiple network system to exhaust their computing resources or render them unavailable to their intended users.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Basic Categories of DoS/DDoS Attack Vectors

DDoS attacks mainly aim to diminish the network bandwidth by exhausting network, application, or service resources, thereby restricting legitimate users from accessing system or network resources. In general, DoS/DDoS attack vectors are categorized as follows:

- **Volumetric Attacks**

  These attacks exhaust the bandwidth either within the target network/service or between the target network/service and the rest of the Internet to cause traffic blockage, preventing access to legitimate users. The attack magnitude is measured in bits per second (bps).

  Volumetric DDoS attacks generally target protocols such as the Network Time Protocol (NTP), Domain Name System (DNS), and Simple Service Discovery Protocol (SSDP), which are stateless and do not have built-in congestion avoidance features. The generation of a large number of packets can cause the consumption of the entire bandwidth on the network. A single machine cannot make enough requests to overwhelm network equipment. Hence, in DDoS attacks, the attacker uses several computers to flood a victim. In this case, the attacker can control all the machines and instruct them to direct traffic to the target system. DDoS attacks flood a network, causing a significant statistical change in network traffic that overwhelms network equipment such as switches and routers. Attackers use the processing power of a large number of geographically distributed machines to generate huge traffic directed at the victim, which is why such an attack is called a DDoS attack.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

There are two types of bandwidth depletion attacks:

- In a **flood attack**, zombies send large volumes of traffic to the victim's systems to exhaust the bandwidth of these systems.
- In an **amplification attack**, the attacker or zombies transfer messages to a broadcast IP address. This method amplifies malicious traffic that consumes the bandwidth of the victim's systems.

Attackers use botnets and perform DDoS attacks by flooding the network. The entire bandwidth is used up by attackers, and no bandwidth remains for legitimate use. The following are examples for volumetric attack techniques:

- User Datagram Protocol (UDP) flood attack
- Internet Control Message Protocol (ICMP) flood attack
- Ping of Death (PoD) attack
- Smurf attack
- Pulse wave attack
- Zero-day attack
- Malformed IP packet flood attack
- Spoofed IP packet flood attack
- NTP amplification attack

- **Protocol Attacks**

  Attackers can also prevent access to a target by consuming types of resources other than bandwidth, such as connection state tables. Protocol DDoS attacks exhaust resources available on the target or on a specific device between the target and the Internet. These attacks consume the connection state tables present in network infrastructure devices such as load balancers, firewalls, and application servers. Consequently, no new connections will be allowed, because the device will be waiting for existing connections to close or expire. In this case, the attack magnitude is measured in packets per second (pps) or connections per second (cps). These attacks can even take over the state of millions of connections maintained by high-capacity devices.

  The following are examples for protocol attack techniques:

  - Synchronize (SYN) flood attack
  - Fragmentation attack
  - Spoofed session flood attack
  - Acknowledgement (ACK) flood attack
  - SYN-ACK flood attack
  - ACK and PUSH ACK flood attack
  - TCP connection flood attack
  - TCP state exhaustion attack
  - RST attack
  - TCP SACK panic attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Application Layer Attacks**

  In these attacks, the attacker attempts to exploit vulnerabilities in the application layer protocol or in the application itself to prevent legitimate users from accessing the application. Attacks on unpatched, vulnerable systems do not require as much bandwidth as protocol or volumetric DDoS attacks for succeeding. In application DDoS attacks, the application layer or application resources are consumed by opening connections and leaving them open until no new connections can be made. These attacks destroy a specific aspect of an application or service and can be effective with one or a few attacking machines that produce a low traffic rate. Furthermore, these attacks are very difficult to detect and mitigate. The magnitude of attack is measured in requests per second (rps).

  Application-level flood attacks result in the loss of services of a particular network, such as emails and network resources, or the temporary shutdown of applications and services. Through this attack, attackers exploit weaknesses in programming source code to prevent the application from processing legitimate requests.

  Several kinds of DoS attacks rely on software-related exploits such as buffer overflows. A buffer overflow attack sends excessive data to an application that either shuts down the application or forces the data sent to the application to run on the host system. The attack crashes a vulnerable system remotely by sending excessive traffic to an application.

  Occasionally, attackers can also execute arbitrary code on the remote system via a buffer overflow. Sending too much data to an application overwrites the data that controls the program, enabling the hacker to run their code instead.

  Using application-level flood attacks, attackers attempt to do the following:

  - Flood web applications with legitimate user traffic
  - Disrupt service to a specific system or person by, for example, blocking a user's access through repeated invalid login attempts
  - Jam the application database connection by crafting malicious Structured Query Language (SQL) queries

  Application-level flood attacks can result in a substantial loss of money, service, and reputation for organizations. These attacks occur after the establishment of a connection. Because a connection is established and the traffic entering the target appears to be legitimate, it is difficult to detect these attacks. However, if the user identifies the attack, they can stop it and trace it back to its source more easily than other types of DDoS attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following are examples for application layer attack techniques:

- Hypertext Transfer Protocol (HTTP) flood attack
- Slowloris attack
- UDP application layer flood attack
- DDoS extortion attack

DoS/DDoS Attack Techniques

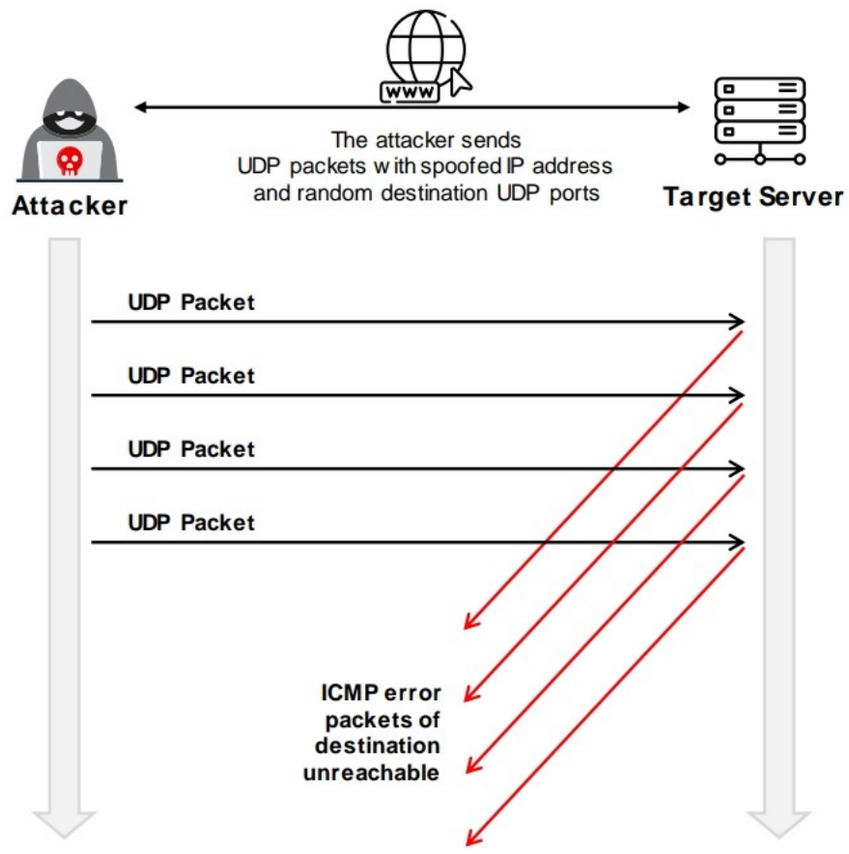
Next, the following DoS/DDoS attack techniques will be discussed:

- UDP flood attack
- ICMP flood attack
- PoD attack
- Smurf attack
- Pulse wave attack
- Zero-day attack
- NTP amplification attack
- SYN flood attack
- Fragmentation attack
- ACK flood attack
- TCP state exhaustion attack
- Spoofed session flood attack
- HTTPS GET/POST attack
- Slowloris attack
- UDP application layer flood attack
- Multi-vector attack
- Peer-to-peer attack
- Permanent DoS (PDoS) attack
- Distributed reflection DoS (DRDoS) attack
- TCP SACK panic attack
- DDoS extortion attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

UDP Flood Attack

- An attacker sends **spoofed UDP packets** at a very high packet rate to a remote host on random ports of a target server using a large source IP range
- The flooding of UDP packets causes the server to repeatedly check for **non-existent applications** at the ports
- Legitimate applications are inaccessible by the system and give an **error reply** with an ICMP "Destination Unreachable" packet
- This attack consumes **network resources** and available bandwidth, exhausting the network until it goes offline



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

UDP Flood Attack

In a UDP flood attack, an attacker sends spoofed UDP packets at a very high packet rate to a remote host on random ports of a target server by using a large source IP range. The flooding of UDP packets causes the server to check repeatedly for nonexistent applications at the ports. Consequently, legitimate applications become inaccessible by the system, and any attempts to access them return an error reply with an ICMP "Destination Unreachable" packet. This attack consumes network resources and available bandwidth, exhausting the network until it goes offline.

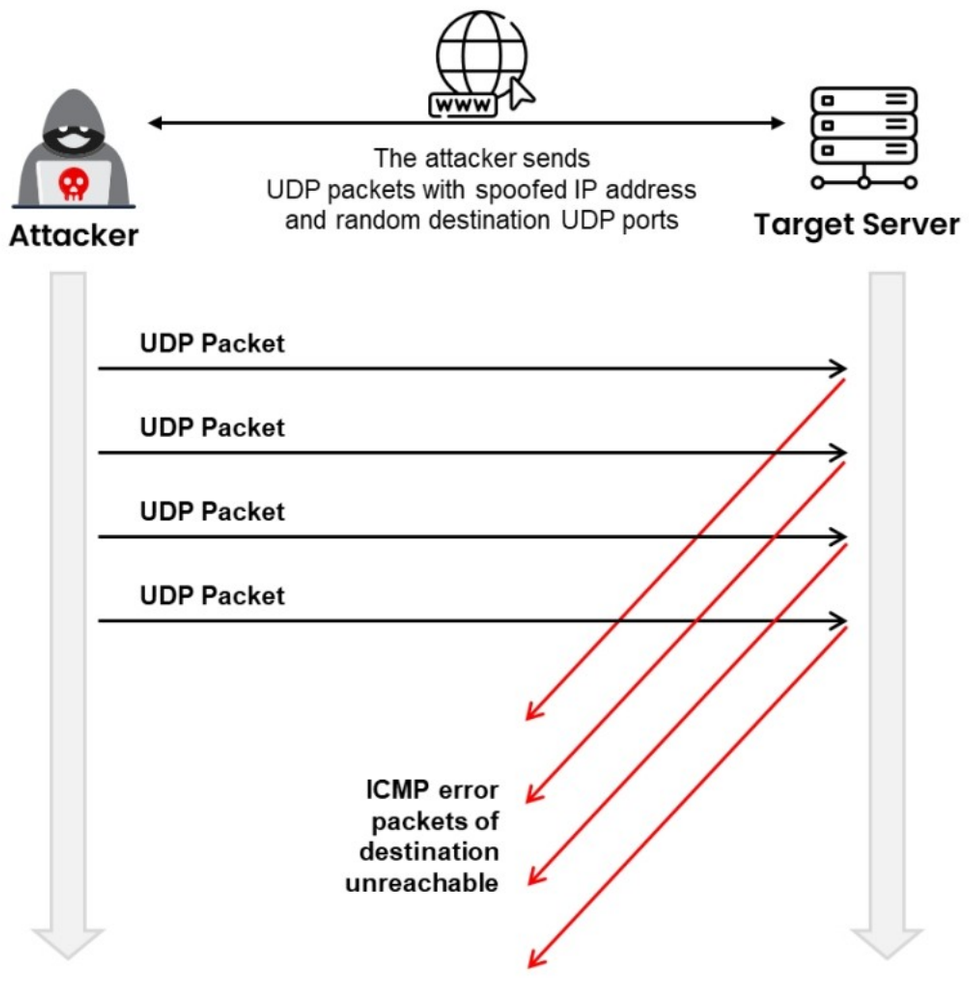


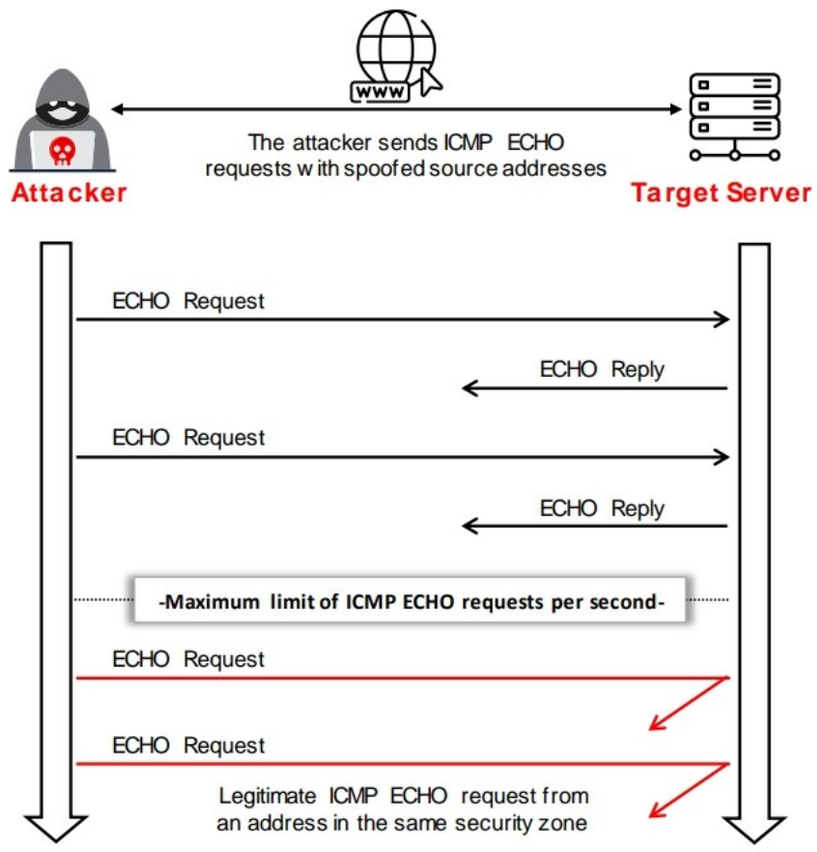
Figure 10.14: UDP flood attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

EC-Council CEH v13

ICMP Flood Attack

- Network administrators use ICMP primarily for IP operations and troubleshooting, and error messaging is used for **undeliverable packets**
- ICMP flood attacks are a type of attack in which attackers send large volumes of **ICMP echo request packets** to a victim system directly or through reflection networks
- These packets signal the victim's system to reply, and the resulting combination of traffic saturates the bandwidth of the victim's network connection, causing it to be overwhelmed and **subsequently stop** responding to legitimate TCP/IP requests
- To protect against ICMP flood attacks, set a **threshold limit** that invokes an ICMP flood attack protection feature when exceeded



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

ICMP Flood Attack

Network administrators use ICMP primarily for IP operations, troubleshooting, and error messaging for undeliverable packets. In this attack, attackers send large volumes of ICMP echo request packets to a victim's system directly or through reflection networks. These packets signal the victim's system to reply, and the large traffic saturates the bandwidth of the victim's network connection, causing it to be overwhelmed and subsequently stop responding to legitimate TCP/IP requests.

To protect against ICMP flood attacks, it is necessary to set a threshold that invokes the ICMP flood attack protection feature when exceeded. When the ICMP threshold is exceeded (by default, the threshold value is 1000 packets/s), the router rejects further ICMP echo requests from all addresses in the same security zone for the remainder of the current second as well as the next second.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

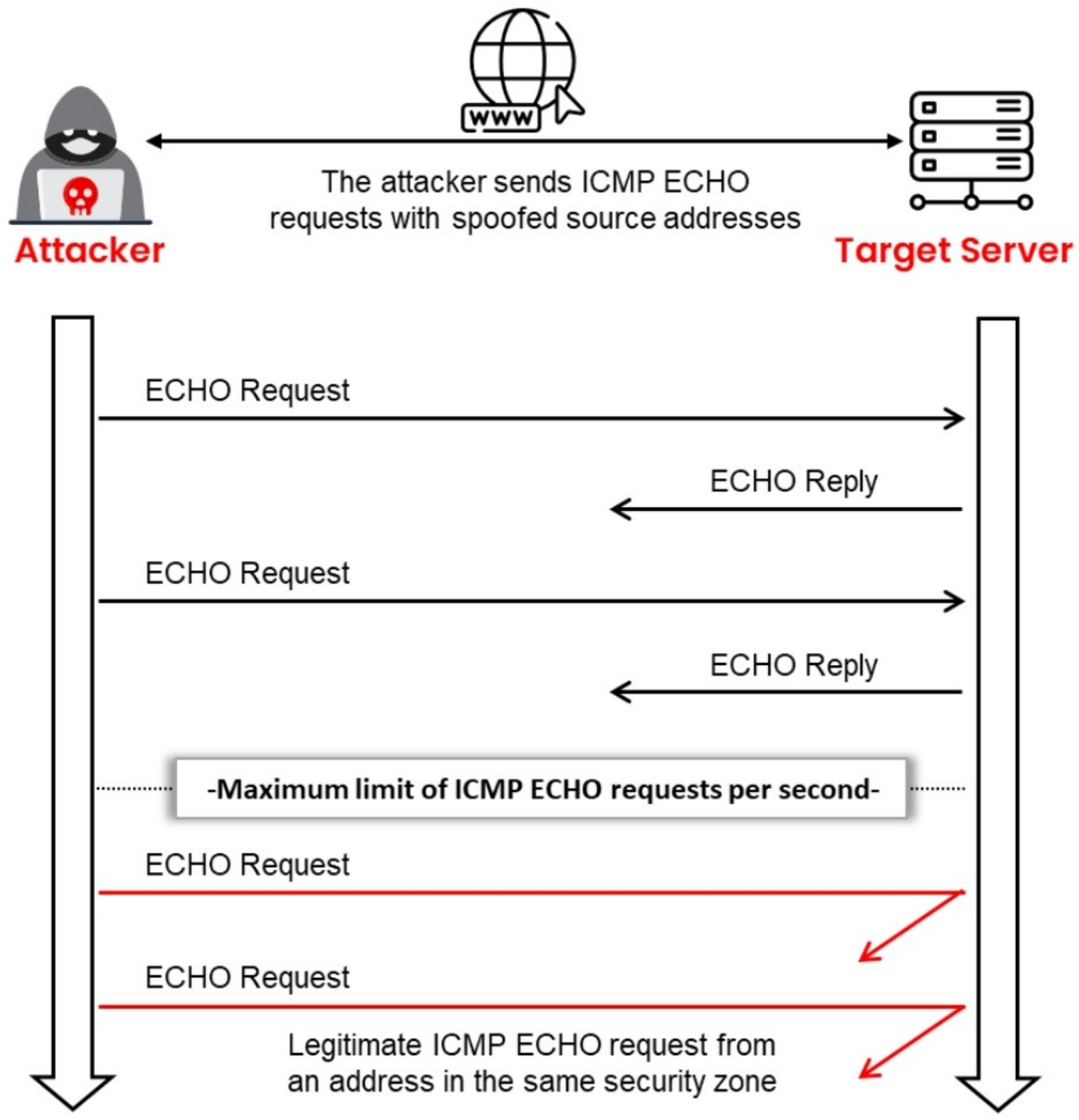
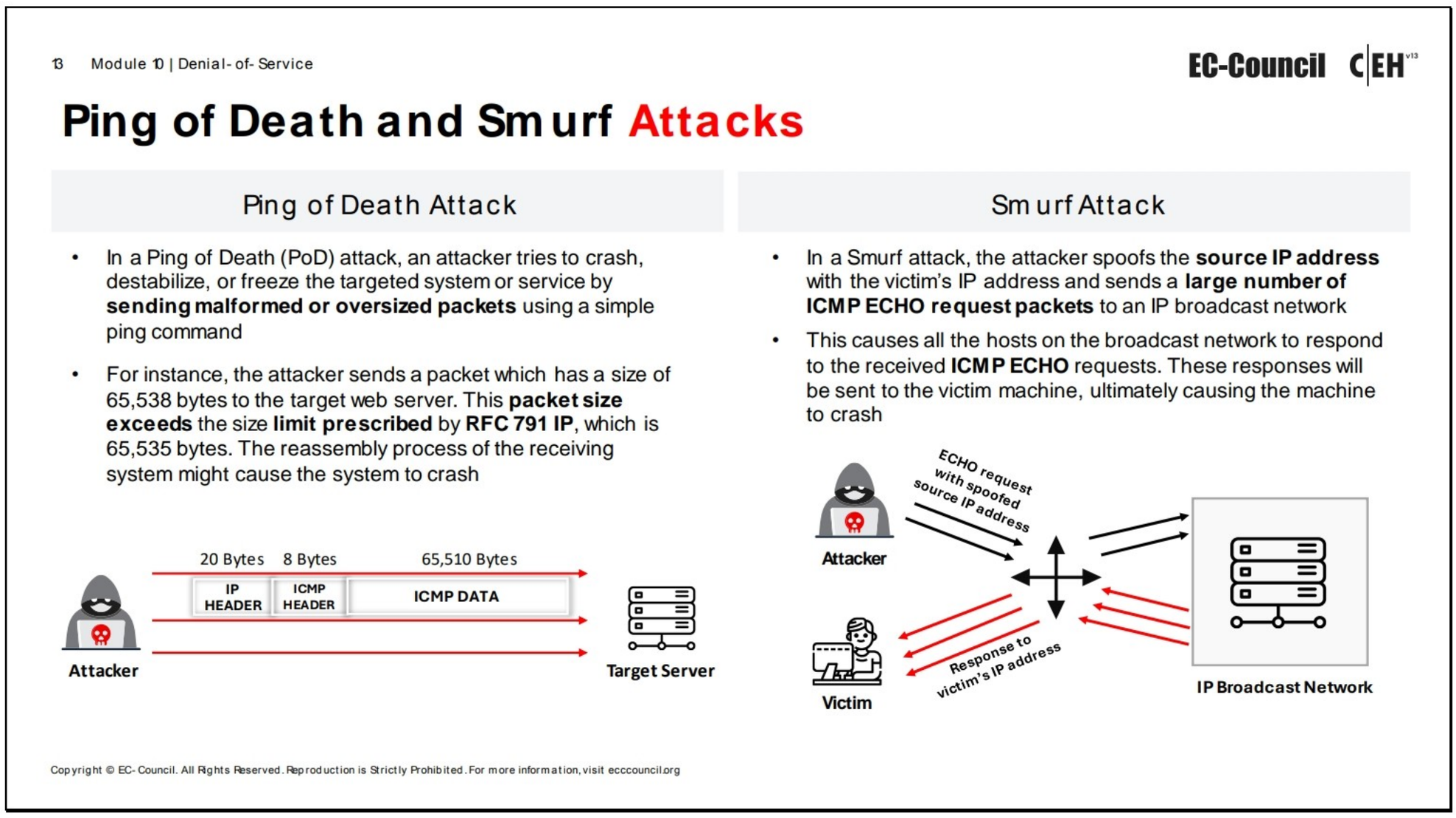


Figure 10.15: ICMP flood attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Ping of Death Attack

In a Ping of Death (PoD) attack, an attacker attempts to crash, destabilize, or freeze the target system or service by sending malformed or oversized packets using a simple ping command. Suppose an attacker sends a packet with a size of 65,538 bytes to the target web server. This size exceeds the size limit prescribed by RFC 791 IP, which is 65,535 bytes. The reassembly process performed by the receiving system might cause the system to crash. In such attacks, the attacker's identity can be easily spoofed, and the attacker might not need detailed knowledge of the target machine, except its IP address.

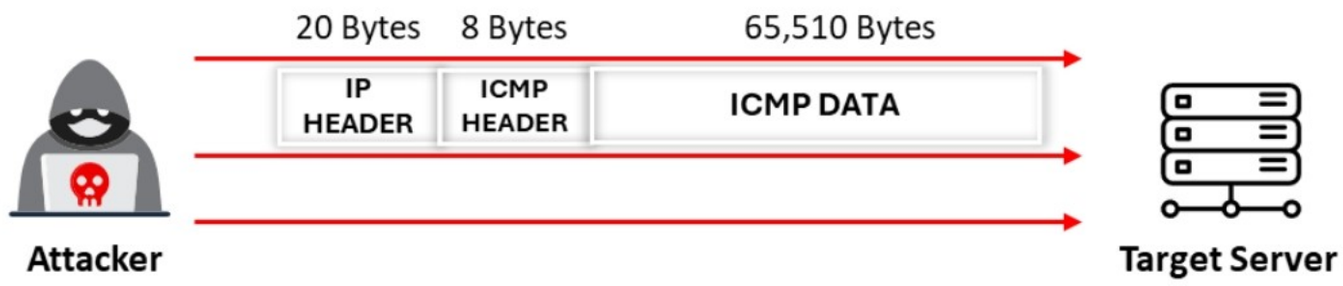


Figure 10.16: Ping-of-death attack

Smurf Attack

In a Smurf attack, the attacker spoofs the source IP address with the victim's IP address and sends a large number of ICMP ECHO request packets to an IP broadcast network. This causes all the hosts on the broadcast network to respond to the received ICMP ECHO requests. These responses are sent to the victim's machine because the IP address was spoofed by the attacker, causing significant traffic to the victim's machine and ultimately making it crash.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

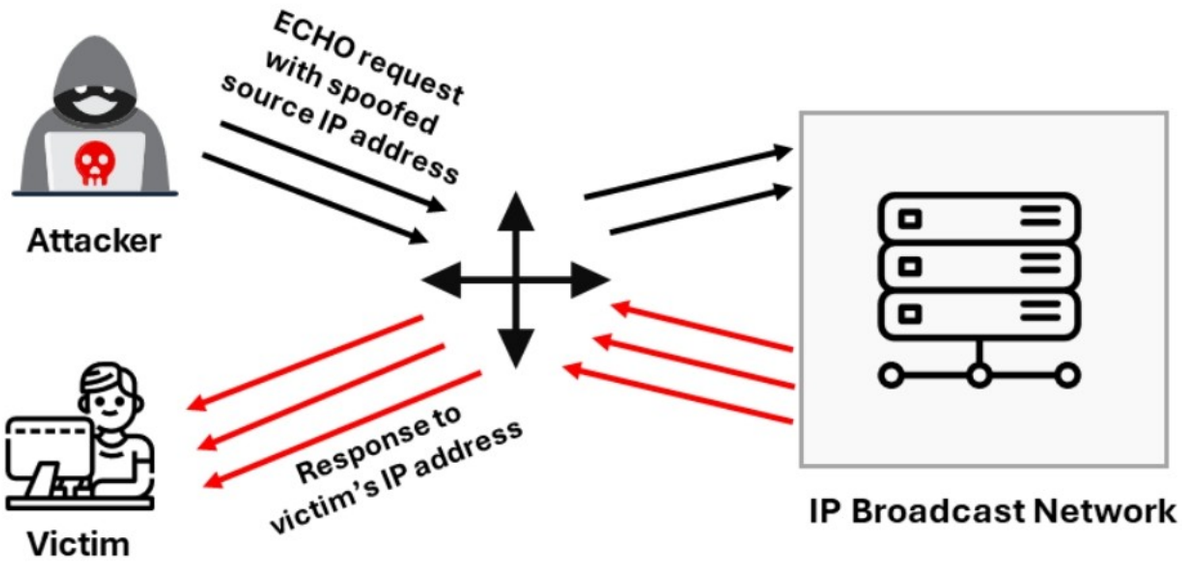


Figure 10.17: Smurf attack

Pulse Wave DDoS Attack

Pulse wave DDoS attacks are the latest type of DDoS attacks employed by threat actors to disrupt the standard operations of targets. Generally, DDoS attack patterns are continuous incoming traffic flows. However, in pulse wave DDoS attacks, the attack pattern is periodic, and the attack is huge, consuming the entire bandwidth of target networks. Attackers send a highly repetitive strain of packets as pulses to the target victim every 10 min, and the attack session lasts for approximately an hour or some days. A single pulse (300 Gbps or more) is more than enough to crowd a network pipe. Recovery from such attacks is very difficult and occasionally impossible.

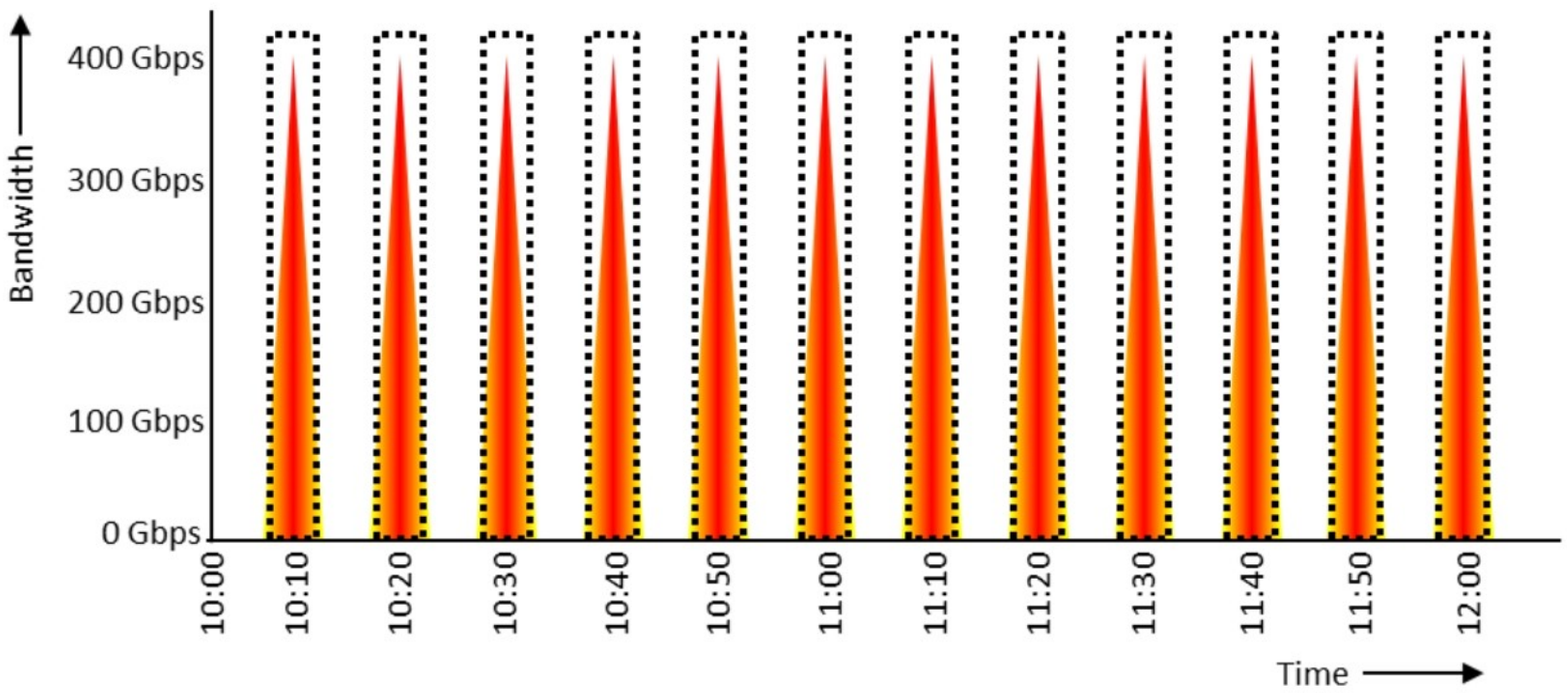
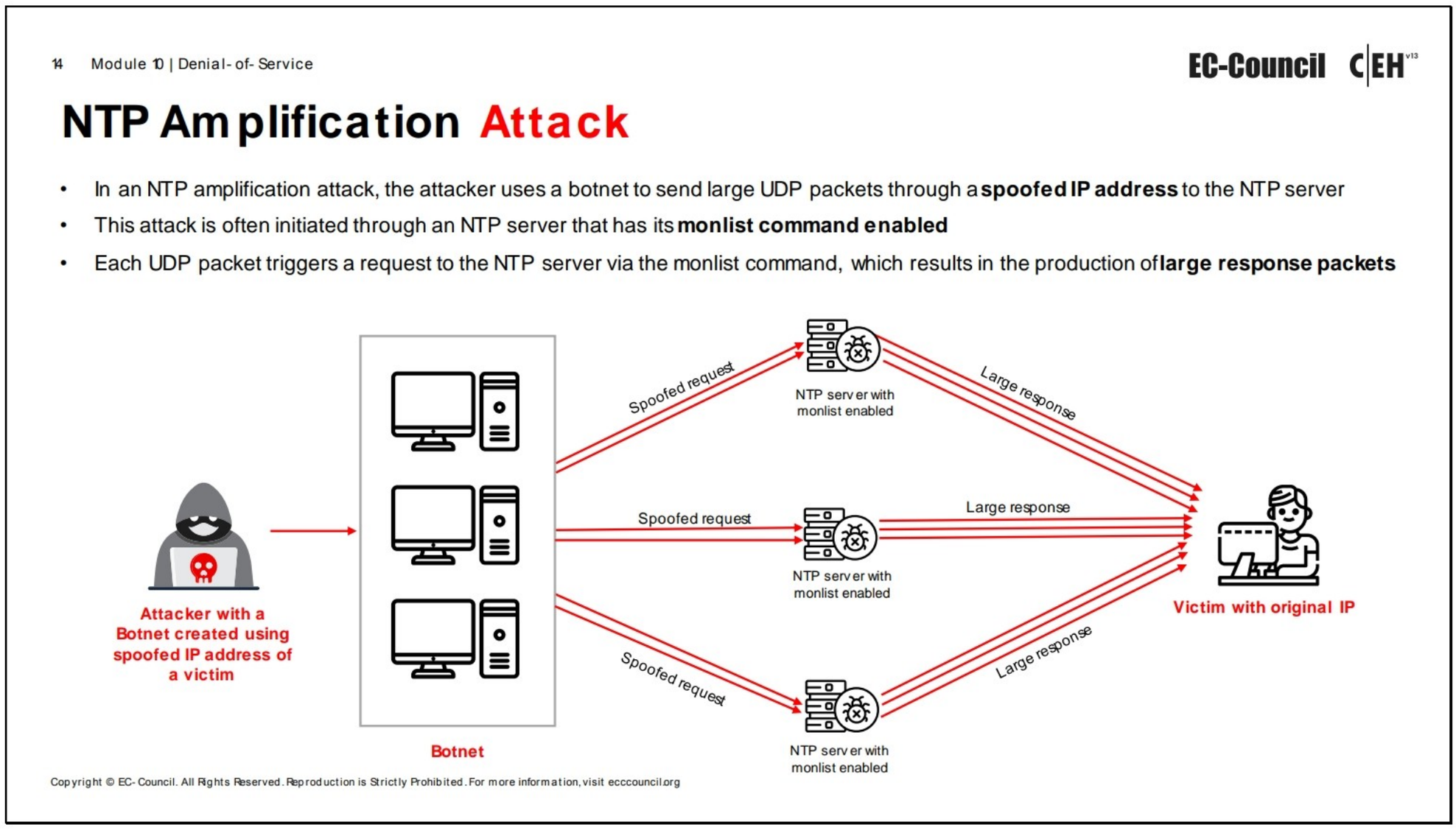


Figure 10.18: Pulse wave DDoS attack

Zero-Day DDoS Attack

Zero-day DDoS attacks are attacks in which DDoS vulnerabilities do not have patches or effective defensive mechanisms. Until the victim identifies the threat actor's attack strategy and deploys a patch for the exploited DDoS vulnerability, the attacker actively blocks all the victim's resources and steals the victim's data. These attacks can cause severe damage to the victim's network infrastructure and assets. Currently, there is no versatile approach to protect networks from this type of attack.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



NTP Amplification Attack

The Network Time Protocol (NTP) synchronizes time across networks, including host machines, processes, and devices associated with the network. It also ensures precision in timekeeping, which is mandatory for a multitude of network activities, protocols, and logs. In an NTP amplification attack, the attacker uses a botnet to send large UDP packets through a spoofed IP address (that mimics the victim's real IP address) to the NTP server. This attack is often initiated through an NTP server that has its monlist command enabled. Each UDP packet triggers a request to the NTP server via the monlist command, which results in the production of large response packets. The server then starts responding to the spoofed IP address immediately. As a result, the victim's IP address is flooded with large responses, causing the surrounding network infrastructure to be inundated with unwanted traffic. Consequently, this leads to a denial-of-service scenario, causing network congestion, service disruption, and the exhaustion of network resources such as bandwidth, excessive memory, and power usage.

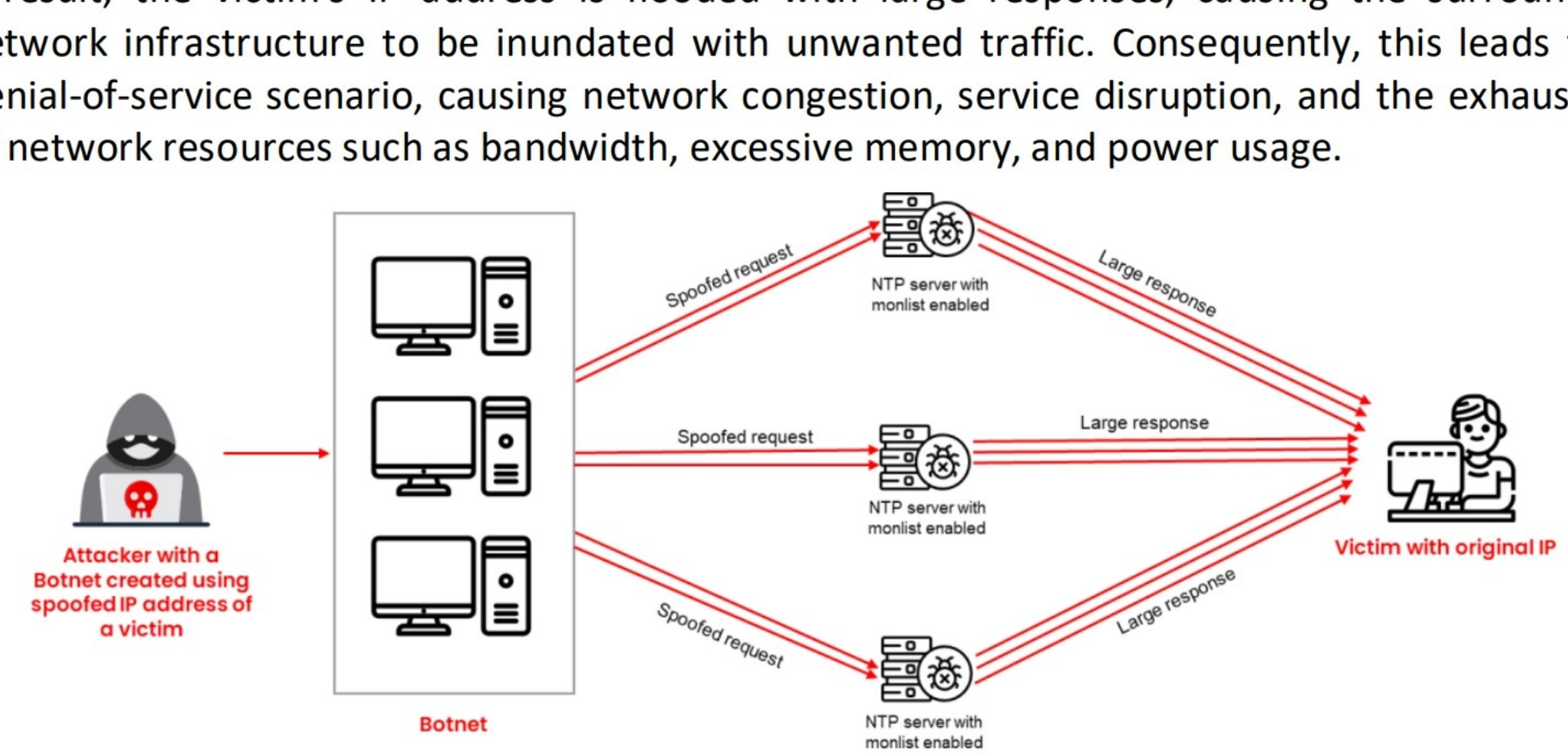


Figure 10.19: Illustration of NTP server amplification attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Steps to retrieve monlist from an NTP server:

- Run the following command to retrieve the monlist.

  `nmap -sU -pU:123 -Pn -n --script=ntp-monlist <target>`

- After executing the above command, Nmap provides a list of public and private clients that have communicated with the NTP server.

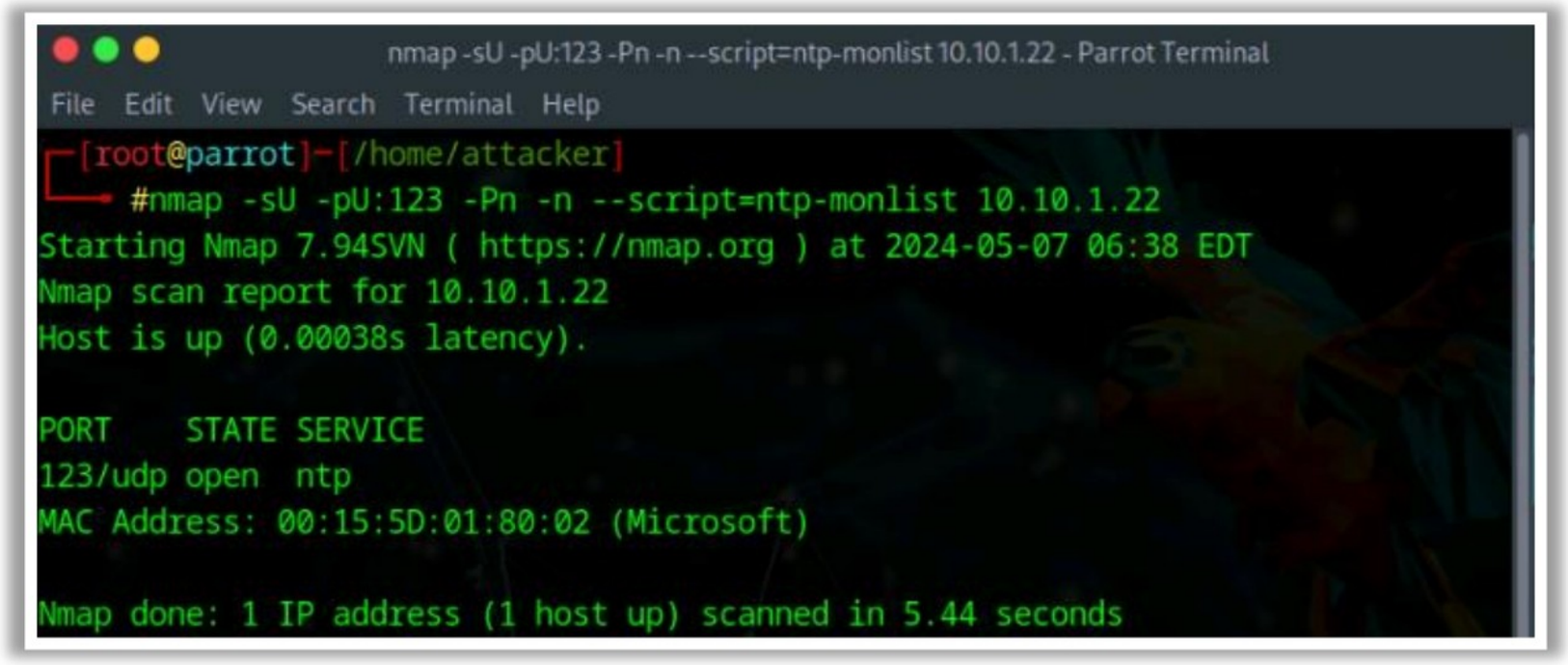


Figure 10.20: Screenshot showing output of Nmap monlist retrieval from NTP Server

Countermeasures for NTP amplification attack:

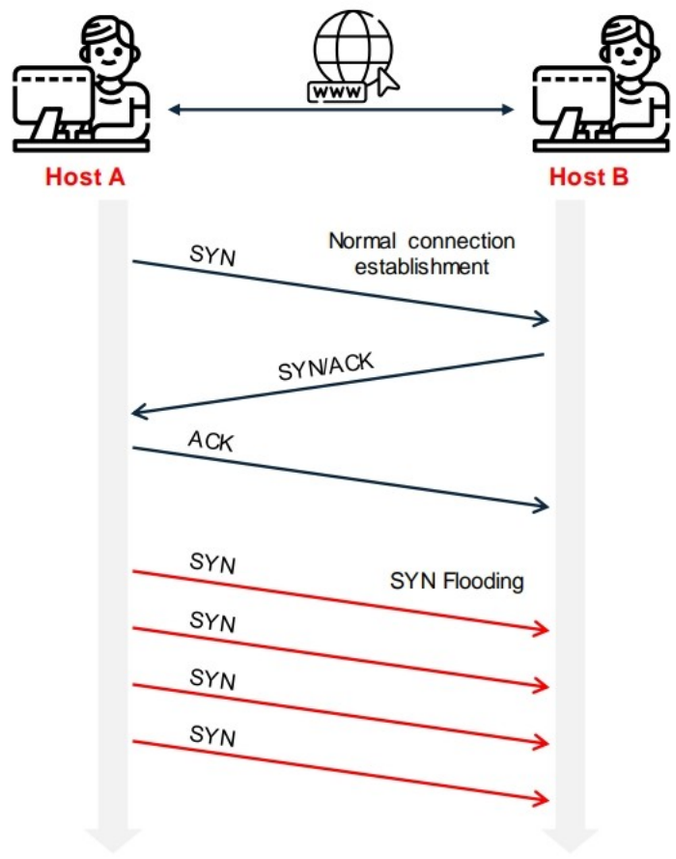
- Secure and harden NTP server configurations to prevent monlist exploitation
- Limit flow control in the NTP server
- Frequently monitor network for abnormal behavior
- Implement zero-trust network
- Use firewalls to filter NTP server requests

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

EC-Council CEH v13

SYN Flood Attack

- The attacker sends a large number of **SYN requests** with **fake source IP addresses** to the target server (victim)
- The target machine sends back a **SYN/ACK** in **response to the request** and waits for the ACK to complete the session setup
- The target machine **does not get the response** because the **source address is fake**
- SYN flooding takes advantage of a flaw in the implementation of the **TCP three-way handshake** in most hosts
- When **Host B** receives the **SYN** request from Host A, it must keep track of the partially opened connection in a "**listen queue**" for **at least 75 seconds**
- A malicious host can exploit the small size of the listen queue by **sending multiple SYN requests** to a host, but **never replying to the SYN/ACK**
- The victim's listen queue is quickly filled up
- The ability to **delay** each incomplete **connection for 75 seconds** can be used cumulatively as a **Denial-of-Service attack**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

SYN Flood Attack

In a SYN attack, the attacker sends a large number of SYN requests to the target server (victim) with fake source IP addresses. The attack creates incomplete TCP connections that use up network resources. Normally, when a client wants to begin a TCP connection to a server, the client and server exchange the following series of messages:

- A TCP SYN request packet is sent to a server.
- The server sends a SYN/ACK (acknowledgement) in response to the request.
- The client sends a response ACK to the server to complete the session setup.

This method is a "three-way handshake."

In a SYN attack, the attacker exploits the three-way handshake method. First, the attacker sends a fake TCP SYN request to the target server. After the server sends a SYN/ACK in response to the client's (attacker's) request, the client never sends an ACK response. This leaves the server waiting to complete the connection.

SYN flooding takes advantage of the flawed manner in which most hosts implement the TCP three-way handshake. This attack occurs when the attacker sends unlimited SYN packets (requests) to the host system. The process of transmitting such packets is faster than the system can handle. Normally, a connection is established with the TCP three-way handshake. The host keeps track of partially open connections while waiting for response ACK packets in a listening queue.

As shown in the figure, when Host B receives a SYN request from Host A, it must keep track of the partially opened connection in a "listen queue" for at least 75 s.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

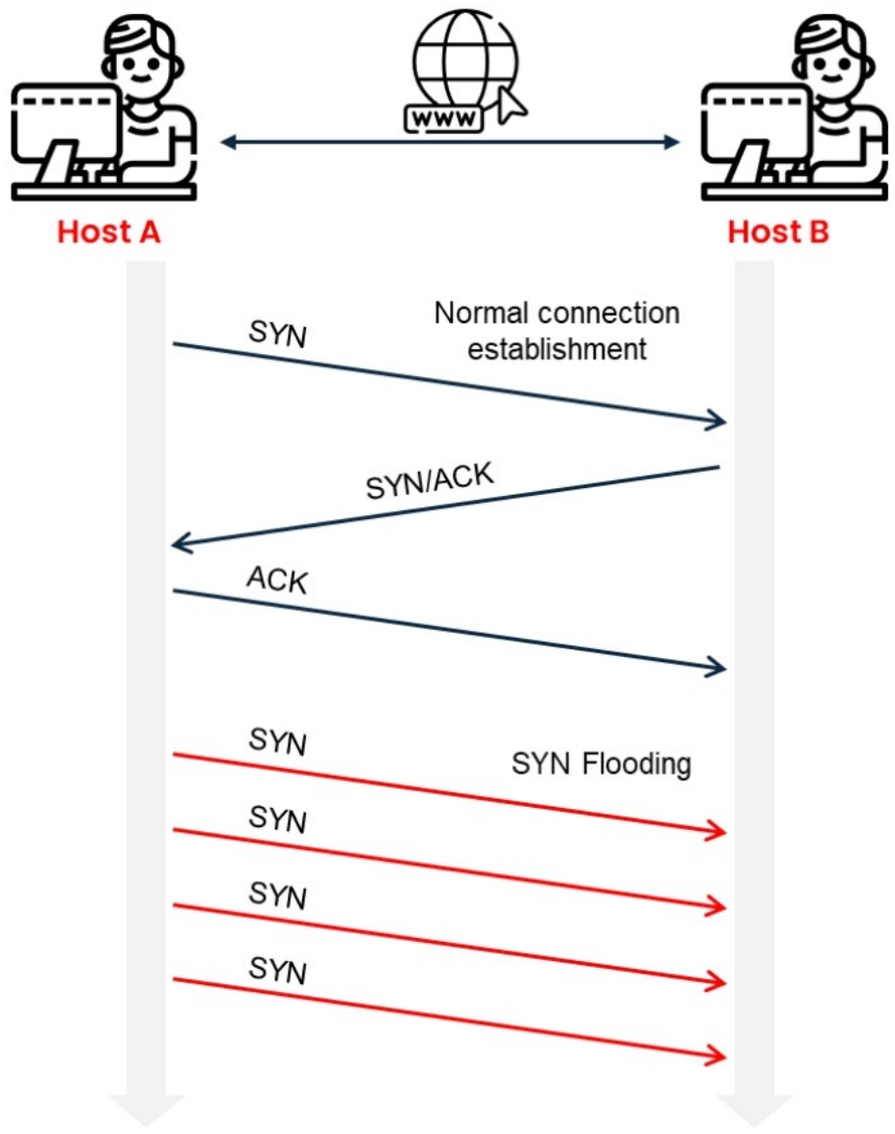


Figure 10.21: SYN flood attack

A malicious host can exploit another host, managing many partial connections by sending many SYN requests to the target host simultaneously. When the queue is full, the system cannot open new connections until it drops some entries from the connection queue through handshake timeouts. This ability to hold up each incomplete connection for 75 s can be cumulatively exploited in a DoS attack. The attack uses fake IP addresses, making it difficult to trace the source. An attacker can fill a table of connections even without spoofing the source IP address.

In addition to SYN flood attacks, attackers can also employ SYN-ACK and ACK/PUSH ACK flood attacks to disrupt target machines. All these attacks are similar in functionality with minor variations.

SYN-ACK Flood Attack

This type of attack is similar to the SYN flood attack, except that in this type of flood attack, the attacker exploits the second stage of a three-way handshake by sending a large number of SYN-ACK packets to the target machine to exhaust its resources.

ACK and PUSH ACK Flood Attack

During an active TCP session, ACK and PUSH ACK are the flags used to transfer information to and from the server and client machines till the session ends. In an ACK and PUSH ACK flood attack, attackers send a large amount of spoofed ACK and PUSH ACK packets to the target machine, making it non-functional.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Countermeasures for SYN Flood Attacks

Proper packet filtering is a viable solution to SYN flood attacks. An administrator can also tune the TCP/IP stack to reduce the impact of SYN attacks while allowing legitimate client traffic.

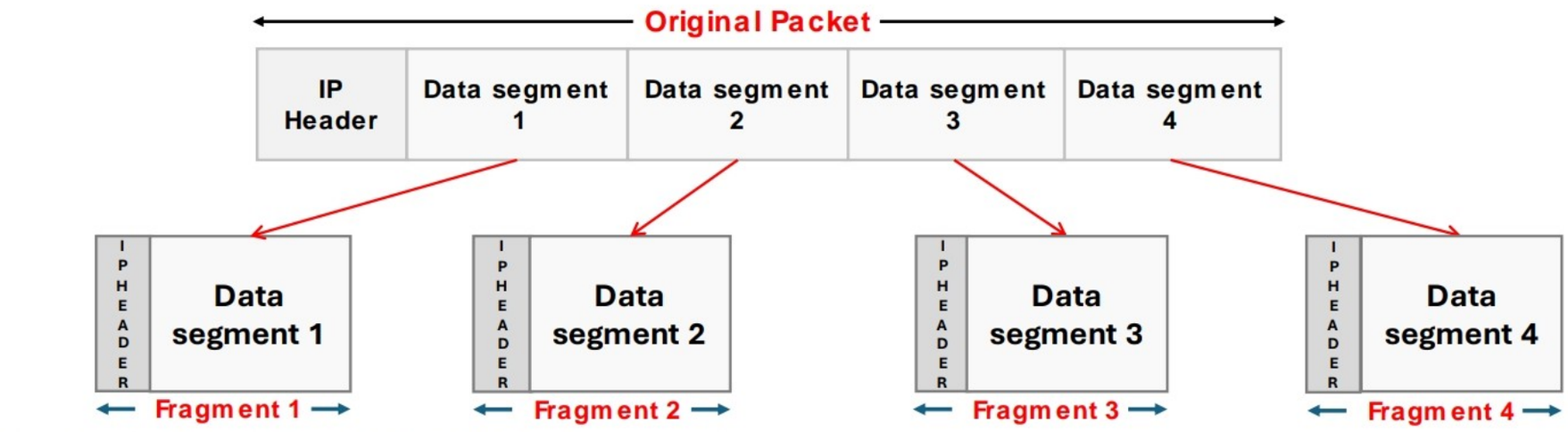
Some SYN attacks do not attempt to upset servers; instead, they attempt to consume the entire bandwidth of the Internet connection. Two tools to counter this attack are SYN cookies and SynAttackProtect.

To guard against an attacker attempting to consume the bandwidth of an Internet connection, an administrator can implement some additional safety measures; for example, they can decrease the time-out period in which a pending connection is maintained in the "SYN RECEIVED" state in the queue. Normally, if a client sends no response ACK, a server will retransmit the first ACK packet. This vulnerability can be removed by decreasing the time of the first packet's retransmission, decreasing the number of packet retransmissions, or turning off packet retransmissions entirely.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Fragmentation Attack

- These attacks stop a victim from being able to **re-assemble fragmented packets** by flooding the target system with TCP or UDP fragments, resulting in reduced performance. Attackers send a large number of fragmented (1500+ byte) packets to a **target web server** with a relatively small packet rate
- Because the protocol allows for fragmentation, these packets usually pass uninspected through network equipment such as routers, firewalls, and IDS/IPS
- Reassembling and inspecting these large fragmented packets consumes excessive resources. Moreover, the **content in the packet fragments** will be randomized by the attacker, which in turn makes the process consume more resources, causing the system to crash



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Fragmentation Attack

These attacks destroy a victim's ability to reassemble fragmented packets by flooding it with TCP or UDP fragments, resulting in reduced performance. In fragmentation attacks, the attacker sends a large number of fragmented (1500+ byte) packets to a target web server with a relatively small packet rate. Since the protocol allows fragmentation, these packets are usually uninspected as they pass through network equipment such as routers, firewalls, and the intrusion detection system (IDS)/intrusion prevention system (IPS). The reassembly and inspection of these large, fragmented packets consume excessive resources. Moreover, the content in the packet fragments is randomized by the attacker, which makes the reassembly and inspection consume more resources and, in turn, causes the system to crash.

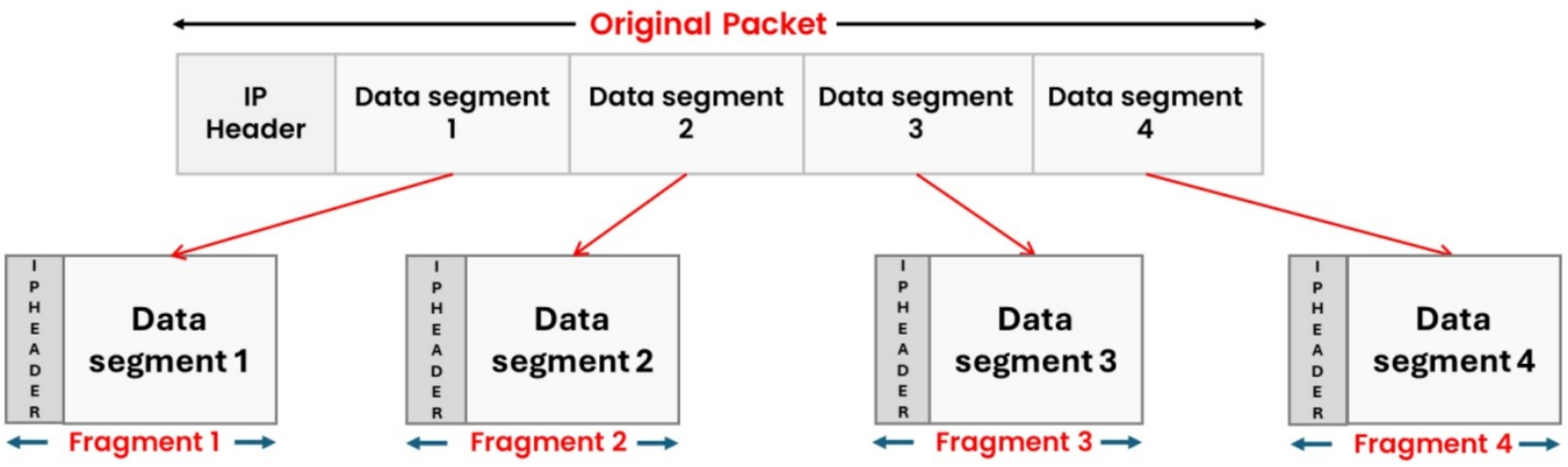


Figure 10.22: Fragmentation attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Spoofed Session Flood Attack

- Attackers **create fake or spoofed TCP sessions** by carrying multiple **SYN**, **ACK**, and **RST or FIN packets**
- Attackers employ this attack to **bypass firewalls** and **perform DDoS attacks** against the target network, exhausting its network resources

Multiple SYN-ACK Spoofed Session Flood Attack

Attackers create a fake session with **multiple SYN and multiple ACK packets** along with **one or more RST or FIN packets**

Multiple ACK Spoofed Session Flood Attack

Attackers create a fake session by **completely skipping the SYN packets** and using only **multiple ACK packets** along with **one or more RST or FIN packets**

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Spoofed Session Flood Attack

In this type of attack, attackers create fake or spoofed TCP sessions by carrying multiple SYN, ACK, and RST or FIN packets. Attackers employ this attack to bypass firewalls and perform DDoS attacks against target networks, exhausting their network resources.

The following are examples for spoofed session flood attacks:

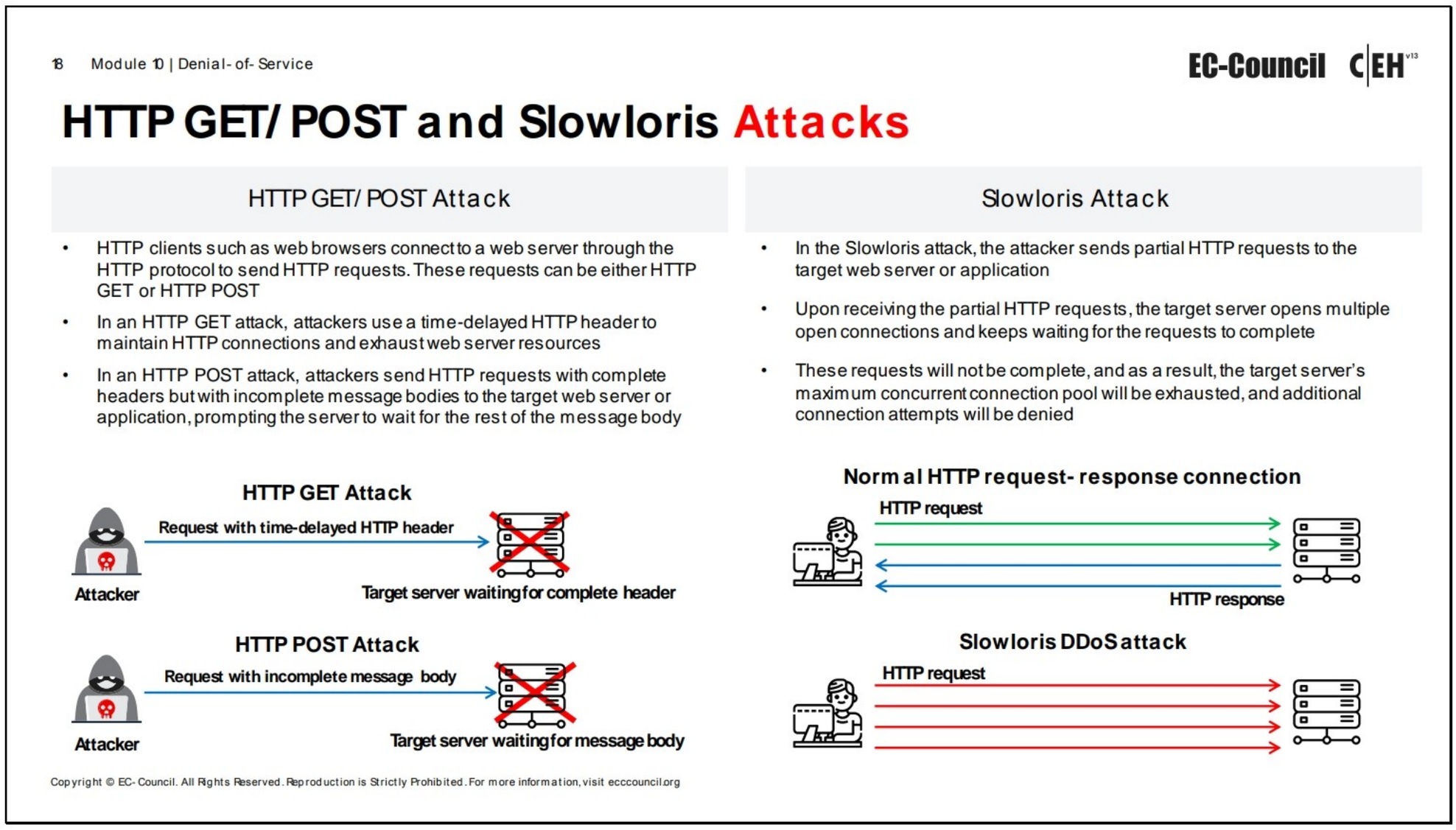
- **Multiple SYN-ACK Spoofed Session Flood Attack**

  In this type of flood attack, attackers create a fake session with multiple SYN and multiple ACK packets, along with one or more RST or FIN packets.

- **Multiple ACK Spoofed Session Flood Attack**

  In this type of flood attack, attackers create a fake session by completely skipping SYN packets and using only multiple ACK packets along with one or more RST or FIN packets. Because SYN packets are not employed and firewalls mostly use SYN packet filters to detect abnormal traffic, the DDoS detection rate of the firewalls is very low for these types of attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



HTTP GET/POST Attack

HTTP attacks are layer-7 attacks. HTTP clients, such as web browsers, connect to a web server through HTTP to send HTTP requests, which can be either HTTP GET or HTTP POST. Attackers exploit these requests to perform DoS attacks.

In an HTTP GET attack, the attacker uses a time-delayed HTTP header to hold on to an HTTP connection and exhaust web-server resources. The attacker never sends the full request to the target server. Consequently, the server retains the HTTP connection and waits, making it inaccessible for legitimate users. In these types of attacks, all the network parameters appear healthy while the service remains unavailable.

In an HTTP POST attack, the attacker sends HTTP requests with complete headers but an incomplete message body to the target web server or application. Because the message body is incomplete, the server waits for the rest of the body, making the web server or web application unavailable to legitimate users.

An HTTP GET/POST attack is a sophisticated layer-7 attack that does not use malformed packets, spoofing, or reflection techniques. This type of attack requires less bandwidth than other attacks to bring down the targeted site or web server. This attack aims to compel the server to allocate as many resources as possible to serve the attack, thereby denying legitimate users access to the server's resources.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

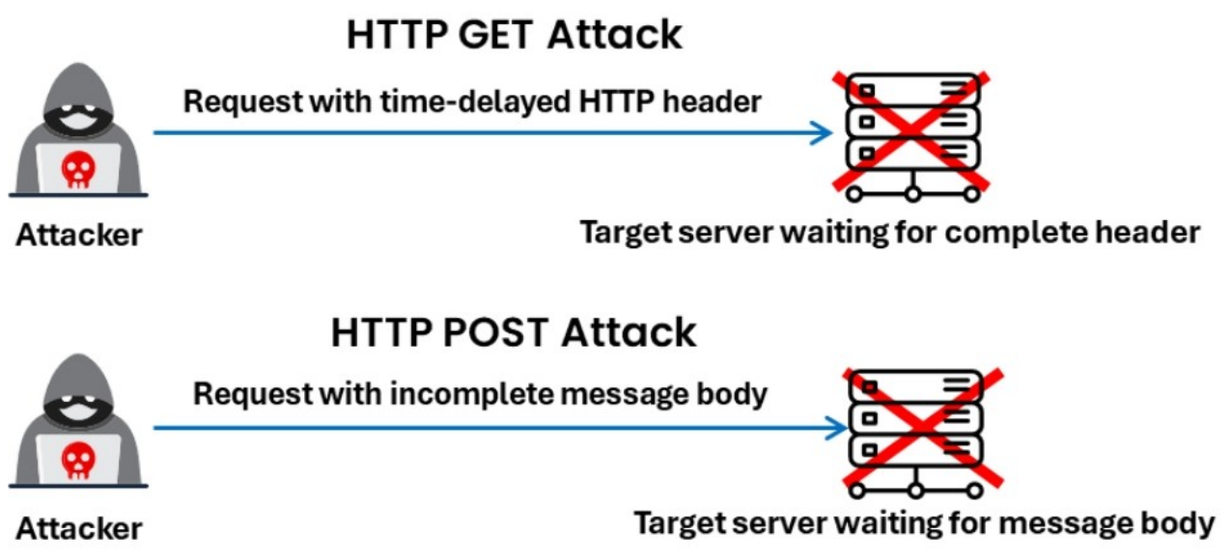


Figure 10.23: HTTP GET/POST attack

In addition to the aforementioned HTTP GET/POST attack, attackers can employ the following HTTP flood attacks to exhaust the target network's bandwidth:

- **Single-Session HTTP Flood Attack**

  In this type of flood attack, an attacker exploits the vulnerabilities in HTTP 1.1 to bombard a target with multiple requests in a single HTTP session.

- **Single-Request HTTP Flood Attack**

  This type of attack involves the attacker making multiple HTTP requests from a single HTTP session by concealing these requests within a single HTTP packet. This technique allows attackers to be anonymous and invisible while performing DDoS attacks.

- **Recursive HTTP GET Flood Attack**

  Staying undetected is key for attackers. An attacker posing as a legitimate user and performing legitimate actions can trick any firewall into believing that the source is legitimate while it is not. Recursive GET collects a list of pages or images and appears to be going through these pages or images. However, it stealthily performs flooding attacks on the target. The recursive GET in combination with an HTTP flood attack can cause extreme damage to the target.

- **Random Recursive GET Flood Attack**

  This type of attack is a tweaked version of the recursive GET flood attack. It is designed for forums, blogs, and other websites that have pages in a sequence. Similar to the recursive GET flood attack, in this attack, the recursive GET pretends to be going through pages. Because the targets are forums, groups, and other blogs, the attacker uses random numbers from a valid page range to pose as a legitimate user and sends a new GET request each time. In both recursive GET and random recursive GET flood attacks, the target is bombarded with a large number of GET requests, exhausting its resources.

Slowloris Attack

Slowloris is a DDoS attack tool used to perform layer-7 DDoS attacks to take down web infrastructure. It is distinctly different from other tools in that it uses perfectly legitimate HTTP traffic to take down a target server. In Slowloris attacks, the attacker sends partial HTTP

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

requests to the target web server or application. Upon receiving the partial requests, the target server opens multiple connections and waits for the requests to complete. However, these requests remain incomplete, causing the target server's maximum concurrent connection pool to be filled up and additional connection attempts to be denied.

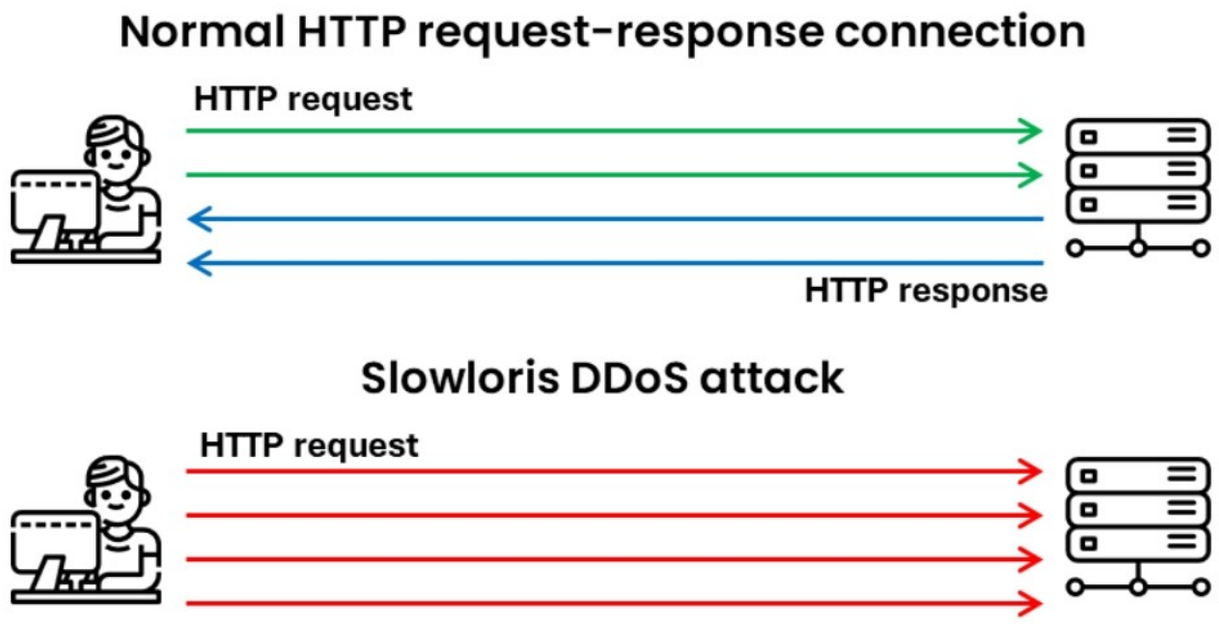


Figure 10.24: Slowloris attack

UDP Application Layer Flood Attack

Though UDP flood attacks are known for their volumetric attack nature, some application layer protocols that rely on UDP can be employed by attackers to perform flood attacks on target networks.

The following are examples for UDP-based application layer protocols that attackers can employ for flooding target networks:

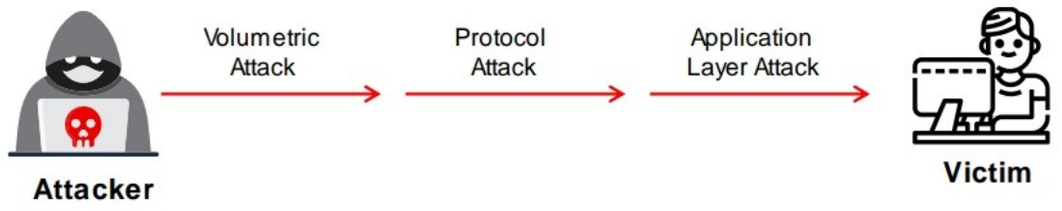
- Character Generator Protocol (CHARGEN)
- Simple Network Management Protocol Version 2 (SNMPv2)
- Quote of the Day (QOTD)
- Remote procedure call (RPC)
- SSDP
- Connection-less Lightweight Directory Access Protocol (CLDAP)
- Trivial File Transfer Protocol (TFTP)
- Network Basic Input/Output System (NetBIOS)
- NTP
- Quake Network Protocol
- Steam Protocol
- Voice over Internet Protocol (VoIP)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

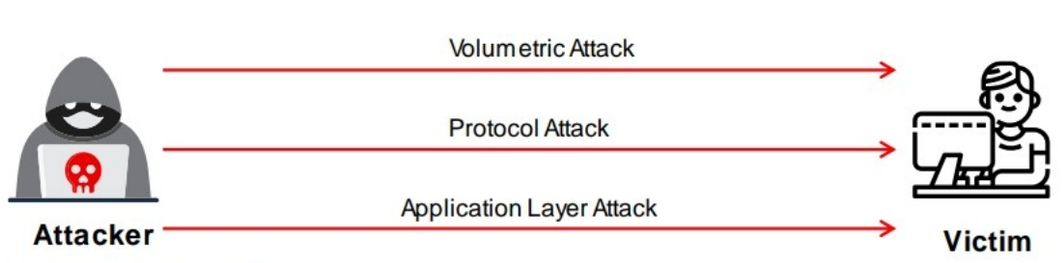
Multi-Vector Attack

- In multi-vector DDoS attacks, the attackers use **combinations of volumetric**, protocol, and application-layer attacks to disable the target system or service
- Attackers rapidly and repeatedly change the form of their DDoS attack (e.g., SYN packets, Layer 7)
- These attacks are either **launched one vector at a time** or in parallel to confuse a company's IT department and exhaust their resources with their focus diverted to the wrong solution

Multi-Vector attack in sequence



Multi-Vector attack in parallel

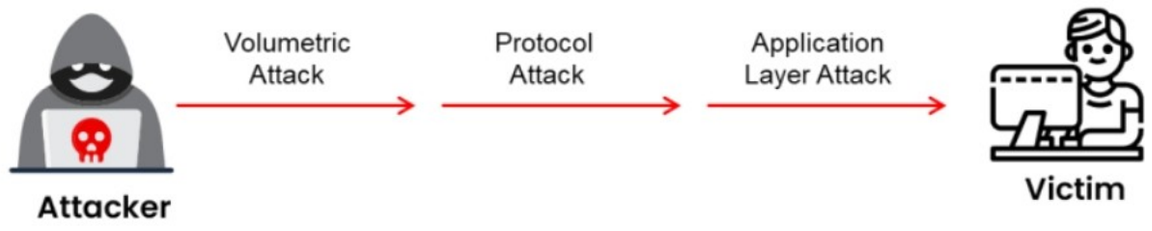


Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Multi-Vector Attack

In multi-vector DDoS attacks, the attacker uses combinations of volumetric, protocol, and application layer attacks to take down the target system or service. The attacker quickly changes from one form of DDoS attack (e.g., SYN packets) to another (layer 7). These attacks are either launched through one vector at a time or through multiple vectors in parallel to confuse a company's IT department, making them spend all their resources and maliciously diverting their focus.

Multi-Vector attack in sequence



Multi-Vector attack in parallel

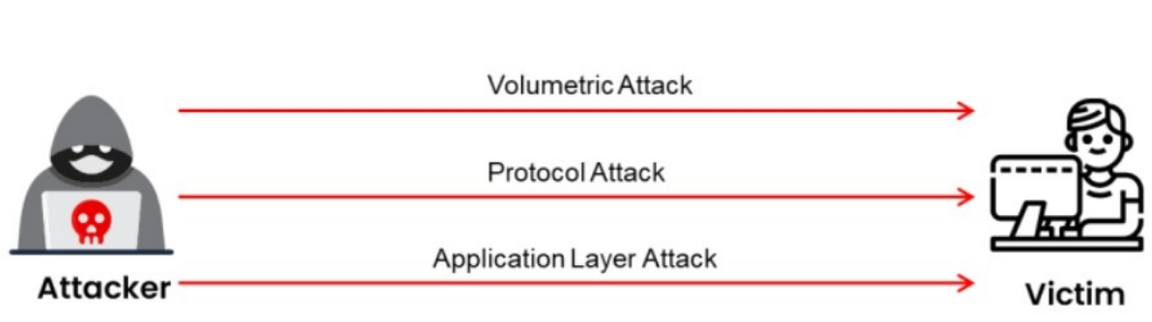
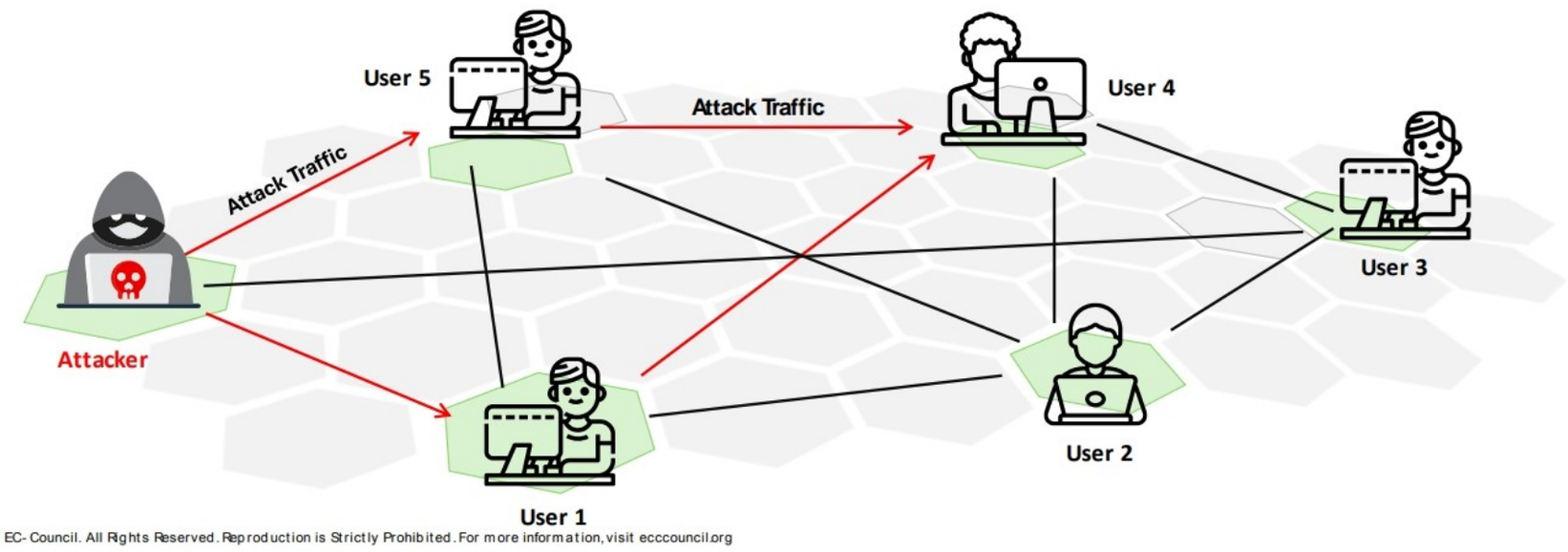


Figure 10.25: Multi-vector attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Peer-to-Peer Attack

- Using peer-to-peer attacks, attackers **instruct clients of peer-to-peer file sharing hubs** to disconnect from their peer-to-peer network and to connect to the victim's fake website
- Attackers **exploit flaws** found in the network using the DC++ (Direct Connect) protocol, which is used for sharing all types of files between instant messaging clients
- Using this method, attackers launch **massive denial-of-service attacks** and compromise websites



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Peer-to-Peer Attack

A peer-to-peer attack is a form of DDoS attack in which the attacker exploits a number of bugs in peer-to-peer servers to initiate a DDoS attack. Attackers exploit flaws found in networks that use the Direct Connect (DC++) protocol, which allows the exchange of files between instant-messaging clients. This kind of attack does not use botnets. Unlike a botnet-based attack, a peer-to-peer attack eliminates the need for attackers to communicate with the clients they subvert. Here, the attacker instructs clients of large peer-to-peer file sharing hubs to disconnect from their peer-to-peer network and instead connect to the victim's website. Consequently, several thousand computers may aggressively attempt to connect to a target website, causing a drop in the performance of the target website. It is easy to identify peer-to-peer attacks based on signatures. By using this method, attackers launch massive DoS attacks to compromise websites.

Peer-to-peer DDoS attacks can be minimized by specifying ports for peer-to-peer communication. For example, specifying port 80 to disallow peer-to-peer communication minimizes the possibility of attacks on websites.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

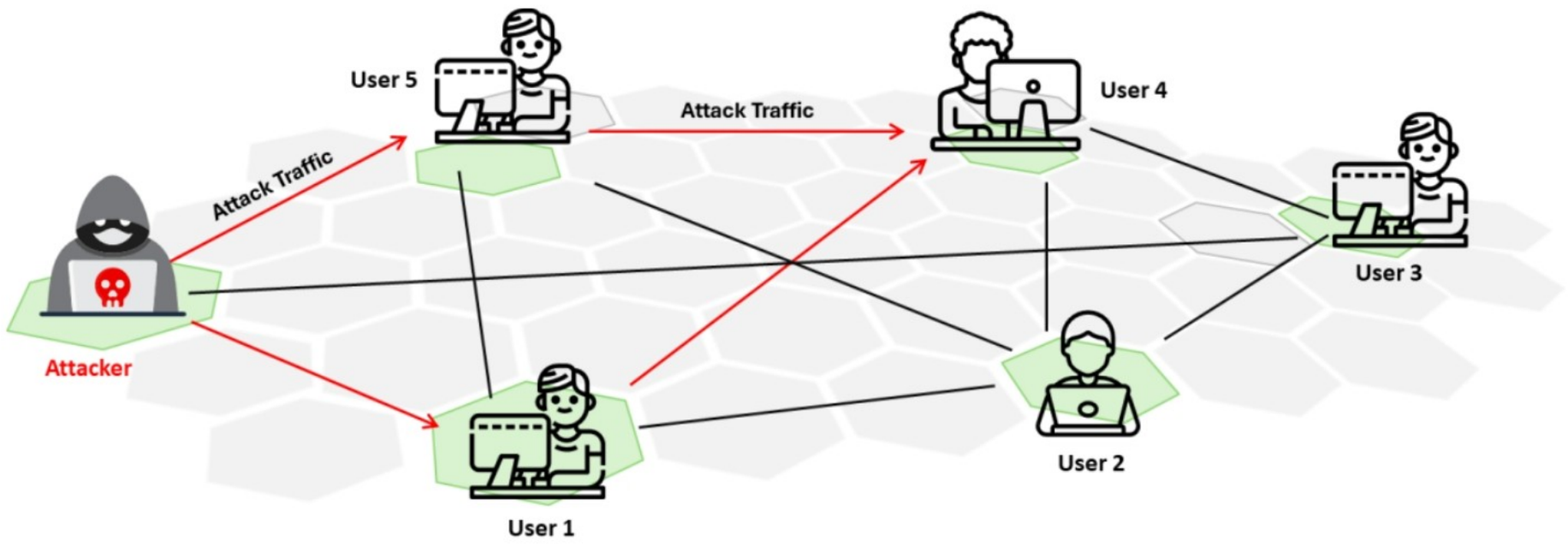
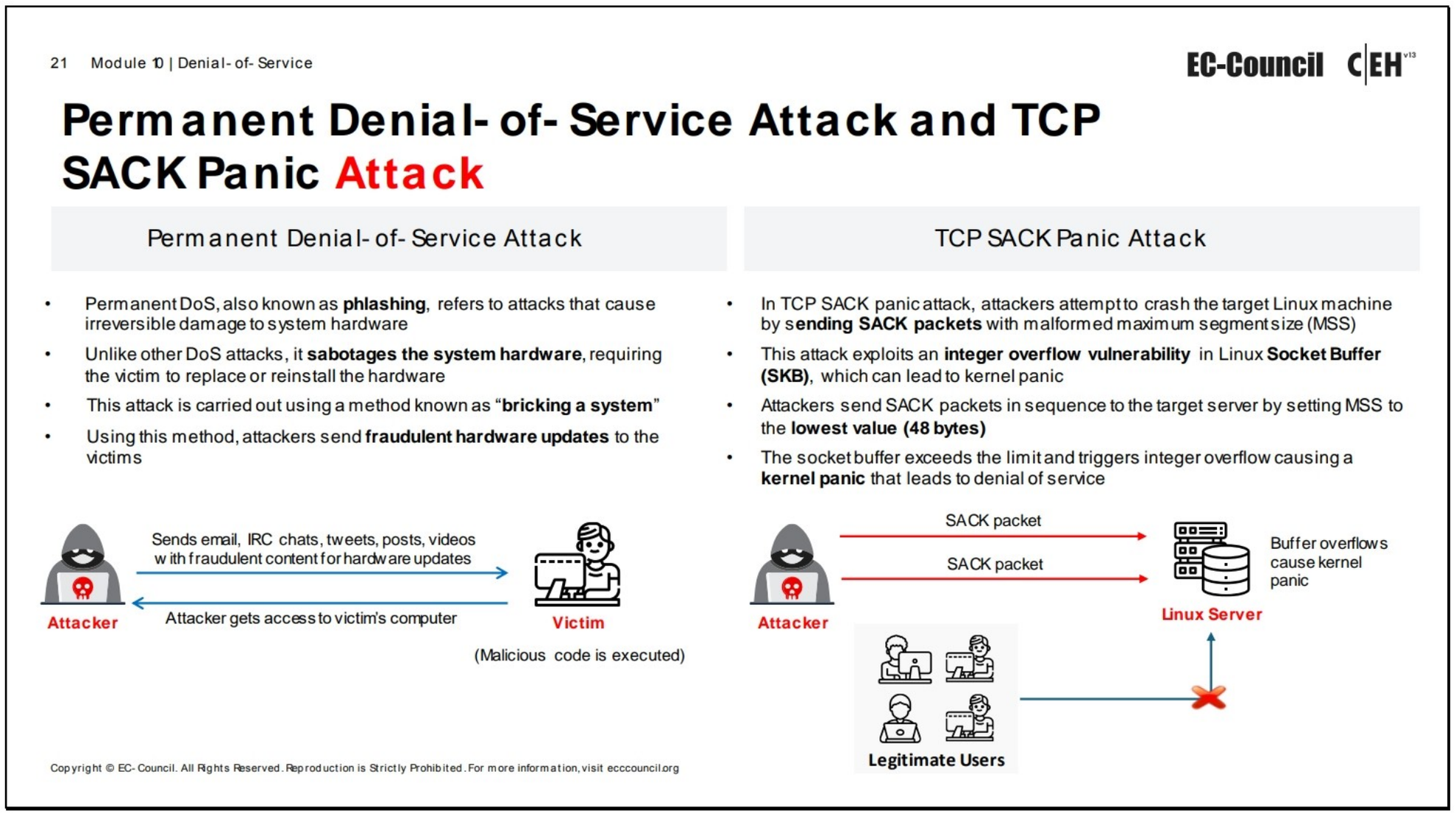


Figure 10.26: Peer-to-peer attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Permanent Denial-of-Service Attack

Permanent DoS (PDoS) attacks, also known as phlashing, purely target hardware and cause irreversible damage to the hardware. Unlike other types of DoS attacks, it sabotages the system hardware, requiring the victim to replace or reinstall the hardware. The PDoS attack exploits security flaws in a device to allow remote administration on the management interfaces of the victim's hardware, such as printers, routers, and other networking devices.

This type of attack is quicker and more destructive than conventional DoS attacks. It works with a limited amount of resources, unlike a DDoS attack, in which attackers unleash a set of zombies onto a target. Attackers perform PDoS attacks by using a method known as the "bricking" of a system. In this method, the attacker sends emails, IRC chats, tweets, or videos with fraudulent content for hardware updates to the victim. The hardware updates are modified and corrupted with vulnerabilities or defective firmware. When the victim clicks on a link or pop-up window referring to the fraudulent hardware update, the victim installs it in their system. Consequently, the attacker attains complete control over the victim's system.

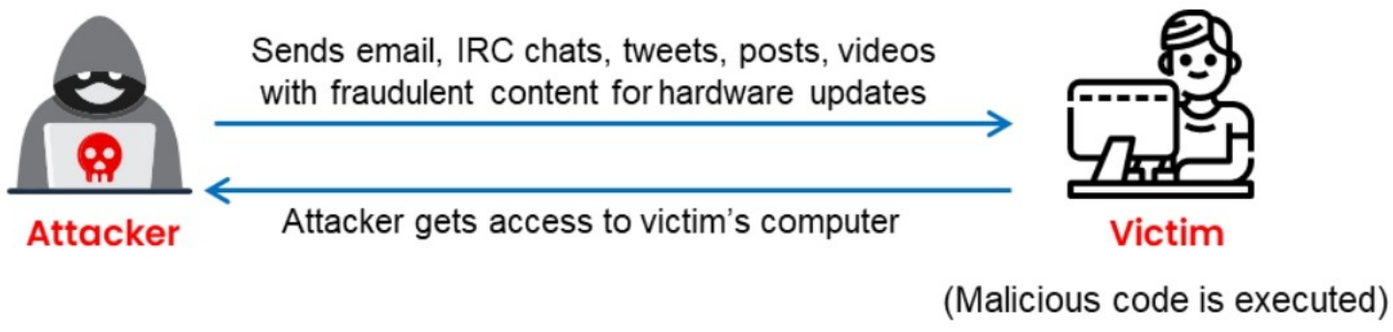


Figure 10.27: Permanent DoS attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

TCP SACK Panic Attack

TCP Selective Acknowledgment (SACK) panic attack is a remote attack vector in which attackers attempt to crash the target Linux machine by sending SACK packets with malformed maximum segment size (MSS). This attack exploits an integer overflow vulnerability in Linux Socket Buffer (SKB) that can lead to kernel panic. Generally, Linux systems use the TCP SACK method, where the sender is informed about the packets that are successfully acknowledged by the receiver. Therefore, the sender can retransmit only those packets that are not successfully acknowledged by the receiver. Here, Linux uses a linked-list data structure called socket buffer to store the data until it is acknowledged or received. The socket buffer can store a maximum of 17 segments. Then, the acknowledged packets are instantly deleted from the linked data structure. If buffer socket tries to store more than 17 segments, it can cause kernel panic.

The TCP SACK panic attack leverages this vulnerability of the socket buffer. To achieve this, attackers send specially designed SACK packets in sequence to the target server by setting the MSS to the lowest value (48 bytes). The lowest MSS value increases the number of TCP segments that need to be retransmitted. This selective retransmission causes the socket buffer of the target server to exceed the limit of 17 segments. Thus, the socket buffer exceeds the limit and triggers integer overflow, causing a kernel panic that leads to DoS. As the vulnerability lies in the kernel stack, attackers can also perform this attack against containers and virtual machines.

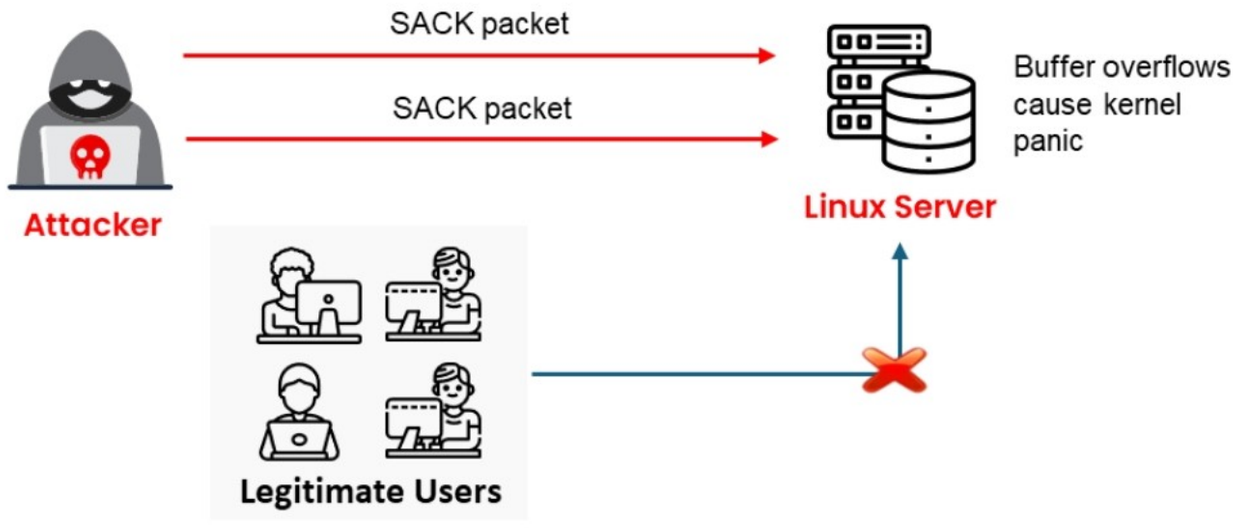
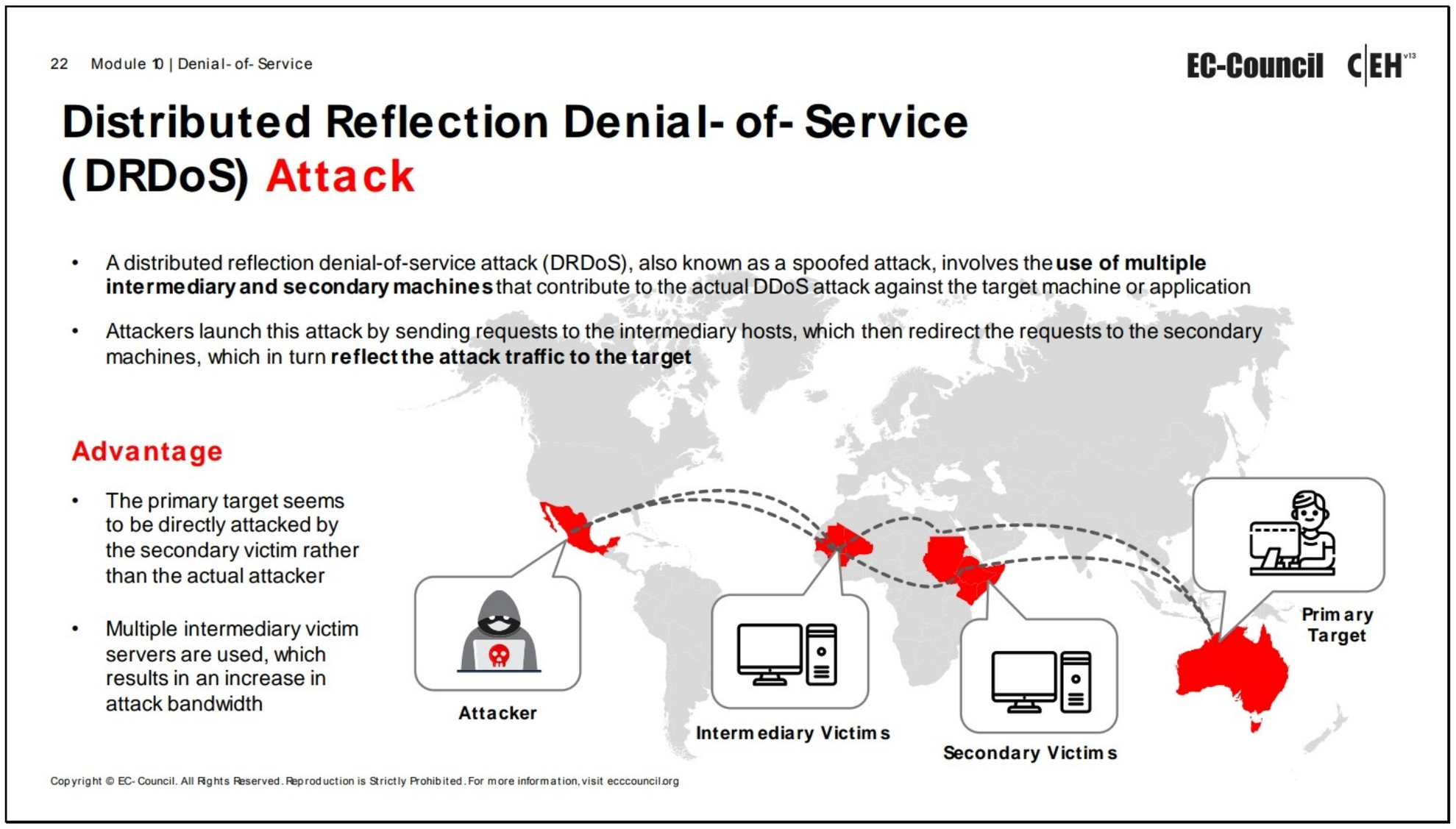


Figure 10.28: TCP SACK panic attack

Countermeasures

- Implement vulnerability patching
- Implement a firewall rule to block requesting packets with the lowest MSS

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Distributed Reflection Denial-of-Service (DRDoS) Attack

A distributed reflection DoS (DRDoS) attack, also known as a "spoofed" attack, involves the use of multiple intermediary and secondary machines that contribute to a DDoS attack against a target machine or application. A DRDoS attack exploits the TCP three-way handshake vulnerability.

This attack involves an attacker machine, intermediary victims (zombies), secondary victims (reflectors), and a target machine. The attacker launches this attack by sending requests to the intermediary hosts, which in turn reflect the attack traffic to the target.

The process of a DRDoS attack is as follows. First, the attacker commands the intermediary victims (zombies) to send a stream of packets (TCP SYN) with the primary target's IP address as the source IP address to other non-compromised machines (secondary victims or reflectors) in order to exhort them to establish a connection with the primary target. Consequently, the reflectors send a huge volume of traffic (SYN/ACK) to the primary target to establish a new connection with it because they believe the host requested it. The primary target discards the SYN/ACK packets received from the reflectors because they did not send the SYN packet. Meanwhile, the reflectors wait for the ACK response from the primary target. Assuming that the packet was lost, the reflector machines resend SYN/ACK packets to the primary target to establish the connection, until a time-out occurs. In this manner, the target machine is flooded with a heavy volume of traffic from the reflector machines. The combined bandwidth of these reflector machines overwhelms the target machine.

A DRDoS attack is an intelligent attack because it is very difficult or even impossible to trace the attacker. Instead of the actual attacker, the secondary victims (reflectors) seem to attack the primary target directly. This attack is more effective than a typical DDoS attack because multiple intermediary and secondary victims generate huge attack bandwidth.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

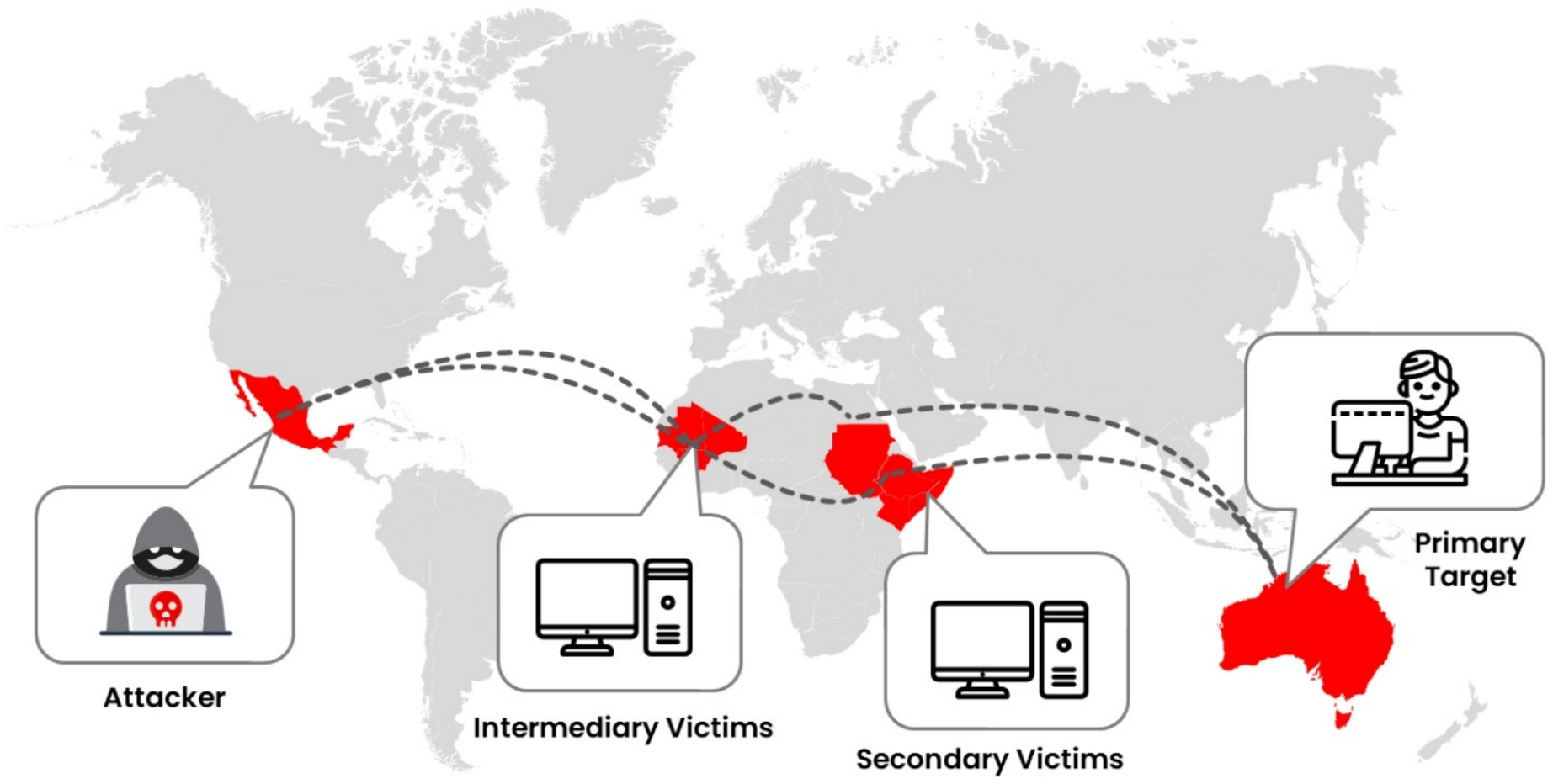


Figure 10.29: Distributed reflection DoS (DRDoS) attack

- **Countermeasures**
  - Turn off the Character Generator Protocol (CHARGEN) service to stop this attack method
  - Download the latest updates and patches for servers

DDoS Extortion/Ransom DDoS (RDDoS) Attack

The DDoS extortion attack is also referred to as ransom DDoS (RDDoS). Herein, attackers threaten the target organizations with a DDoS attack and insist them to pay a specified ransom amount. The attacker either sends a ransom note or initiates a sample DDoS attack using a botnet on specific resources of the organizations to make them believe that the attack is real. Consequently, an email with a ransom or extortion note with the payment option, deadline, etc. is delivered to the victim and warns that the original attack can be launched at any moment. The ransom note may also include short messages or a series of messages threatening the victim with vulnerabilities, exposed assets, or data followed by instructions for ransom payment through digital currency. Generally, attackers fake these attacks claiming that they have high-capacity DDoS capability tools that can cause potential damage to the organization's business.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

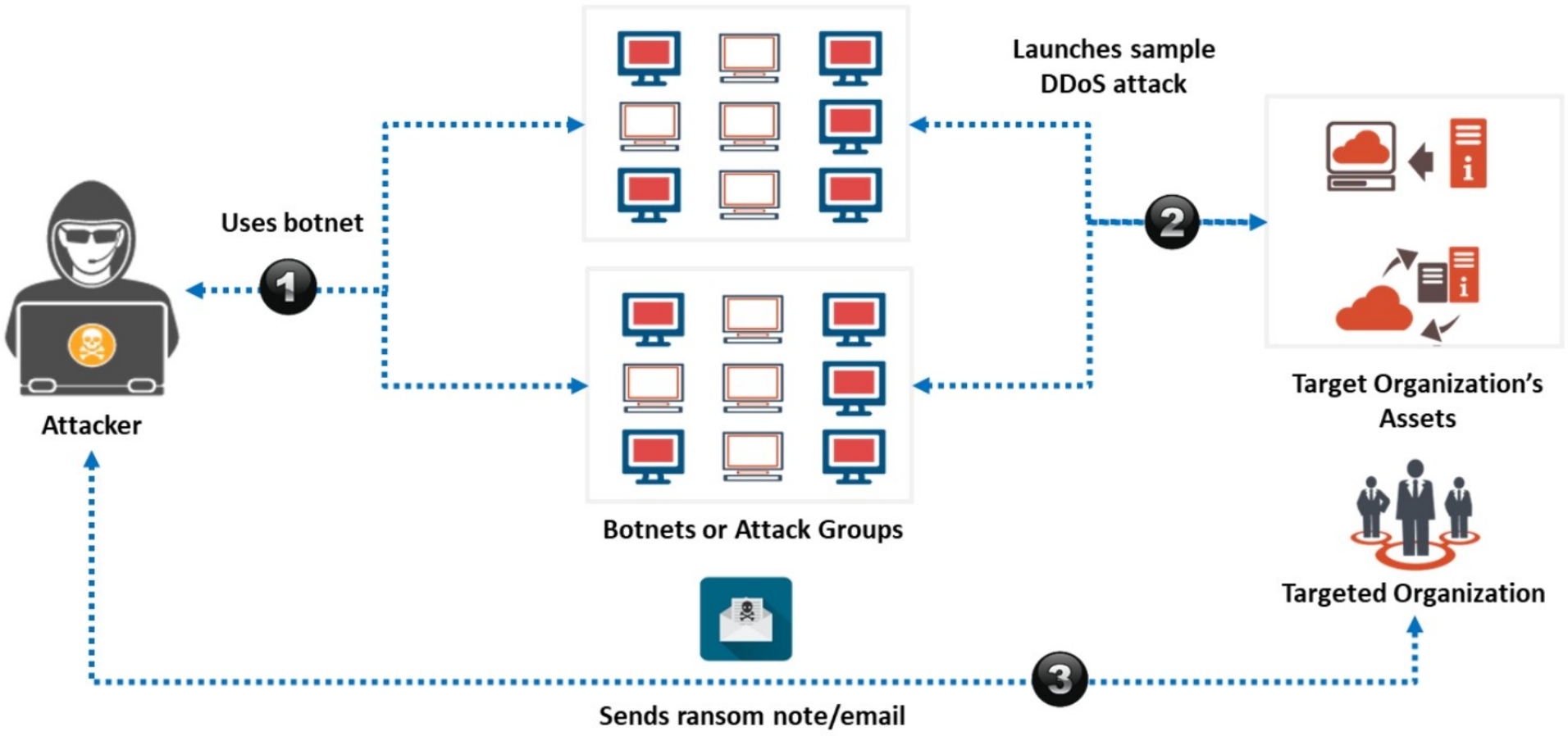
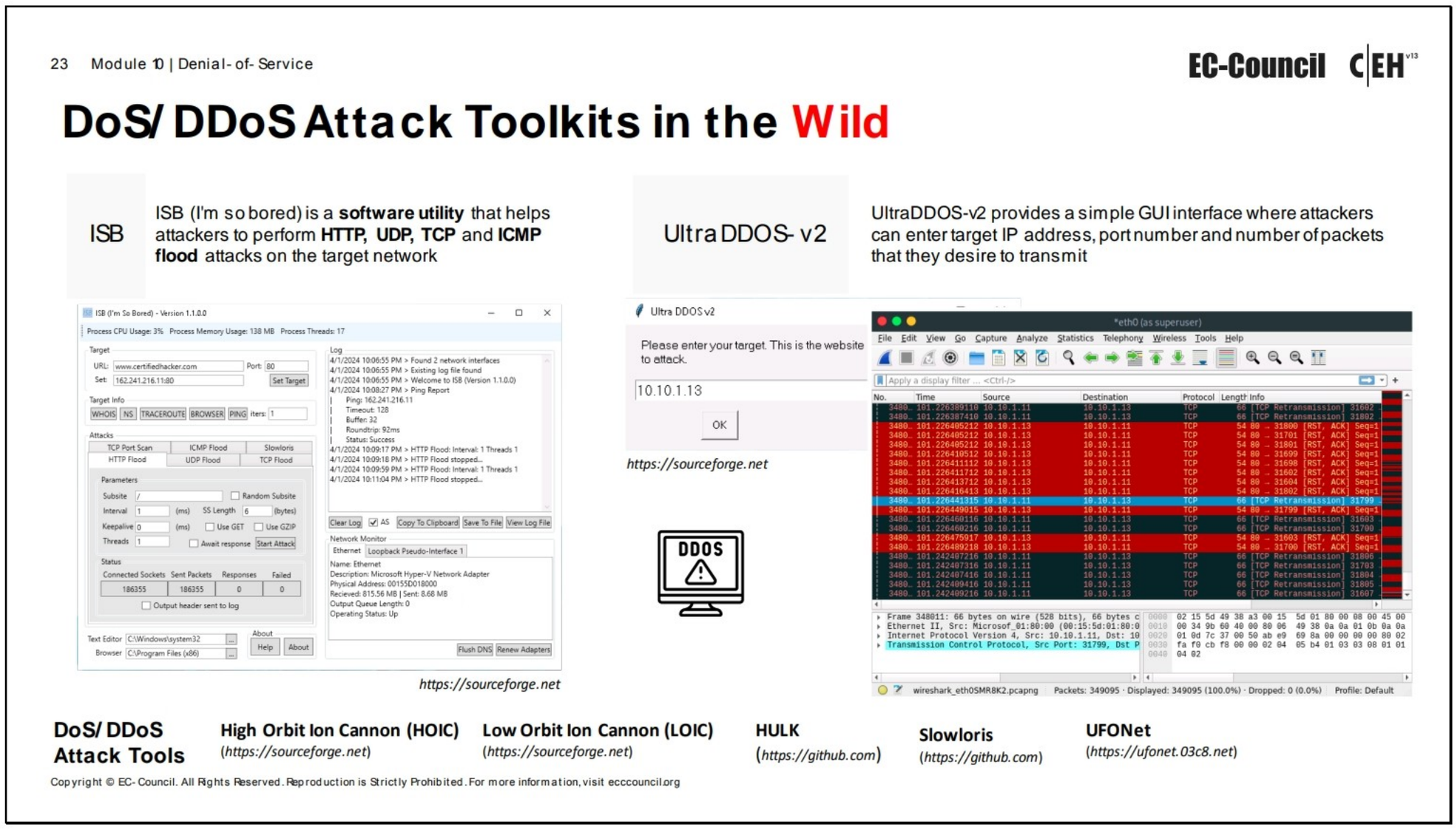


Figure 10.30: DDoS extortion attack

Countermeasures

- Implement effective DDoS defense tools
- Immediately report to the law enforcement agencies and security teams after receiving a ransom note
- Frequently evaluate assets for risk tolerance
- Implement mitigation strategies such as BGP/ DNS swing and always-on protection service

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



DoS/DDoS Attack Toolkits in the Wild

- **ISB**

  Source: *https://sourceforge.net*

  Attackers can use ISB (I'm so bored) software utility for launching DDoS on the target network. The tool helps attackers to perform HTTP, UDP, TCP and ICMP flood attacks on the target network. The tool also provides one-click access to some of the most commonly used network commands, such as WHOIS, netstat, traceroute, or ping, which helps attackers to discover the target.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

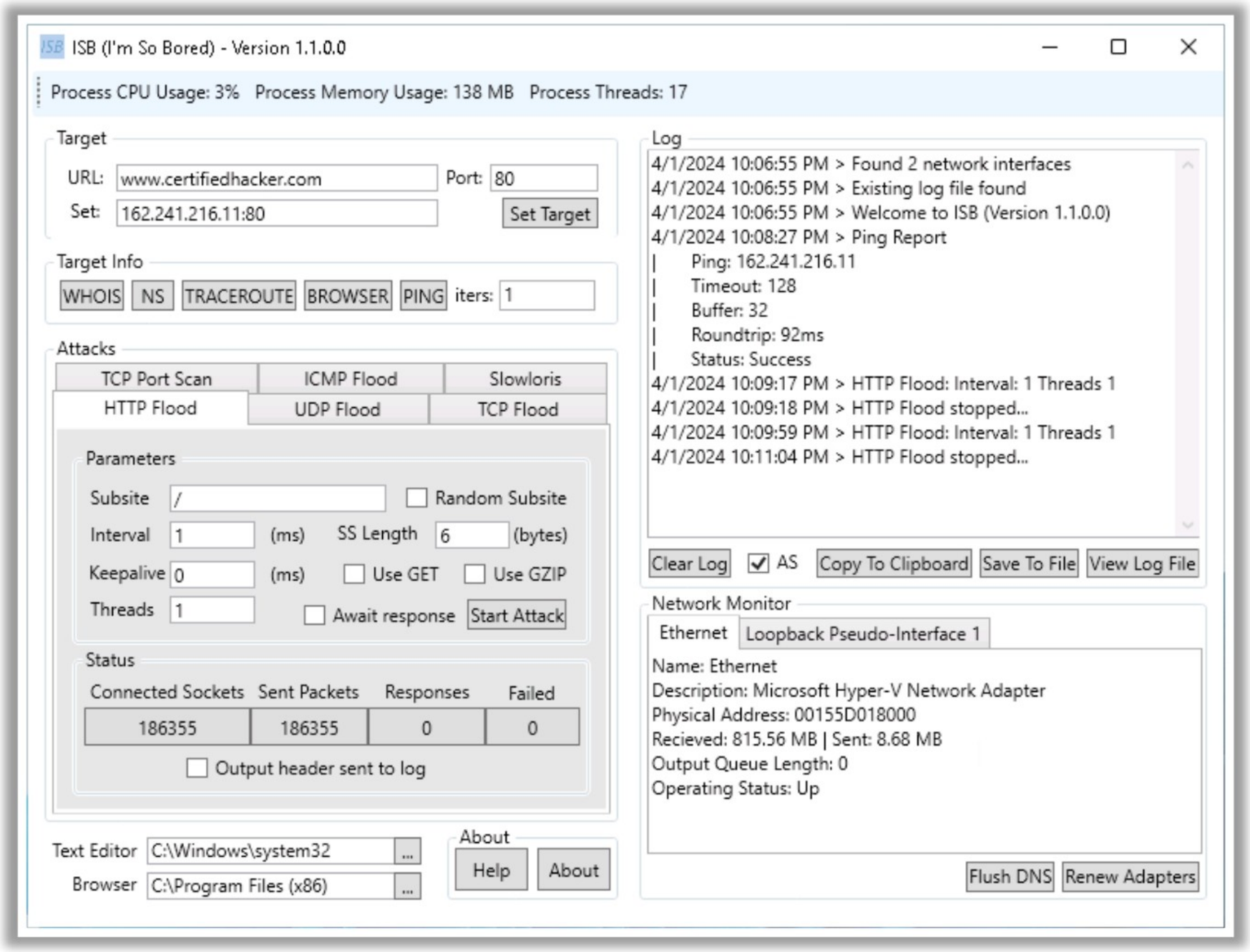


Figure 10.31: Screenshot of ISB DoS attack tool

- **UltraDDOS-v2**

Source: *https://sourceforge.net*

UltraDDOS-v2 is a DDoS tool that helps attackers perform DDoS attacks on target websites or servers. The tool provides a simple GUI interface where attackers can enter the target IP address, port number and number of packets that they desire to transmit.

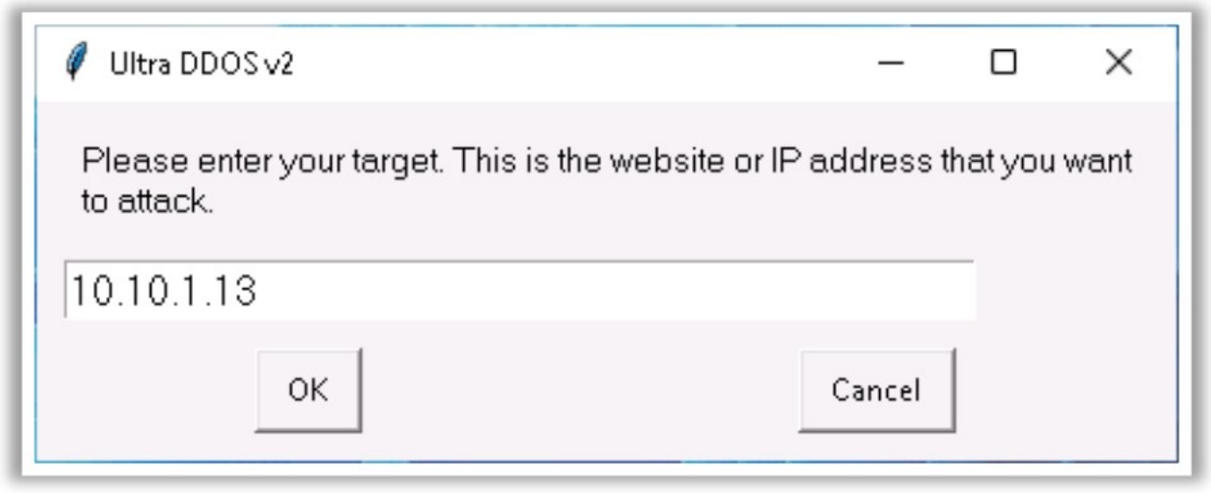


Figure 10.32: Screenshot of target IP address specified on UltraDDOS-v2

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

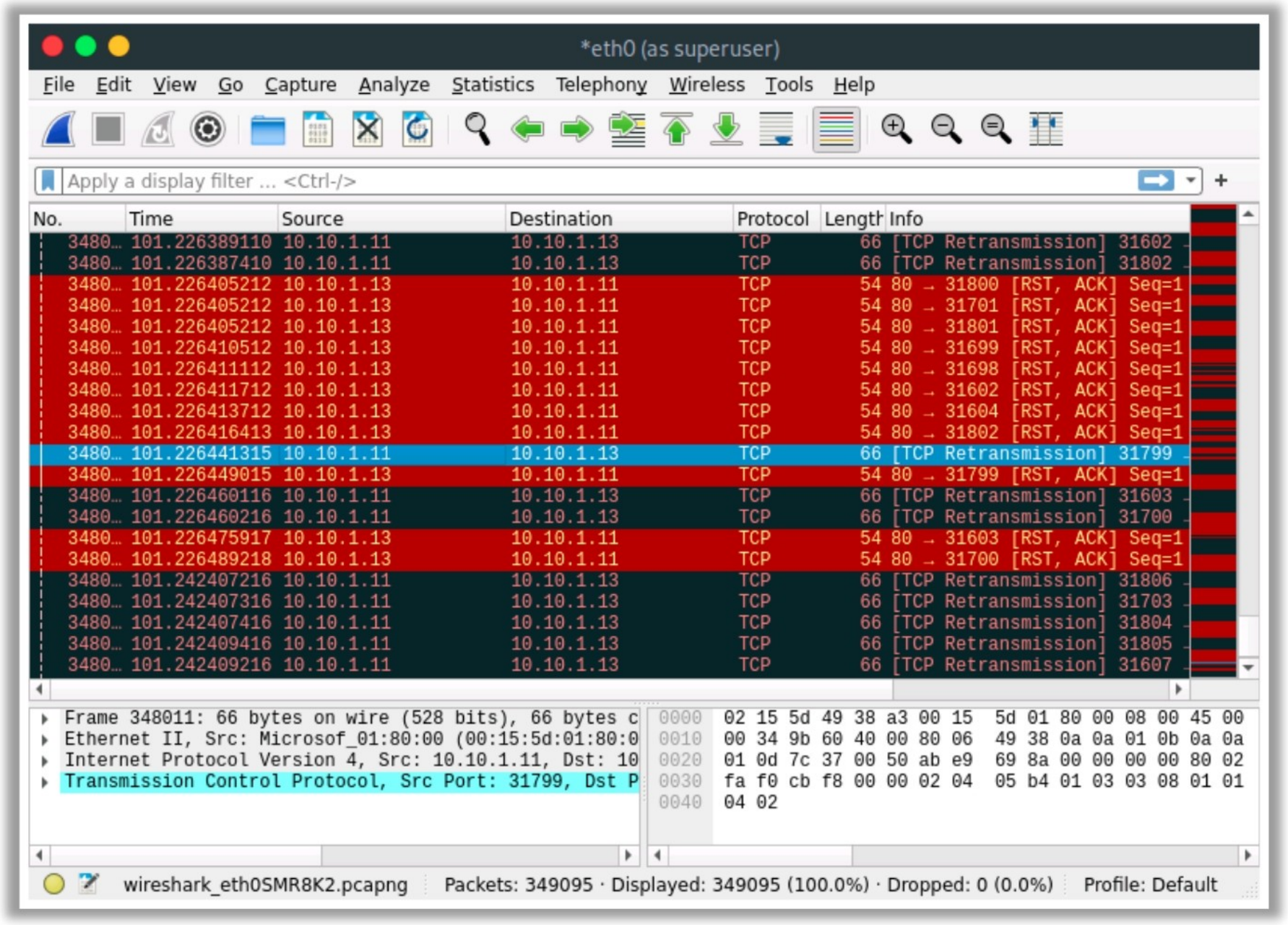
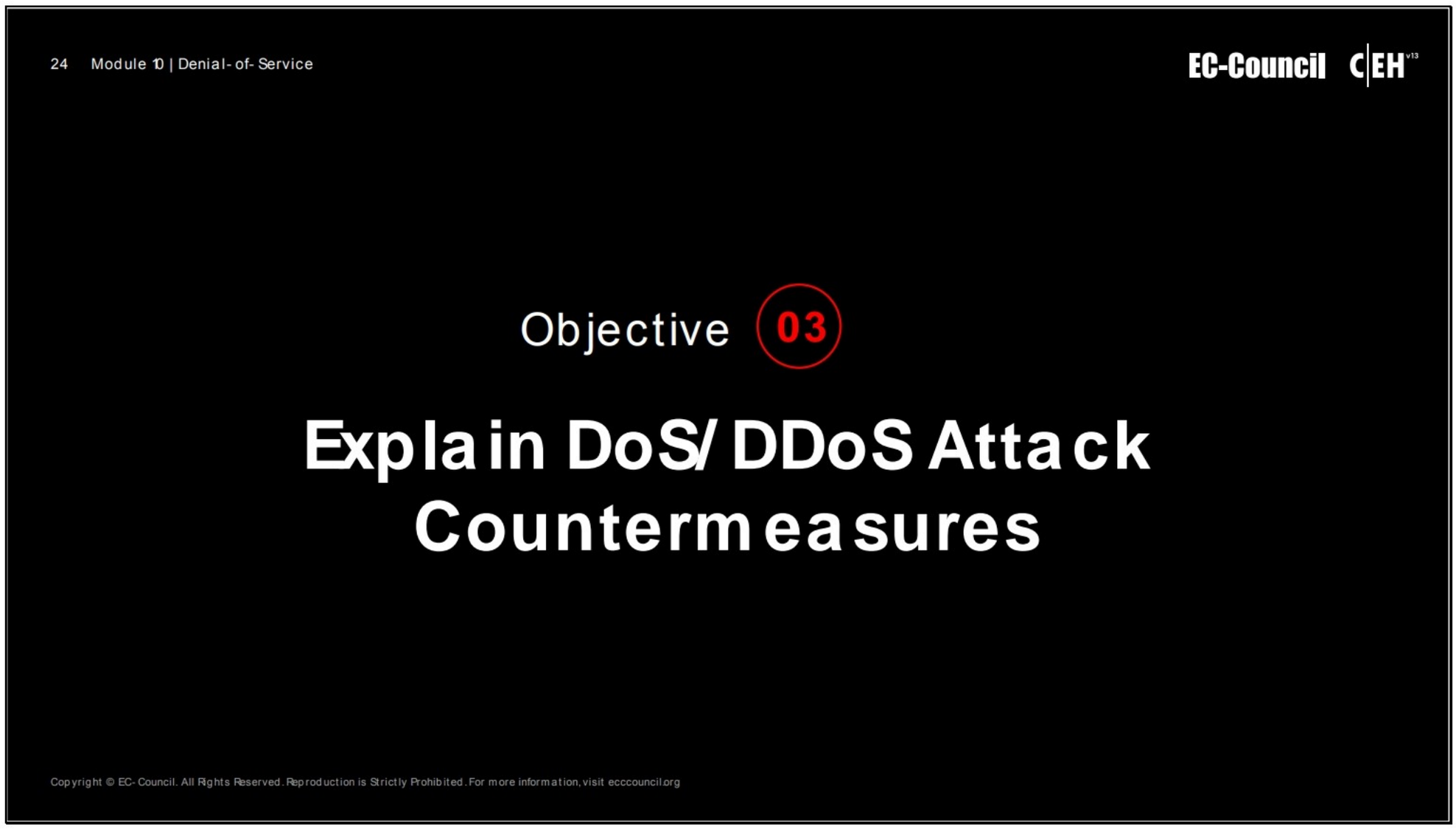


Figure 10.33: Flood recorded on the target machine

The following are some of the additional DoS/DDoS attack tools:

- High Orbit Ion Cannon (HOIC) (*https://sourceforge.net*)
- Low Orbit Ion Cannon (LOIC) (*https://sourceforge.net*)
- HULK (*https://github.com*)
- Slowloris (*https://github.com*)
- UFONet (*https://ufonet.03c8.net*)
- Packet Flooder Tool (*https://www.netscantools.com*)

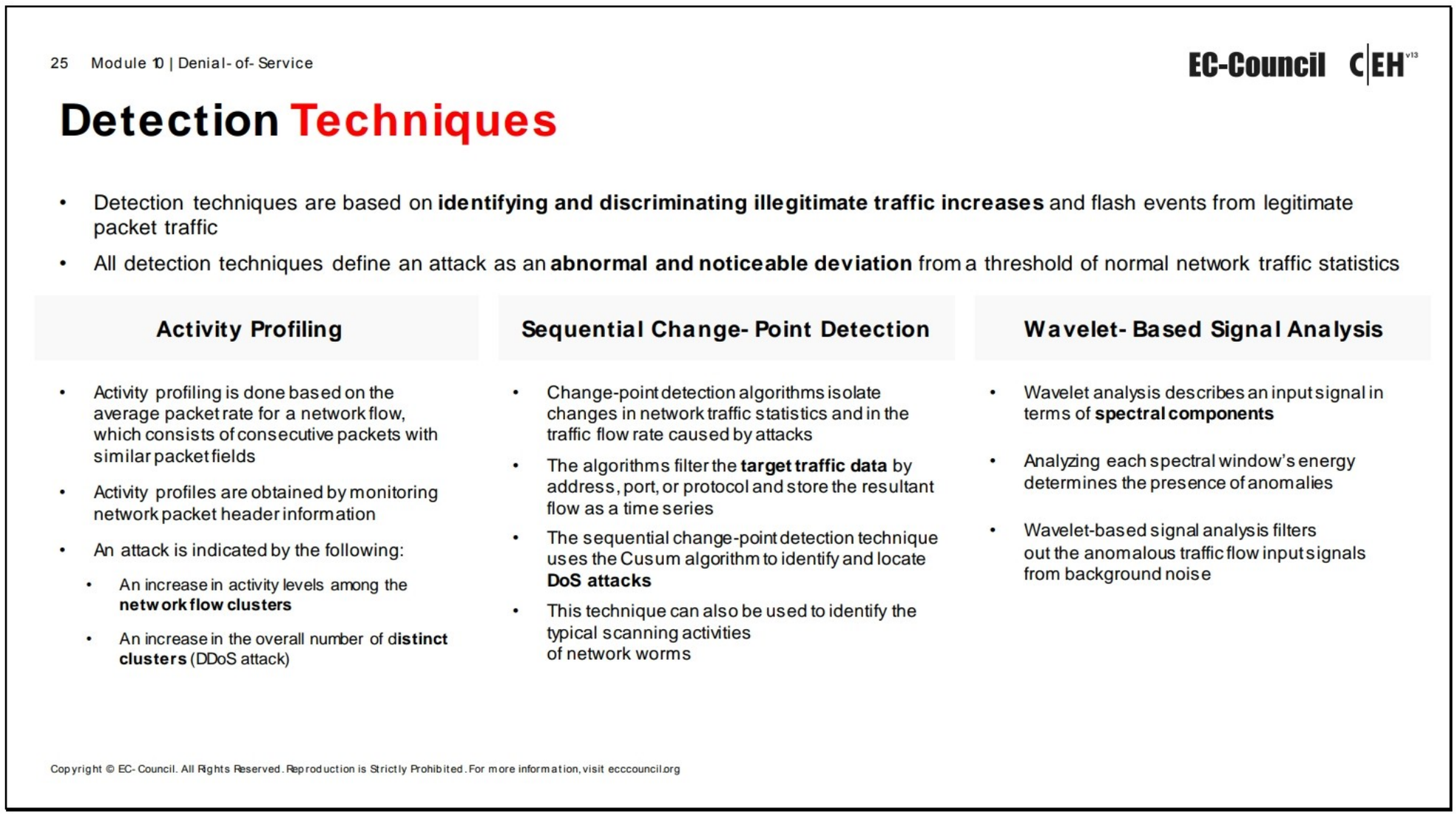
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



DoS/DDoS Attack Countermeasures

DoS/DDoS is one of the foremost security threats on the Internet; thus, there is a great necessity for solutions to mitigate these attacks. This section discusses detection methods, various preventive measures, responses to DoS/DDoS attacks, and hardware/software DoS/DDoS protection tools that are effective in safeguarding networks from DoS/DDoS attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Detection Techniques

Early detection techniques help prevent DoS/DDoS attacks. Detecting a DoS/DDoS attack is a tricky task. A DoS/DDoS attack traffic detector needs to distinguish between a genuine and a bogus data packet, which is not always possible. Therefore, the techniques employed for this purpose are not perfect. There is always a chance of confusion between traffic generated by a legitimate network user and traffic generated by a DoS/DDoS attack. Detection techniques are based on the identification and discrimination of an illegitimate traffic increase and flash events from legitimate packet traffic.

One problem in filtering bogus traffic from legitimate traffic is the volume of traffic. It is impossible to scan each data packet to ensure security from a DoS/DDoS attack.

All the detection techniques used today define an attack as an abnormal and noticeable deviation in network traffic statistics and characteristics. These techniques involve the statistical analysis of deviations to categorize malicious and genuine traffic.

The following are the three types of detection techniques:

- **Activity Profiling**

  Activity profiling is performed based on the average packet rate for network flow, which consists of consecutive packets with similar packet header information. The packet header information includes the IP addresses of the destination and sender, ports, and transport protocols used. An attack is indicated by:

  - An increase in activity levels among the network flow clusters
  - An increase in the overall number of distinct clusters (DDoS attack)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

For a higher average packet rate or activity level of a flow, the time between consecutive matching packets is lower. Randomness in the average packet rate or activity level can indicate suspicious activity. The entropy calculation method measures randomness in activity levels. If a network is under attack, the entropy of network activity levels increases.

One of the major hurdles in the activity profiling method is the huge volume of traffic. This problem can be overcome by clustering packet flows with similar characteristics. Because DoS attacks generate a large number of data packets that are very similar, an increase in the average packet rate or an increase in the diversity of packets could indicate a DoS attack.

- **Sequential Change-Point Detection**

  In the sequential change-point detection technique, network traffic is filtered by IP addresses, targeted port numbers, and communication protocols used, and the traffic flow data are stored in a graph that shows the traffic flow rate versus time. Change-point detection algorithms isolate changes in network traffic statistics and in traffic flow rate caused by attacks. If there is a drastic change in traffic flow rate, a DoS attack may be occurring.

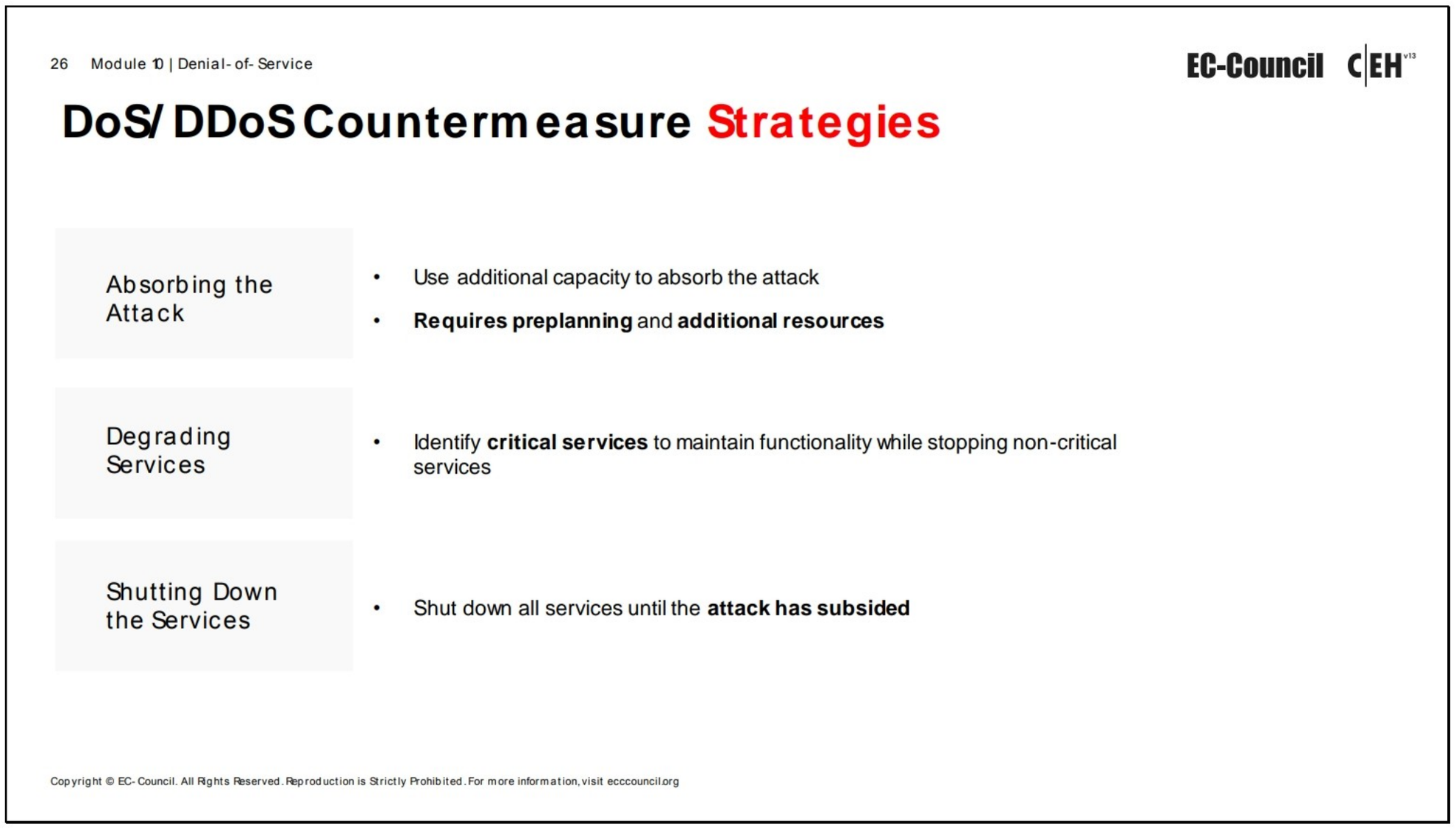
  This technique uses the cumulative sum (CUSUM) algorithm to identify and locate DoS attacks. The algorithm calculates deviations in the actual versus expected local average in the traffic time series. The sequential change-point detection technique identifies the typical scanning activities of network worms.

- **Wavelet-Based Signal Analysis**

  The wavelet analysis technique analyzes network traffic in terms of spectral components. It divides incoming signals into various frequencies and analyzes different frequency components separately. Analyzing each spectral window's energy reveals the presence of anomalies. These techniques check frequency components present at a specific time and provide a description of those components. The presence of an unfamiliar frequency indicates suspicious network activity.

  A network signal consists of a time-localized data packet flow signal and background noise. Wavelet-based signal analysis filters out the input signals of anomalous traffic flow from background noise. Normal network traffic is generally low-frequency traffic. During an attack, the high-frequency components of a signal increase.

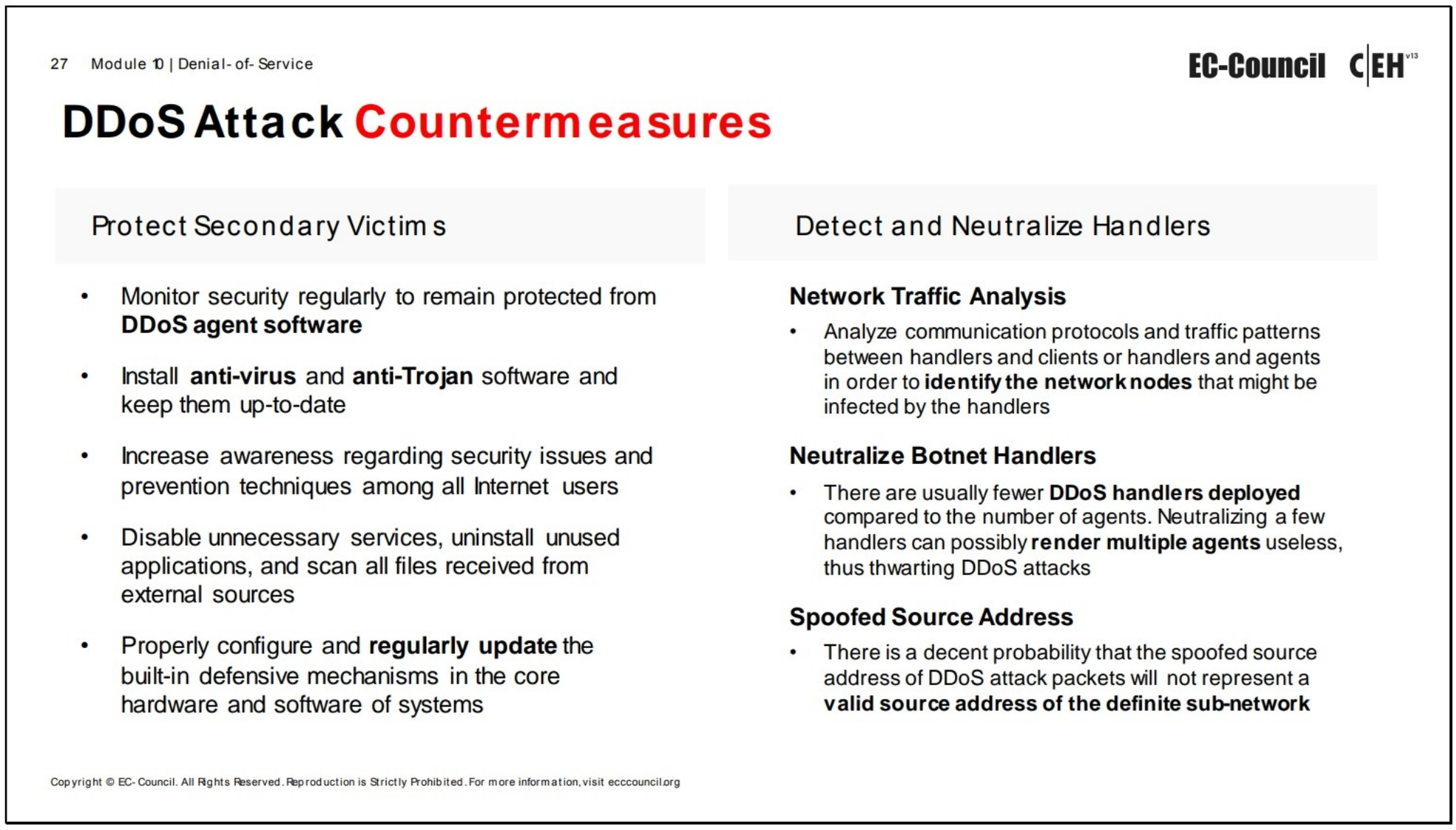
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



DoS/DDoS Countermeasure Strategies

- **Absorbing the Attack**: In this strategy, additional capacity is used to absorb an attack, which requires preplanning. It also requires additional resources. One disadvantage associated with this strategy is the cost of additional resources, which is incurred even when no attacks are underway.
- **Degrading Services**: If it is not possible to keep all services functioning during an attack, it is a good idea to keep at least the critical services functional. For this, the critical services are first identified, following which the network, systems, and application designs are customized to cut down the noncritical services. This strategy may help keep the critical services functional.
- **Shutting Down Services**: In this strategy, all services are shut down until an attack has subsided. Though it may not be the ideal choice, it may be a reasonable response in some cases.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



DDoS Attack Countermeasures

Many solutions have been proposed for mitigating the effects of a DDoS attack. However, no single complete solution exists that can protect all known forms of DDoS attacks. Moreover, attackers continually devise new methods to perform DDoS attacks to bypass the security solutions employed.

The following are examples for DDoS attack countermeasures:

- Protect secondary victims
- Detect and neutralize handlers
- Prevent potential attacks
- Deflect attacks
- Mitigate attacks
- Post-attack forensics

Protect Secondary Victims

- **Individual Users**

  The best method to prevent DDoS attacks is for secondary victim systems to prevent themselves from taking part in the attack. This demands intensified security awareness and prevention techniques. Secondary victims must monitor their security regularly to remain protected from DDoS agent software. It must be ensured that the system does not install any DDoS agent program; further, DDoS agent traffic must not be transferred into the network.

  Antivirus and anti-Trojan software must be installed and updated regularly, as well as software patches to fix known vulnerabilities. Moreover, awareness of security issues and prevention techniques must be increased among all Internet users. It is important to disable unnecessary services, uninstall unused applications, and scan all files received from external sources. Because these tasks may appear daunting to the average web

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

user, the core hardware and software of computing systems come with integrated mechanisms that defend against malicious code insertion. Therefore, the built-in defensive mechanisms in the core hardware and software of the systems must be properly configured and regularly updated to avoid DDoS attacks. Employing the above countermeasures will leave attackers with no DDoS attack network through which they can launch DDoS attacks.

- **Network Service Providers**

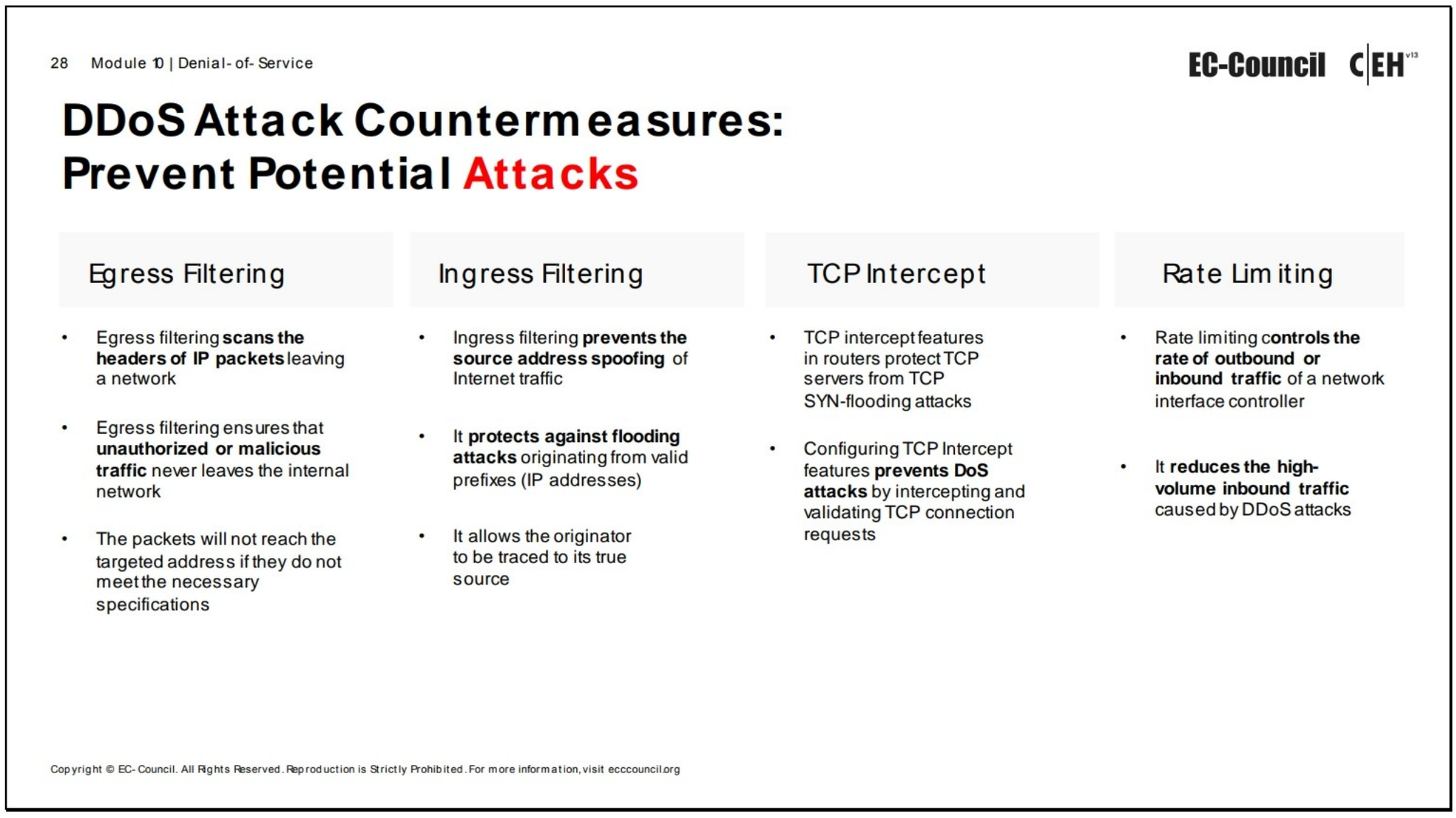
  Service providers and network administrators can adopt dynamic pricing for their network usage to charge potential secondary victims for accessing the Internet and thereby encourage them to become more active in preventing themselves from becoming a part of a DDoS attack.

Detect and Neutralize Handlers

An important method used to stop DDoS attacks is to detect and neutralize handlers. This can be achieved by network traffic analysis, neutralizing botnet handlers, and identifying spoofed source addresses. In the agent-handler DDoS attack-tool arsenal, the handler works as an intermediary for the attacker to initiate attacks. Analyzing communication protocols and traffic patterns between handlers and clients or handlers and agents can reveal the network nodes infected by the handlers. Discovering the handlers in the network and disabling them can be a quick method of disrupting the DDoS attack network. Because the number of DDoS handlers deployed in the network is much less than the number of agents, neutralizing a few handlers can possibly render multiple agents useless, thereby thwarting DDoS attacks.

Furthermore, there is a reasonable probability that the spoofed source address of DDoS attack packets will not represent a valid source address of the definite sub-network. Identifying spoofed source addresses will prevent DDoS attacks with thorough comprehension of communication protocols and traffic among handlers, clients, and agents.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Prevent Potential Attacks

- **Egress Filtering**

  Egress filtering scans the headers of IP packets leaving a network. If the packets meet specifications, they can be routed out of the sub-network from which they originated. On the other hand, the packets do not reach the targeted address if they fail to meet the necessary specifications. Egress filtering ensures that unauthorized or malicious traffic never leaves the internal network.

  DDoS attacks generate spoofed IP addresses. Establishing protocols to require any legitimate packet that leaves a company's network to have a source address in which the network portion matches the internal network can help mitigate attacks. A properly developed firewall for the sub-network can filter out many DDoS packets with spoofed IP source addresses.

  If a web server is vulnerable to a zero-day attack known only to the underground hacker community, a server can be vulnerable even after applying all available patches. However, if the user enables egress filtering, they can save the integrity of a system by keeping the server from establishing a connection back to the attacker. This would also limit the effectiveness of many payloads used in common exploits. Outbound exposure can be restricted to the required traffic, thereby limiting the attacker's ability to connect to other systems and gain access to tools that can enable further access into the network.

- **Ingress Filtering**

  Ingress filtering is a packet filtering technique used by many Internet Service Providers (ISPs) to prevent the source address spoofing of Internet traffic. Thus, ingress filtering

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

can indirectly combat several types of net abuse by making Internet traffic traceable to its true source. It protects against flooding attacks that originate from valid prefixes (IP addresses) and enables the originator to be traced to its true source.

- **TCP Intercept**

  TCP intercept is a traffic-filtering feature in routers to protect TCP servers from a TCP SYN-flooding attack, which is a kind of DoS attack. In a SYN-flooding attack, the attacker sends a huge volume of requests to connect with unreachable return addresses. As the addresses are not reachable, the connections cannot be established and remain unresolved. This huge volume of unresolved open connections overwhelms the server and may cause it to deny service even to valid requests. Consequently, legitimate users may not be able to connect to a website, access email, use an FTP service, and so on.

  In the TCP intercept mode, a router intercepts the SYN packets sent by clients to a server and matches them with an extended access list. If a match is obtained, then on behalf of the destination server, the intercept software establishes a connection with the client. Similarly, the intercept software also establishes a connection with the destination server on behalf of the client. Once the two half connections are established, the intercept software combines them transparently. Thus, the TCP intercept software prevents fake connection attempts from reaching the server by acting as a mediator between the server and client throughout the connection.

- **Rate Limiting**

  Rate limiting is a technique used to control the rate of outbound or inbound traffic of a network interface controller. This technique effectively reduces the high volume of inbound traffic that causes a DDoS attack. It is especially important to employ this technique in hardware appliances, in which the technique is configured to limit the rate of requests on layers 4 and 5 of the Open Systems Interconnection (OSI) model.

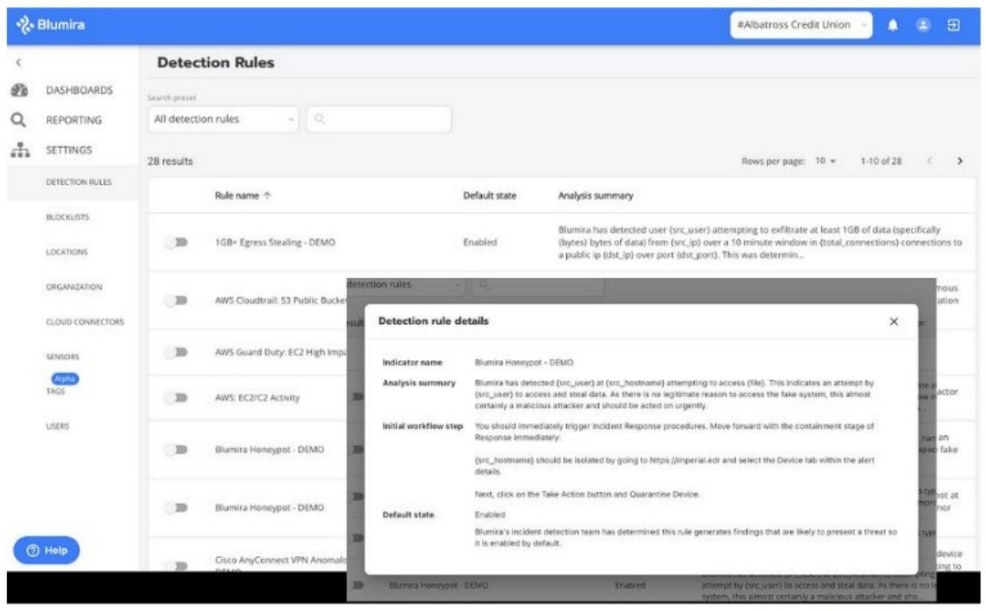
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

DDoS Attack Countermeasures: Deflect Attacks

- Systems that are set up with limited security, also known as **Honeypots**, act as an enticement for an attacker
- Honeypots serve as a means of **gaining information** about attackers, **attack techniques**, and tools by storing a record of the system activities
- The defense-in-depth approach is used with IPSes at different network points to divert **suspicious DoS traffic** to several honeypots

Blumira Honeypot Software

Blumira honeypot software helps security professionals **detect unauthorized access attempts** and the attackers' lateral movement



https://www.blumira.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Deflect Attacks

Systems set up with limited security, also known as honeypots, act as enticement for an attacker. Recent research reveals that a honeypot can imitate all aspects of a network, including its web servers, mail servers, and clients. Honeypots are intentionally set up with low security to gain the attention of DDoS attackers and serve as a means for gaining information about attackers, attack techniques, and tools by storing a record of the system activities. DDoS attackers attracted by a honeypot install handlers or agent code within the honeypot. This avoids compromising systems that are more sensitive. Honeypots not only protect the actual system from attackers but also keep track of details on the attackers' activities by recording the activity information. Consequently, the honeypot owner can keep a record of the handler and/or agent activity. Users can employ this knowledge to defend against any future DDoS installation attacks. A defense-in-depth approach with Internet Protocol Security (IPsec) can be used at different network points to divert suspicious DoS traffic to several honeypots.

There are two different types of honeypots:

- Low-interaction honeypots
- High-interaction honeypots

An example for high-interaction honeypots is a honeynet. Honeynets form the security infrastructure; in other words, they simulate the complete layout of a network of computers but are originally intended for "capturing" attacks. The goal is to develop a network wherein all activities are controlled and tracked. This network contains potential victim decoys, and the network even has real computers running real applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Blumira Honeypot Software**

  Source: *https://www.blumira.com*

  Blumira honeypot software is a type of deception technology that helps security professionals detect unauthorized access attempts and the attackers' lateral movement (if a breach has already occurred) across an organization's network. It also aids in enhancing the organization's security maturity and in detecting attacks early—all with low maintenance and overhead. Once Blumira detects a honeypot security event, it immediately blocks the source IP at the switch or firewall level.

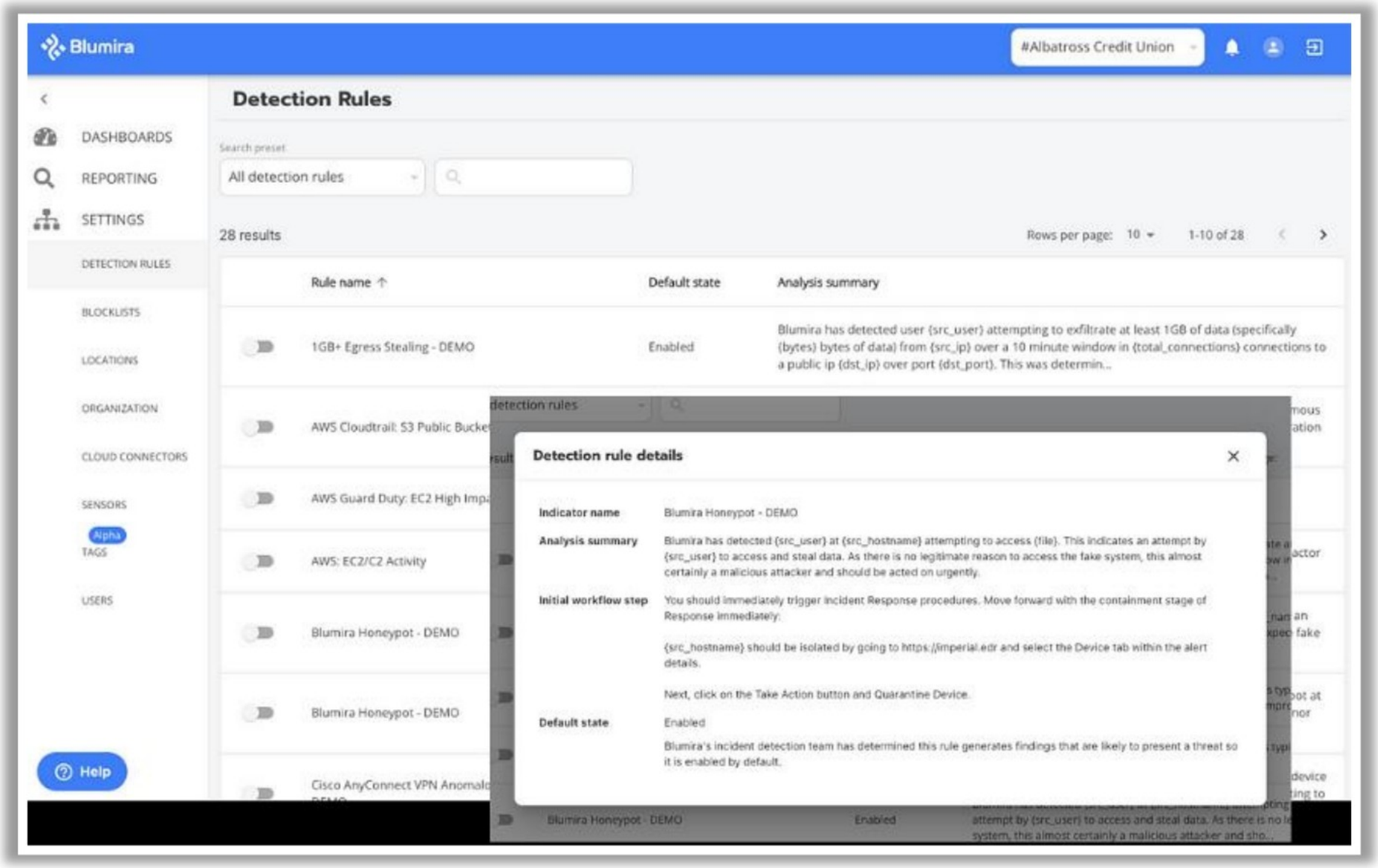
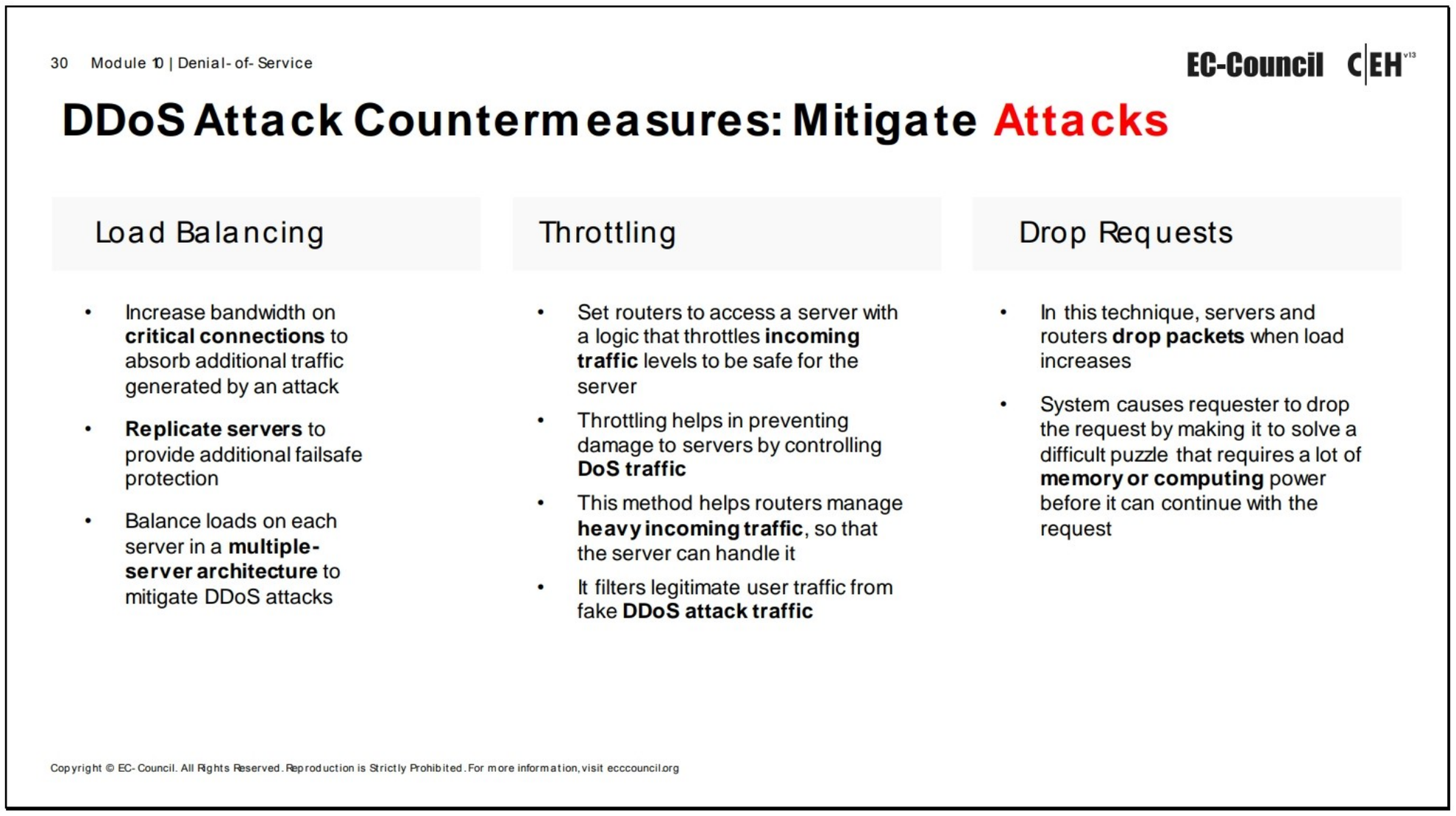


Figure 10.34: Screenshot of Blumira honeypot software

The following are examples for additional DoS/DDoS countermeasure (honeypot) tools:

- KFSensor (*https://www.kfsensor.net*)
- Valhala Honeypot (*https://sourceforge.net*)
- Cowrie (*https://github.com*)
- HoneyHTTPD (*https://github.com*)
- StingBox (https://www.stingbox.com)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Mitigate Attacks

- **Load Balancing**

  Bandwidth providers can increase bandwidth on critical connections in case of a DDoS attack to prevent their servers from shutting down. Using a replicated server model provides additional failsafe protection. Replicated servers help in better load management by balancing loads on each server in a multiple-server architecture; they also increase normal network performance and mitigate the effect of a DDoS attack.

- **Throttling**

  Throttling entails the setting up of routers for server access with a logic to throttle incoming traffic levels that are safe for the server. “Min-max fair server-centric router” throttles (minimum and maximum throughput controls) help users prevent their servers from shutting down. Throttling helps in preventing damage to servers by controlling the DoS traffic. This method helps routers manage heavy incoming traffic so that the server can handle it. It also filters legitimate user traffic from fake DDoS attack traffic and can be extended to throttle DDoS attack traffic while allowing legitimate user traffic for better results.

  A major limitation of this method is that it may trigger false alarms. Occasionally, it may allow malicious traffic to pass through while dropping some legitimate traffic.

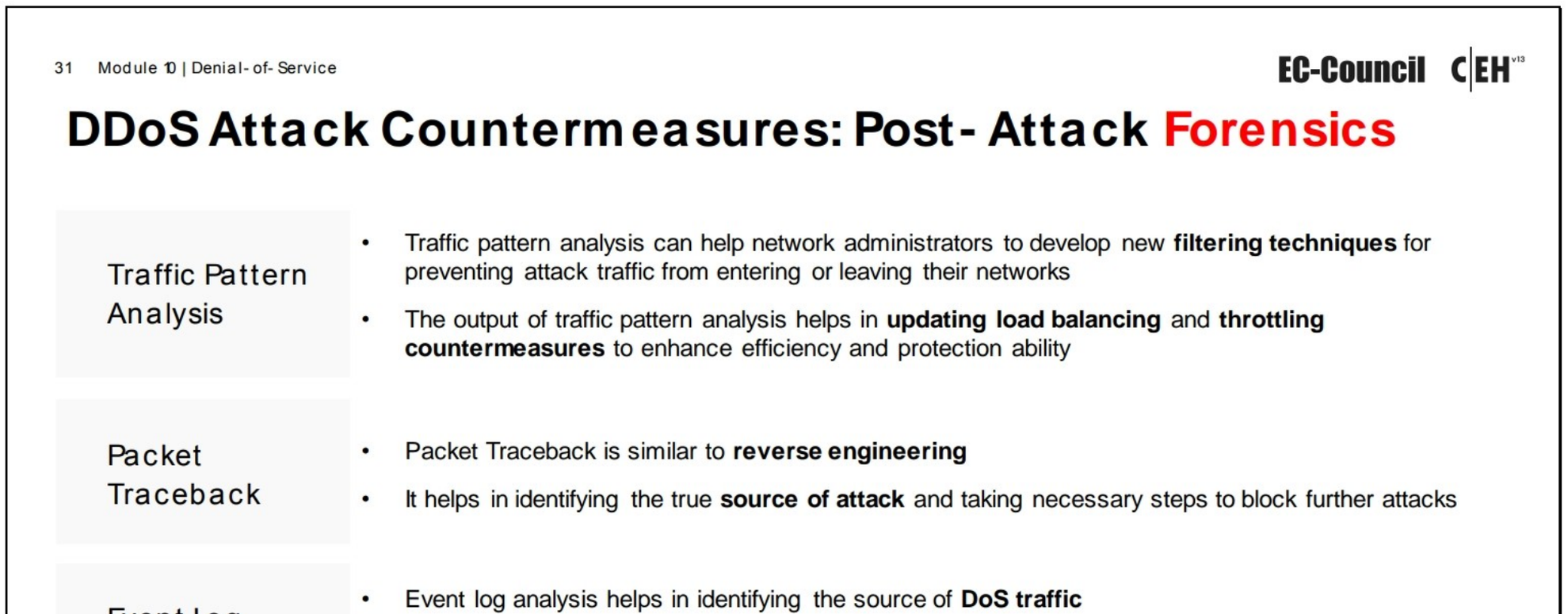
- **Drop Requests**

  Another method is to drop packets when the load increases. Usually, the router or server performs this task. However, before continuing with a request, the system induces the requester to drop the request by making them solve a difficult puzzle that requires a lot of memory or computing power. Consequently, users of zombie systems

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

detect a performance degradation and could possibly be dissuaded from taking part in transferring DDoS attack traffic.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Post-Attack Forensics

- **Traffic Pattern Analysis**

  During a DDoS attack, the traffic pattern tool stores post-attack data, which users analyze to identify characteristics unique to the attacking traffic. These data are helpful in updating load balancing and throttling countermeasures to enhance their efficiency and protection ability. Moreover, DDoS attack traffic patterns can help network administrators develop new filtering techniques to prevent DDoS attack traffic from entering or leaving their networks. Analyzing DDoS traffic patterns can also help network administrators ensure that an attacker cannot use their servers as a DDoS platform to break into other sites.

- **Packet Traceback**

  Packet traceback refers to tracing back attack traffic. It is similar to reverse engineering. In this method, the targeted victim works backward by tracing the packet to its source. Once the victim identifies the true source, they can take steps to block further attacks from that source by developing the necessary preventive techniques. In addition, packet traceback can assist in gaining knowledge of the various tools and techniques that an attacker uses. This information can help in developing and implementing different filtering techniques to block attacks.

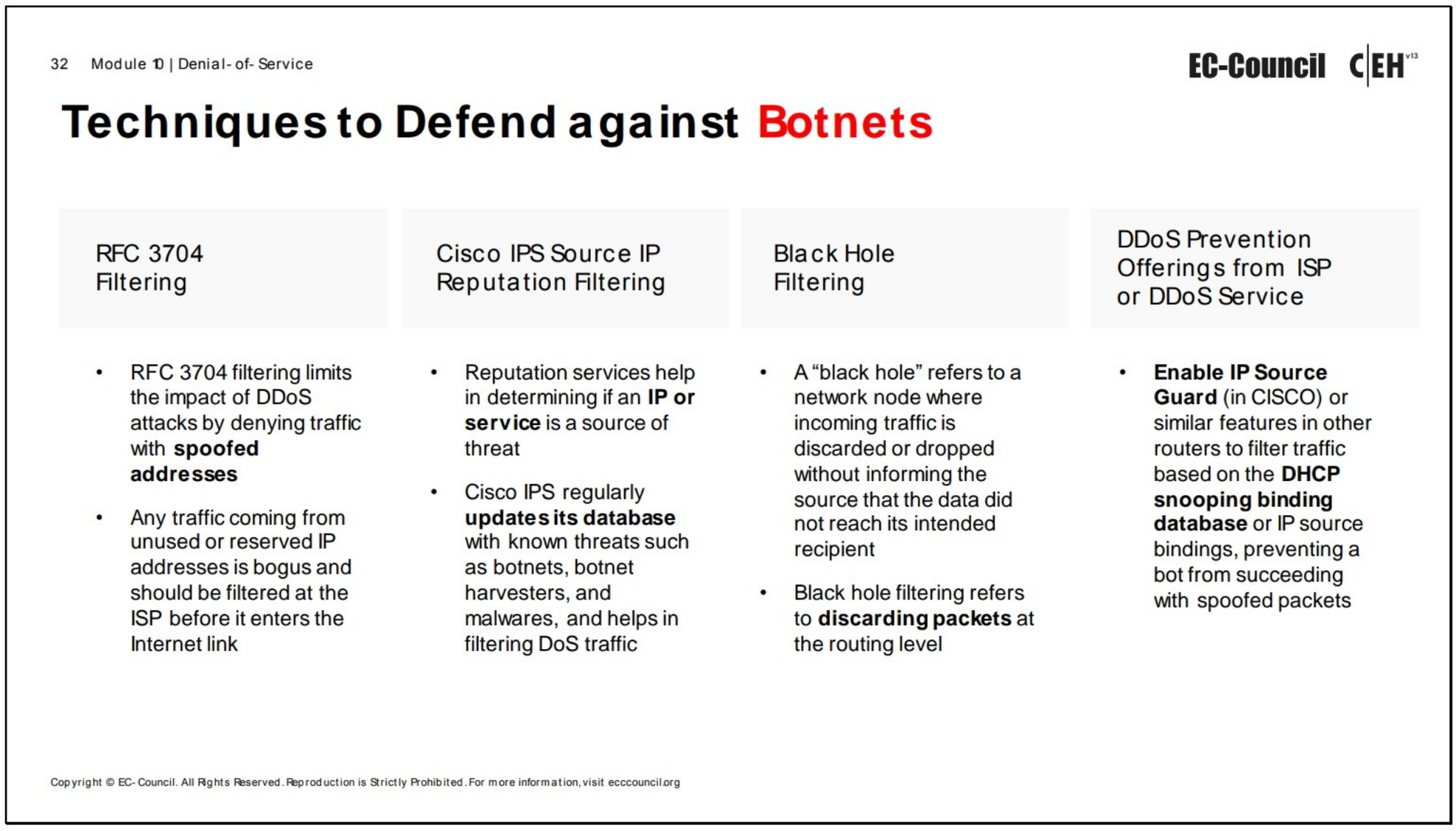
- **Event Log Analysis**

  DDoS event logs assist in forensic investigation and the enforcement of laws, which are helpful when an attacker causes severe financial damage. Providers can use honeypots and other network security mechanisms such as firewalls, packet sniffers, and server logs to store all the events that occurred during the setup and execution of the attack.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This allows network administrators to recognize the type of DDoS attack or the combination of attacks used. Routers, firewalls, and IDS logs can be analyzed to identify the source of the DoS traffic. Further, network administrators can attempt to trace back the attacker's IP address with the help of intermediary ISPs and law enforcement agencies.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Techniques to Defend against Botnets

There are four techniques to defend against botnets:

- **RFC 3704 Filtering**

  RFC 3704 is a basic access-control list (ACL) filter, which limits the impact of DDoS attacks by blocking traffic with spoofed addresses. This filter requires packets sourced from valid, allocated address space that is consistent with the topology and space allocation. A "bogon list" consists of all unused or reserved IP addresses that should not come from the Internet. If a packet is sourced from any of the IP addresses from the bogon list, then the packet is from a spoofed source IP, and the filter should drop it. System administrators should check whether the ISP performs RFC 3704 filtering in the cloud before traffic enters the system. Because the bogon list changes regularly, in case the ISP does not perform RFC 3704 filtering, the system administrator must manage their own bogon ACL rules or switch to another ISP.

- **Cisco IPS Source IP Reputation Filtering**

  Reputation services help in determining whether an IP or service is a source of threat. Cisco Global Correlation, a new security capability of Cisco IPS 7.0, uses immense security intelligence. The Cisco SensorBase Network contains information about all known threats on the Internet, such as botnets, malware outbreaks, dark nets, and botnet harvesters. The Cisco IPS makes use of this network to filter DoS traffic before it damages critical assets. To detect and prevent malicious activity even earlier, it incorporates global threat data into its system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Black Hole Filtering**

  Black-hole filtering is a common technique to defend against botnets and, thus, to prevent DoS attacks. Black holes refer to network nodes wherein incoming traffic is discarded or dropped without informing the source that the data did not reach the intended recipient. Undesirable traffic can be dropped before it enters a protected network with a technique called remotely triggered black-hole (RTBH) filtering. As this is a remotely triggered process, this filtering must be performed in conjunction with the ISP. It uses Border Gateway Protocol (BGP) host routes to route traffic to the victim's servers to a "null0" next hop.

- **DDoS Prevention Offerings from ISP or DDoS Service**

  This method is effective in preventing IP spoofing at the ISP level. Here, the ISP scrubs/cleans traffic before allowing it to enter a user's Internet link. Because this service runs in the cloud, DDoS attacks do not saturate the Internet links. In addition, some third parties offer cloud DDoS prevention services.

  IP Source Guard (in CISCO) or similar features can be enabled in other routers to filter traffic based on the DHCP snooping binding database or IP source bindings, which prevent bots from sending spoofed packets.

Additional DoS/DDoS Countermeasures

Implementing defensive mechanisms at proper places by following proper measures allows the heightening of organizational network security. The following is a list of countermeasures for combating DoS/DDoS attacks:

- Use strong encryption mechanisms such as WPA2/WPA3 and AES 256 for broadband networks to defend against eavesdropping
- Ensure that the software and protocols are up-to-date and scan the machines thoroughly to detect any anomalous behavior
- Update the kernel to the latest release and disable unused and insecure services
- Block all inbound packets originating from the service ports to block traffic from reflection servers
- Enable TCP SYN cookie protection
- Prevent the transmission of fraudulently addressed packets at the ISP level
- Implement cognitive radios in the physical layer to handle jamming and scrambling attacks
- Configure the firewall to deny external Internet Control Message Protocol (ICMP) traffic access
- Secure remote administration and connectivity testing
- Perform thorough input validation
- Prevent the use of unnecessary functions such as gets and strcpy

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Use advanced network-level surveillance technologies to monitor the network perimeter
- Ensure that the semi-accessible connections are enabled with assertive timeout functions
- Implement distributed server model and colocation services as a backup service model to reduce server overloading during DDoS attacks
- Ensure that the servers are free of bottlenecks and failure points
- Use third-party protection services to accommodate enhanced security from many major DDoS attacks
- Use multi-cloud deployment models for major applications to ensure proper backup during DDoS attacks on a cloud platform
- Perform extensive simulations of DoS/DDoS attacks to avoid sudden surges and maintain a proper counteraction strategy
- Share information with industry peers and leverage threat intelligence feeds to stay updated on DDoS attack trends
- Use AI/ML and anomaly detection systems to automatically identify and flag deviations from typical traffic behavior
- Limit the network broadcasting
- Disable services such as echo and chargen

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

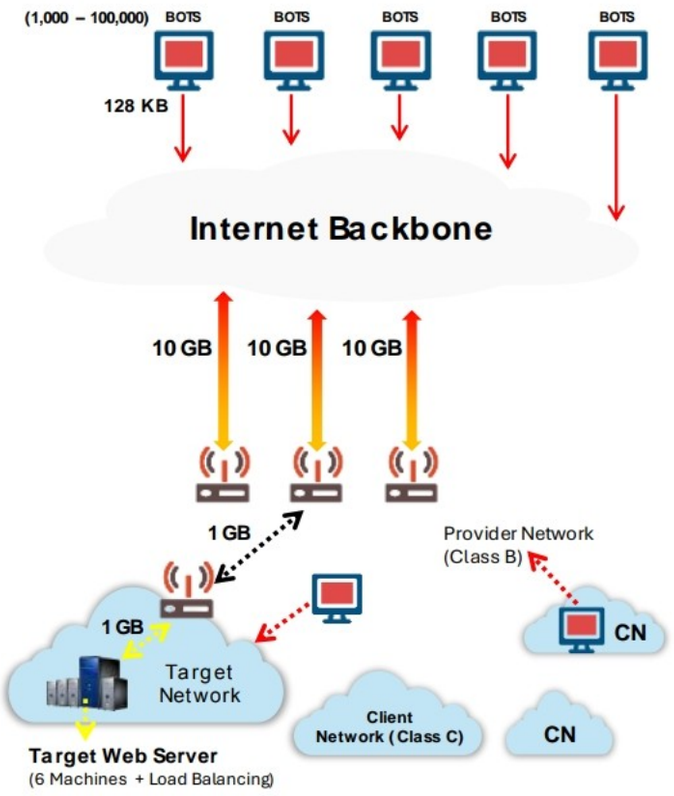
DoS/DDoS Protection at ISP Level

Most ISPs simply block all requests during a **DDoS attack**, **denying even the legitimate traffic** from accessing the service

ISPs offer in-the-cloud DDoS protection for Internet links so that they do not become **saturated by the attack**

In-the-cloud DDoS protection **redirects attack traffic** to the ISP during the attack and sends it back

Administrators can **request ISPs** to block the original affected IP and move their site to another IP after performing DNS propagation



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

DoS/DDoS Protection at ISP Level

One of the best ways to defend against DoS attacks is to block them at the gateway. This task is performed by the contracted ISP. ISPs offer a “clean pipes” service-level agreement that provides an assured bandwidth of genuine traffic, rather than the total bandwidth of all traffic. Most ISPs simply block all requests during a DDoS attack, denying even legitimate traffic from accessing the service. If an ISP does not provide clean-pipes services, subscription services provided by many cloud service providers can be used. The subscription services serve as an intermediary, receive traffic destined for the network, filter it, and then pass on only trusted connections. Vendors such as Imperva and VeriSign offer services for cloud protection against DoS attacks.

ISPs offer in-the-cloud DDoS protection for Internet links to avoid saturation due to an attack. This type of protection redirects attack traffic to the ISP during an attack. Administrators can request ISPs to block the original affected IP and move their site to another IP after performing DNS propagation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

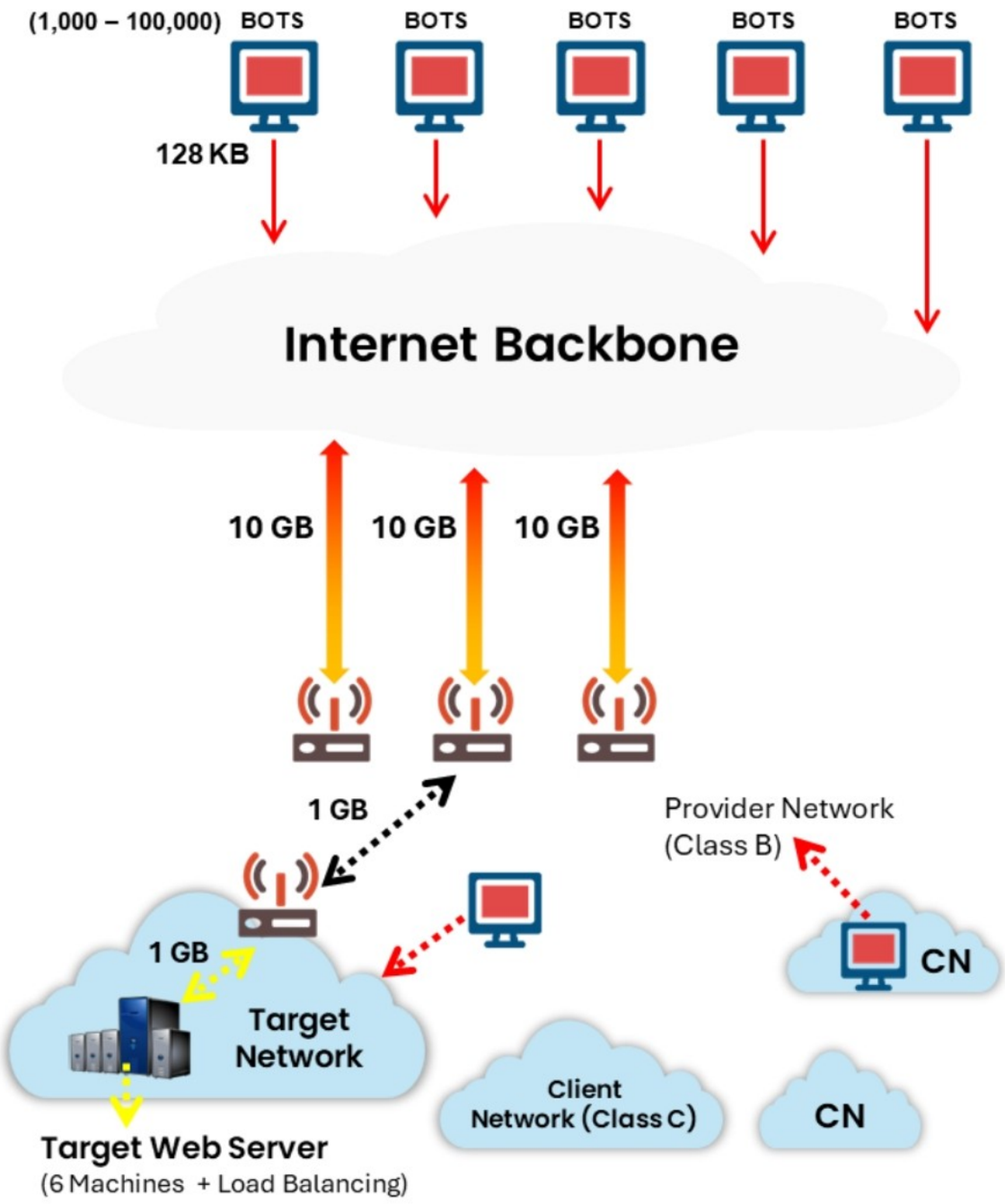


Figure 10.35: DoS/DDoS protection at the ISP level

Enabling TCP Intercept on Cisco IOS Software

Source: *https://www.cisco.com*

TCP intercept can be enabled by executing the commands given in the below table in the global configuration mode.

Step	Command	Purpose
1	`access-list access-list-number {deny | permit} tcp any destination destination-wildcard`	Defines an IP extended access list
2	`ip tcp intercept list access-list-number`	Enables TCP intercept

Table 10.1: Steps to enable TCP intercept on Cisco IOS

An access list achieves three purposes:

1. Interception of all requests
2. Interception of only requests originating from specific networks
3. Interception of only requests destined for specific servers

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Typically, an access list defines the source as any source and the destination as specific networks or servers. As it is unimportant to know who to intercept packets from, the source addresses are not filtered. Rather, the destination server or network to be protected is identified. TCP intercept can operate in either the active intercept mode or passive watch mode. The default is the intercept mode.

In the active intercept mode, the Cisco IOS software actively intercepts all inbound connection requests (SYN) and replies with a SYN-ACK on behalf of the server, following which it waits for an acknowledge (ACK) from the client. On receiving the ACK from the client, the server sends the original SYN, and the software makes a three-way handshake with the server. Once the three-way handshake is complete, the two half connections are linked.

In the passive watch mode, the user sends connection requests that pass through the server, but they need to wait until the connection is established. If connection requests fail to establish within 30 s, the software sends a reset request to the server to clear its state.

Below table presents the command to set the TCP intercept mode in the global configuration mode.

Command	Purpose
`ip tcp intercept mode {intercept | watch}`	Set the TCP intercept mode

Table 10.2: Command to set the TCP intercept mode in the global configuration mode

Advanced DDoS Protection Appliances

The following are examples for appliances that provide advanced protection against DDoS attacks.

- **FortiDDoS 200F, 1500E, 1500E-DC, 1500F, 2000E, 2000E-DC, and VM04/08/16**

  Source: *https://www.fortinet.com*

  FortiDDoS is massively parallel machine-learning architecture that delivers the most advanced and lowest-latency DDoS attack mitigation without the performance compromises normally associated with CPU-based systems. FortiDDoS inspects both inbound and outbound Layer 3, 4, and 7 packets to the smallest sizes, resulting in the fastest and most accurate detection and mitigation.

Figure 10.36: FortiDDoS-1500F

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Quantum DDoS Protector**

  Source: *https://www.checkpoint.com*

  Check Point's Quantum DDoS Protector blocks DDoS attacks with multi-layered protection. Its advantages are listed as follows:

  - Blocks a wide range of attacks with customized multi-layered protection
    - Behavioral protection base-lining multiple elements and blocking abnormal traffic
    - Automatically generated and predefined signatures
    - Use of advanced challenge/response techniques
  - Fast response time to protect against attacks within seconds
    - Automatically defends against network flood and application layer attacks
    - Customized protection optimized to meet the security needs of a specific network environment
    - Quickly filters traffic before it reaches the firewall to protect networks and servers as well as block exploits
  - Flexible deployment options to protect any business
  - Integrated with Check Point Security Management

Figure 10.37: Check Point's Quantum DDoS Protector

- **Huawei AntiDDoS1000 DDoS protection system**

  Source: *https://e.huawei.com*

  The Huawei AntiDDoS1000 DDoS protection system utilizes Big Data analytics technology and supports modeling for 60+ types of network traffic to offer second-level attack response and comprehensive defense against 100+ types of attacks. The AntiDDoS1000 can be deployed on a user network using in-line mode to defend against volumetric and application attacks in real time. When attack traffic exceeds the bandwidth or defense capability of a local scrubbing device, the AntiDDoS1000 associates with the AntiDDoS device of the upstream carrier or ISP to defend against flood attacks and guarantee service continuity.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

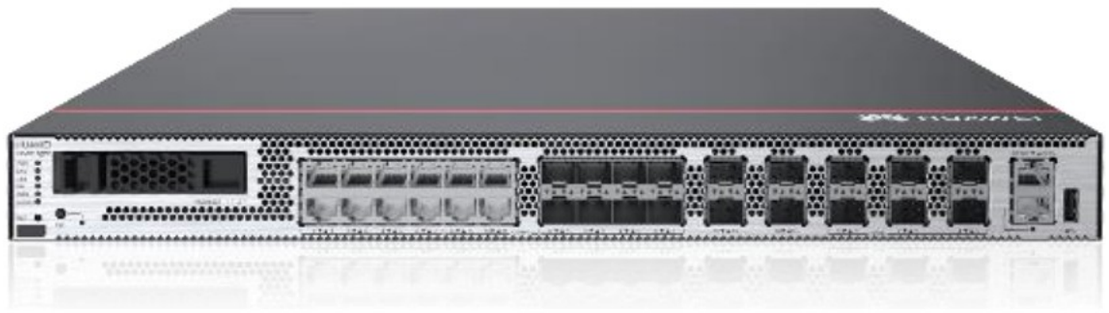


Figure 10.38: Huawei AntiDDoS1000 DDoS protection system

- **A10 Thunder TPS**

  Source: *https://a10networks.optrics.com*

  A10 Thunder Threat Protection System (TPS) ensures reliable access to key network services by detecting and blocking external threats such as DDoS and other cyber-attacks before they escalate into costly service outages. Its features are listed as follows:

  - Maintain service availability
  - Defeat growing attacks
  - Scalable protection
  - Reduce security OpEx

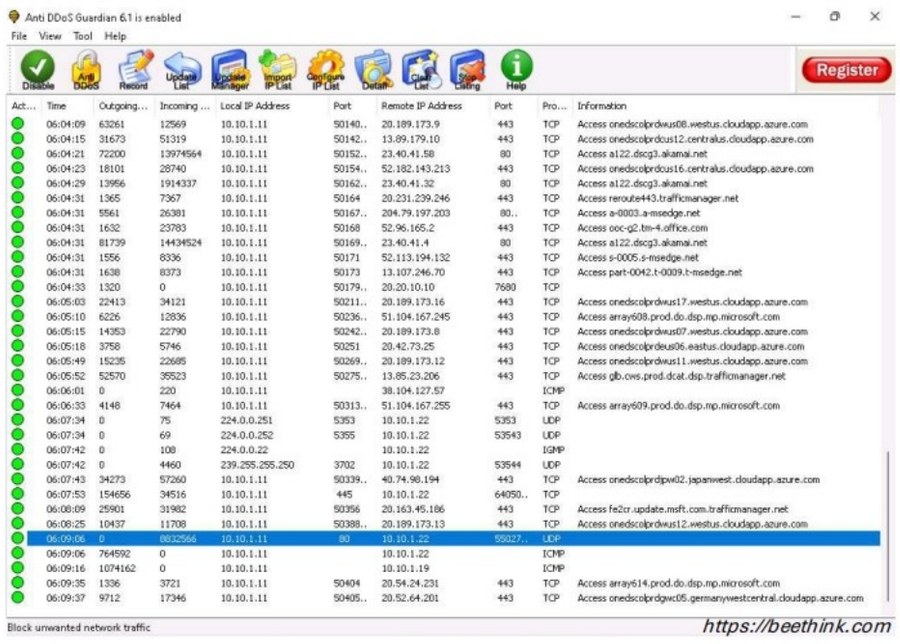
Figure 10.39: A10 Thunder TPS

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

DoS/DDoS Protection Tools

Anti DDoS Guardian

A DDoS attack protection tool that protects **IIS servers**, **Apache serves**, game servers, Camfrog servers, **mail servers**, FTP servers, VOIP PBX, SIP servers, and other systems



DDoS-Guard
https://ddos-guard.net

DOSarrest's DDoS protection service
https://www.dosarrest.com

Radware DefensePro X
https://www.radware.com

Gatekeeper
https://github.com

F5 DDoS Attack Protection
https://www.f5.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

DoS/DDoS Protection Tools

- **Anti DDoS Guardian**

  Source: *https://beethink.com*

  Anti DDoS Guardian is a DDoS attack protection tool. It protects IIS servers, Apache serves, game servers, Camfrog servers, mail servers, FTP servers, VOIP PBX, SIP servers, and other similar systems. Anti DDoS Guardian monitors each incoming and outgoing packet in real time. It displays the local address, remote address, and other information of each network flow. Anti DDoS Guardian limits network flow number, client bandwidth, client concurrent TCP connection number, and TCP connection rate. It also limits the UDP bandwidth, UDP connection rate, and UDP packet rate.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

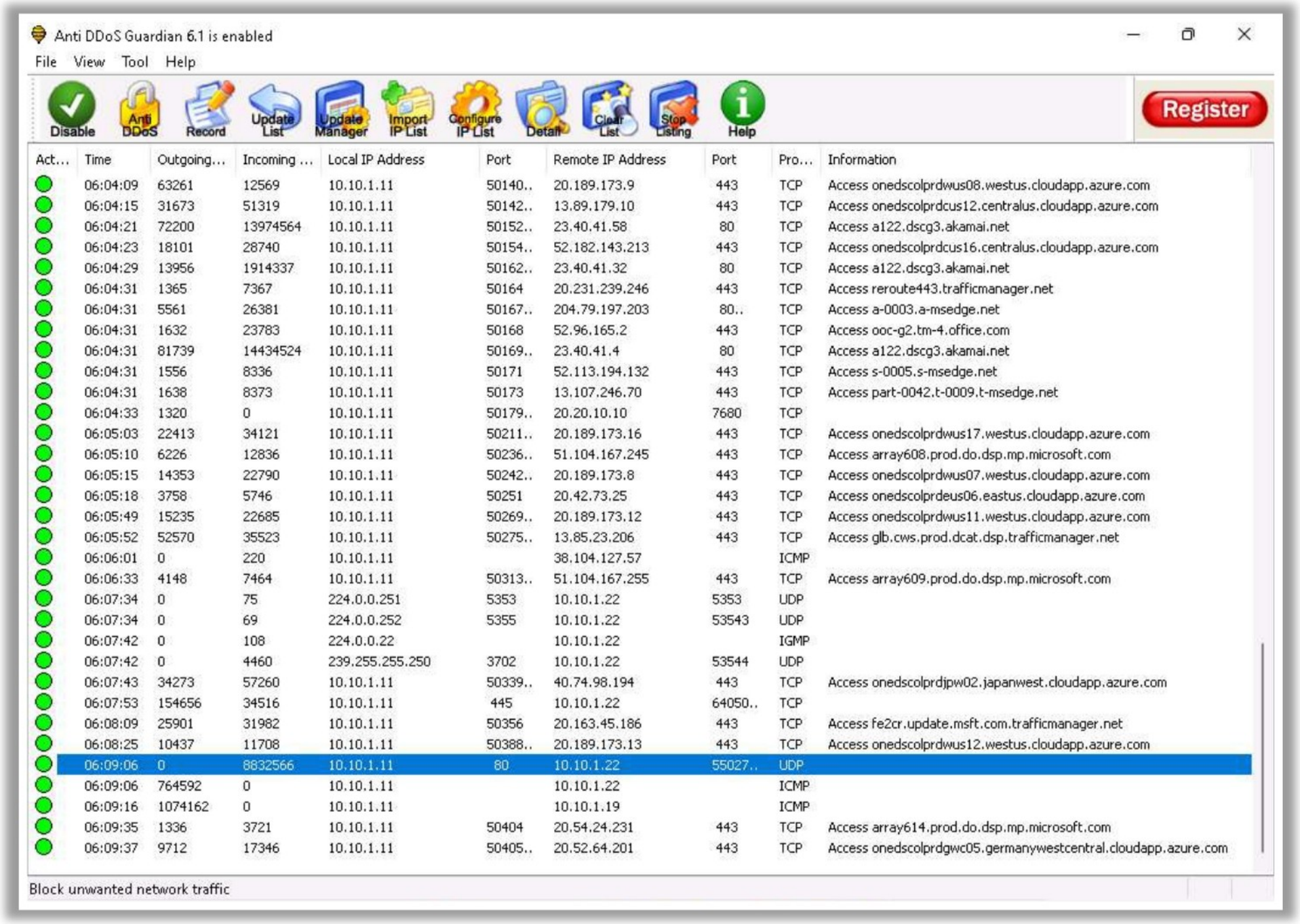
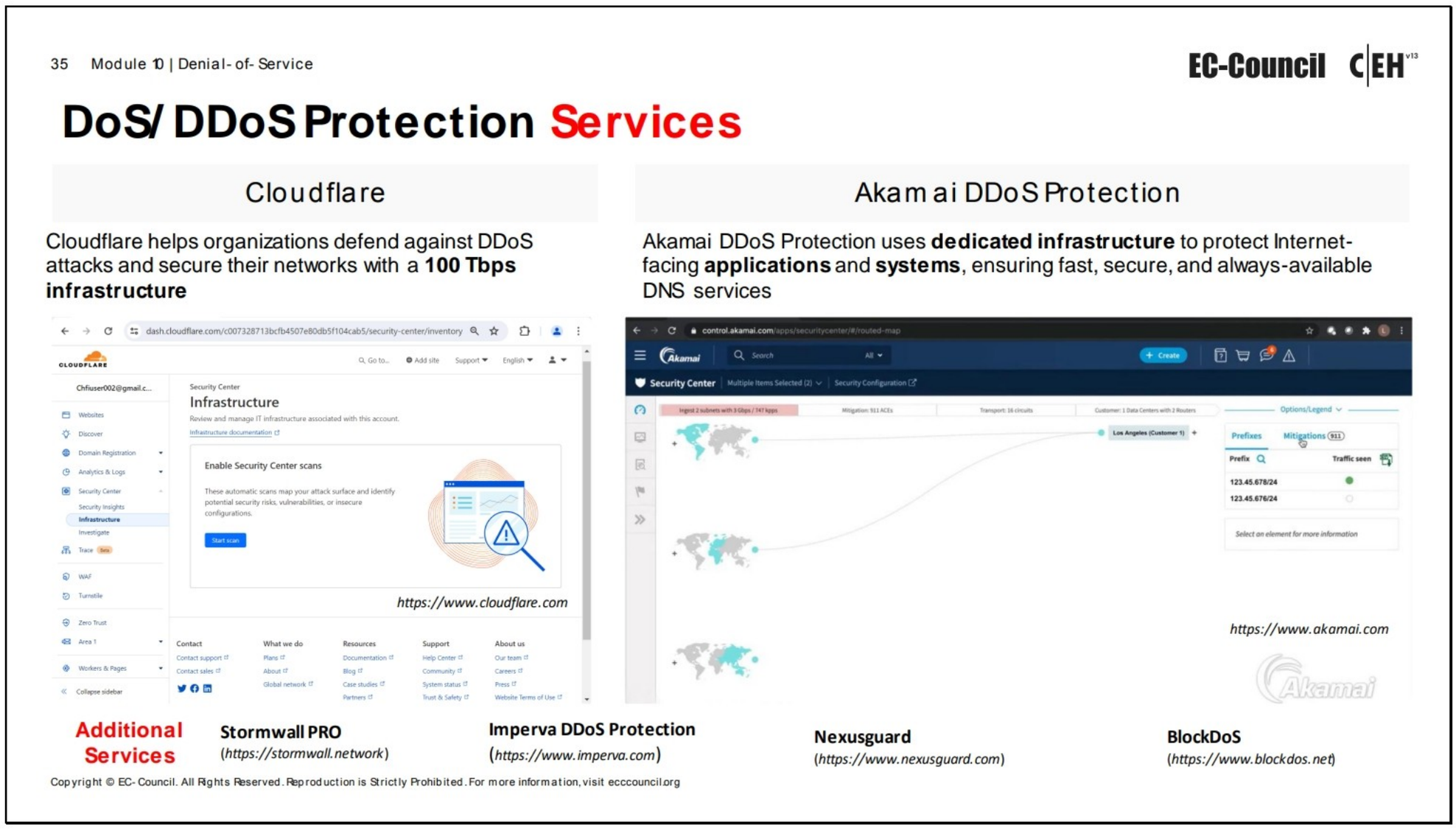


Figure 10.40: Screenshot of Anti DDoS Guardian

The following are examples for other DDoS protection tools:

- DDoS-GUARD (*https://ddos-guard.net*)
- DOSarrest's DDoS protection service (*https://www.dosarrest.com*)
- Radware DefensePro X (*https://www.radware.com*)
- Gatekeeper (*https://github.com*)
- F5 DDoS Attack Protection (*https://www.f5.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



DoS/DDoS Protection Services

- **Cloudflare**

  Source: *https://www.cloudflare.com*

  Cloudflare's DDoS protection service helps organizations defend against distributed denial-of-service attacks and secure their networks by leveraging a 100 Tbps network that blocks an average of 87 billion threats daily. The service provides rapid mitigation within three seconds, using advanced techniques such as BGP-based protection and integration with L7 services, ensuring comprehensive security and reduced operational costs.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

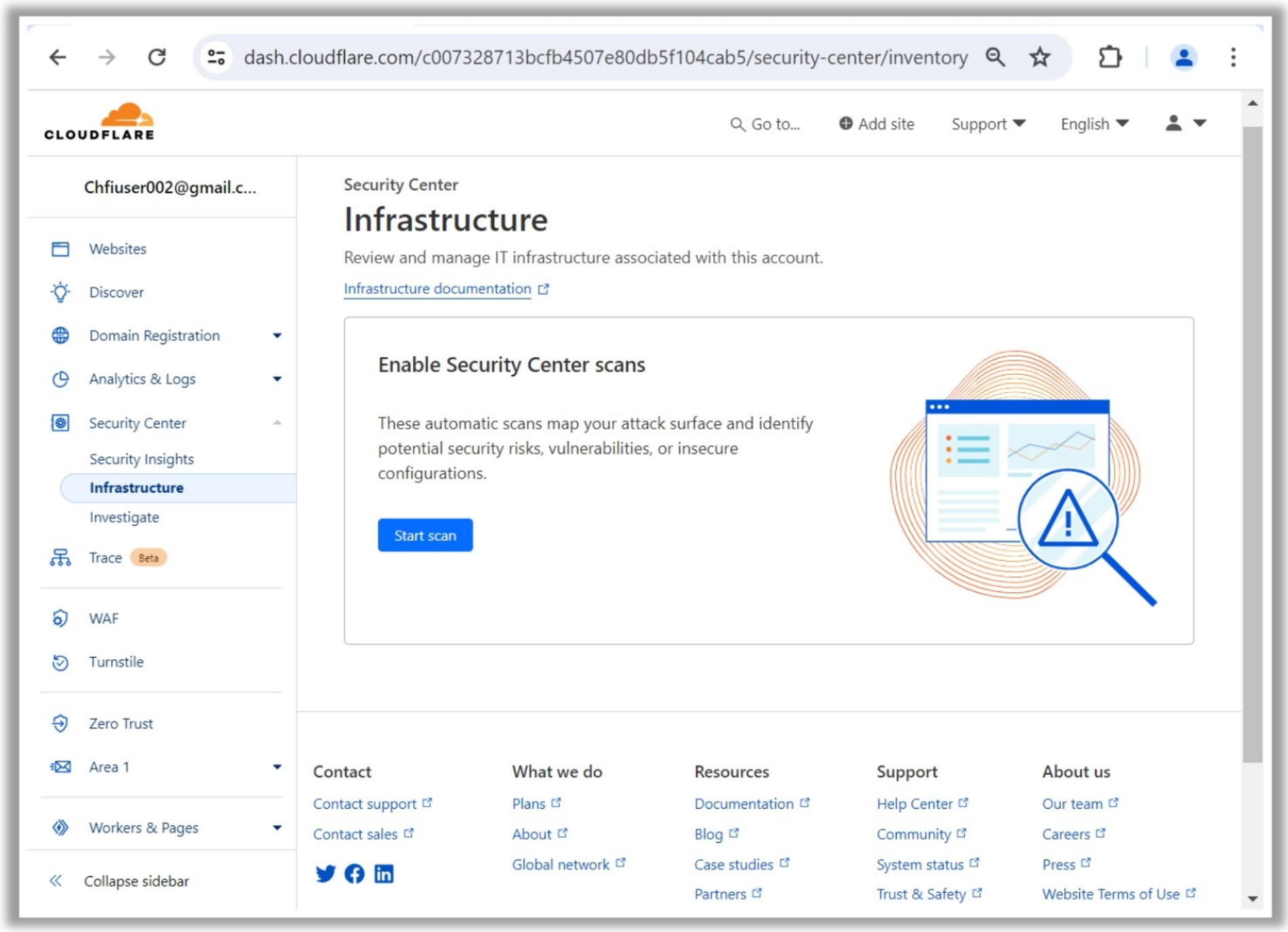


Figure 10.41: Screenshot of Cloudflare dashboard

- **Akamai DDoS Protection**

  Source: *https://www.akamai.com*

  Akamai DDoS Protection leverages dedicated infrastructure to safeguard Internet-facing applications and systems while ensuring fast, secure, and always-available DNS services. It stops DDoS attacks and malicious traffic in the cloud before they reach the applications, data centers, and infrastructure, eliminating the requirement for multiple firewalls.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

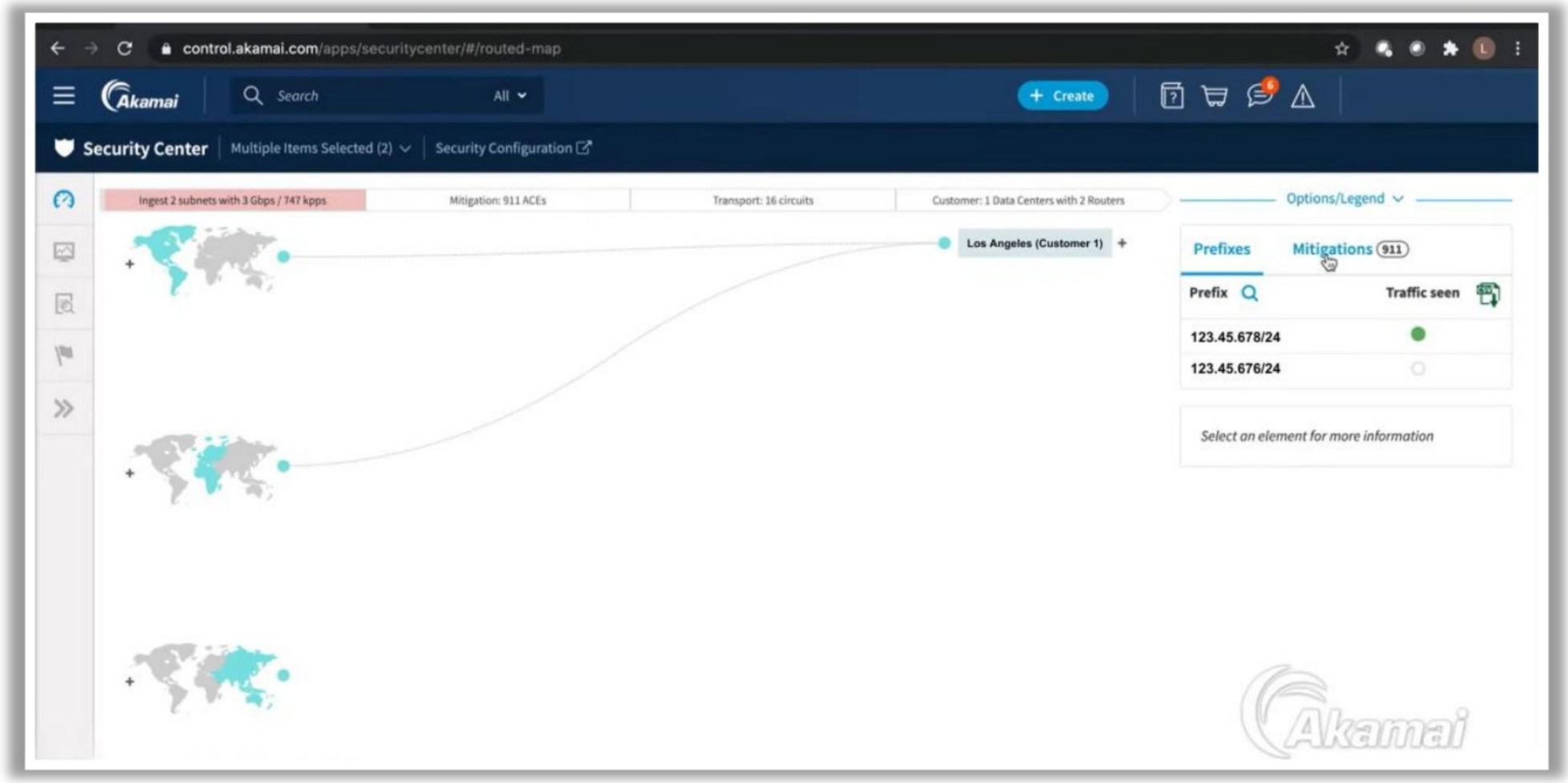


Figure 10.42: Screenshot of Akamai console

The following are examples of other DDoS protection services:

- Stormwall PRO (*https://stormwall.network*)
- Imperva DDoS Protection (*https://www.imperva.com*)
- Nexusguard (*https://www.nexusguard.com*)
- BlockDoS (*https://www.blockdos.net*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Module Summary

- In this module, we have discussed the following:
  - ✓ Concepts of denial-of-service (DoS) and distributed denial-of-service (DDoS) attacks
  - ✓ Concept of botnets along with the botnet ecosystem
  - ✓ Various types of DoS/DDoS attacks
  - ✓ Various DoS/DDoS attack tools
  - ✓ A detailed DDoS case study, namely, the DDoS Attack on Google Cloud - HTTP/2 'Rapid Reset' Attack
  - ✓ We concluded with a detailed discussion on various countermeasures that are to be employed to prevent DoS/DDoS attacks along with various hardware and software DoS/DDoS protection tools
- In the next module, we will discuss in detail how attackers, as well as ethical hackers and pen-testers, perform session hijacking to steal a valid session ID

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Module Summary

In this module, we discussed concepts related to denial-of-service (DoS) and distributed denial-of-service (DDoS) attacks. We also discussed concepts related to botnets along with the botnet ecosystem. Moreover, we illustrated various DoS/DDoS attack tools and also discussed various types of DoS/DDoS attacks. Further, a detailed case study on Google Cloud HTTP/2 'Rapid Reset' attack was presented. We concluded with a detailed discussion on various countermeasures to prevent DoS/DDoS attacks, along with various hardware and software DoS/DDoS protection tools.

In the next module, we will discuss in detail how attackers, as well as ethical hackers and pen testers, perform session hijacking to steal a valid session ID.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.